Tema 25 · Bloque II | 60 preguntas de test

Accesibilidad, seguridad del puesto y desarrollo seguro

Diseño universal y usabilidad · WCAG y EN 301 549 · Confidencialidad y disponibilidad en el puesto de usuario final · Seguridad en el desarrollo de los sistemas

Enunciado oficial del programa (BOAM n.º 10.032, de 23 de diciembre de 2025): Accesibilidad, diseño universal y usabilidad. Acceso y usabilidad de las tecnologías, productos y servicios relacionados con la sociedad de la información. Confidencialidad y disponibilidad de la información en puestos de usuario final. Conceptos de seguridad en el desarrollo de los sistemas.

EXTENSIÓN
~22.500 palabras · 14 diagramas · 60 preguntas de test

TIEMPO ESTIMADO DE ESTUDIO
19–21 horas (primera vuelta completa, sin contar repasos)

Índice

- [ ] **1. Accesibilidad, diseño universal y usabilidad**
  - [ ] **1.1. Principios de usabilidad y experiencia de usuario**
  - [ ] **1.2. Fundamentos del diseño universal y diseño para todos**
  - [ ] **1.3. Modelos de calidad e ISO/IEC 9241 e ISO/IEC 25010**
- [ ] **2. Acceso y usabilidad de las tecnologías, productos y servicios de la sociedad de la información**
  - [ ] **2.1. Pautas de accesibilidad al contenido web WCAG**
  - [ ] **2.2. Requisitos de accesibilidad TIC y norma EN 301 549**
  - [ ] **2.3. Marco normativo en la Administración Pública**
  - [ ] **2.4. Evaluación, auditoría y declaración de accesibilidad**
- [ ] **3. Confidencialidad y disponibilidad de la información en puestos de usuario final**
  - [ ] **3.1. Seguridad en el puesto de usuario final**
  - [ ] **3.2. Control de acceso y protección criptográfica**
  - [ ] **3.3. Seguridad operativa y prevención de pérdida de datos**
- [ ] **4. Conceptos de seguridad en el desarrollo de los sistemas**
  - [ ] **4.1. Ciclo de vida de desarrollo seguro**
  - [ ] **4.2. Principios y prácticas de codificación segura**
  - [ ] **4.3. Vulnerabilidades y verificación de la seguridad**
- [ ] **Cierre: las cuatro materias como un solo criterio de calidad**

Conceptos clave para memorizar

Concepto	Dato clave
Usabilidad (ISO 9241-11)	Grado en que un sistema permite a **usuarios concretos** alcanzar objetivos concretos con **eficacia, eficiencia y satisfacción** en un **contexto de uso** determinado: no es una propiedad absoluta del producto
Accesibilidad vs. usabilidad	La **accesibilidad** es una condición de partida (que se pueda usar, incluidas las personas con discapacidad); la **usabilidad**, un grado de calidad de ese uso. La accesibilidad es **exigible por ley**; la usabilidad, no
Diseño universal	Diseño de productos y entornos utilizables por **todas las personas**, en la mayor medida posible, **sin necesidad de adaptación ni diseño especializado** (definición del art. 2 de la Convención de la ONU). **7 principios** del Center for Universal Design (1997)
Diseño para todas las personas	Denominación española equivalente en el RDL 1/2013, junto a **accesibilidad universal** y a los **ajustes razonables** (medida individual y subsidiaria cuando el diseño universal no basta)
POUR	Los cuatro principios de WCAG: **P**erceptible, **O**perable, **C**omprensible (*Understandable*) y **R**obusto
Estructura de WCAG	4 principios → **13 pautas** → **criterios de conformidad** (verificables, en niveles **A / AA / AAA**) → técnicas (suficientes y consultivas, **no normativas**)
Nivel exigido en el sector público	**AA** de WCAG (más los requisitos no-web de la EN 301 549). Lo fija la Directiva (UE) 2016/2102 y, en España, el **RD 1112/2018**
WCAG 2.2	Recomendación W3C de **5 de octubre de 2023**; añade 9 criterios nuevos y **retira** el criterio 4.1.1 *Análisis sintáctico*. WCAG 2.0 es además la norma **ISO/IEC 40500:2012**
EN 301 549	Norma **armonizada europea** de accesibilidad TIC: cubre web (cap. 9), documentos (cap. 10), software (cap. 11), hardware (cap. 8), comunicación bidireccional (cap. 6) y audiovisual (cap. 7). Es la referencia del RD 1112/2018 y de la contratación pública
Declaración de accesibilidad	Obligatoria, con modelo fijado por la **Decisión (UE) 2018/1523**; indica el grado de cumplimiento (**plenamente / parcialmente / no conforme**), el contenido no accesible, la fecha y método de evaluación y el **mecanismo de comunicación y reclamación**

Concepto	Dato clave
Unidad responsable de accesibilidad	Figura que el **art. 16 del RD 1112/2018** obliga a designar en cada organismo del sector público; coordina, informa y responde las quejas
Triada CID	**Confidencialidad** (solo quien debe accede), **Integridad** (el dato no se altera indebidamente) y **Disponibilidad** (accesible cuando se necesita). El ENS añade **autenticidad** y **trazabilidad**
Mínimo privilegio	Cada usuario y proceso opera con los permisos **estrictamente necesarios** durante el **tiempo estrictamente necesario**: el usuario del puesto **no** debe ser administrador local
RPO / RTO	**RPO**: cuánta información se puede permitir perder (mide hacia atrás, define la frecuencia de la copia). **RTO**: cuánto se puede tardar en volver a funcionar (mide hacia delante, define la capacidad de restauración)
Regla 3-2-1	**3** copias de los datos, en **2** soportes distintos, con **1** fuera de las instalaciones; en su versión reforzada, **1 inmutable o desconectada** frente al *ransomware*. Una copia no verificada mediante **prueba de restauración** no cuenta como copia
DLP	*Data Loss Prevention*: control que inspecciona el dato en uso, en tránsito y en reposo y **bloquea su salida** no autorizada (correo, USB, nube personal)
ENS — categorías	Un sistema se clasifica en categoría **Básica, Media o Alta** según el impacto en las cinco dimensiones (CIDAT); la categoría determina las medidas exigibles del Anexo II del RD 311/2022
SSDLC / *shift left*	Integrar la seguridad **en todas las fases** del ciclo de vida y **cuanto antes**: corregir un defecto en requisitos cuesta órdenes de magnitud menos que corregirlo en producción
STRIDE	Modelo de amenazas de seis categorías: *Spoofing*, *Tampering*, *Repudiation*, *Information disclosure*, *Denial of service* y *Elevation of privilege*; cada una se contrarresta con una propiedad (autenticidad, integridad, no repudio, confidencialidad, disponibilidad y autorización)
Principios de Saltzer y Schroeder	Ocho principios de 1975 que siguen vigentes: mínimo privilegio, economía de mecanismo, valores por defecto seguros (*fail-safe defaults*), mediación completa, **diseño abierto** (la seguridad no reside en el secreto del diseño),

Concepto	Dato clave
	separación de privilegios, mínimo mecanismo común y aceptabilidad psicológica
Validación de entradas	**Lista blanca** (aceptar solo lo previsto) mejor que lista negra; validación **siempre en el servidor** (la del cliente es solo usabilidad); **canonicalizar antes de validar**
Codificación de salida	La inyección se evita **separando código y datos**: consultas **parametrizadas** frente a SQLi y **codificación contextual** de la salida frente a XSS
Vulnerabilidad vs. debilidad	**CWE** cataloga **debilidades** (tipos de defecto, p. ej. CWE-79 XSS); **CVE** identifica **vulnerabilidades concretas** en productos concretos; **CVSS** puntúa su severidad de 0,0 a 10,0
OWASP Top 10:2021	A01 Control de acceso roto · A02 Fallos criptográficos · A03 Inyección · A04 Diseño inseguro · A05 Configuración de seguridad defectuosa · A06 Componentes vulnerables y desactualizados · A07 Fallos de identificación y autenticación · A08 Fallos de integridad de software y datos · A09 Fallos de registro y monitorización · A10 SSRF
SAST / DAST / IAST / SCA	**SAST**: analiza el código sin ejecutarlo (temprano, muchos falsos positivos). **DAST**: ataca la aplicación en ejecución (sin ver el código). **IAST**: instrumenta la aplicación y combina ambos. **SCA**: analiza las **dependencias** de terceros
SBOM	Lista de materiales de software (formatos **SPDX** y **CycloneDX**): inventario de componentes que permite saber en horas si una vulnerabilidad publicada afecta a la organización

Contenido

Convenciones del documento

Este tema incluye cuatro tipos de **cajas callout** para facilitar el estudio:

> **DATO CLAVE**
> Información de alta densidad memorística.

> **EJERCICIO RESUELTO**
> Problema + solución paso a paso (clasificación de un criterio, elección de un control, diagnóstico de una vulnerabilidad).

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicación real de la teoría al entorno municipal (sede electrónica, cita previa, puesto de trabajo del empleado público).

> **RELACIÓN CON OTROS TEMAS**
> Enlace conceptual a otros temas del temario oficial.

Los ejemplos de **código** se escriben en lenguajes reales (Java, Python, JavaScript, SQL, HTML y configuración de servidor), no en pseudocódigo neutro, porque una parte del tema —la codificación segura— consiste precisamente en distinguir una construcción vulnerable de su equivalente correcta, y esa diferencia solo se aprecia en el lenguaje concreto. Los fragmentos son deliberadamente breves e ilustrativos. Las fuentes se citan con etiquetas breves tipo `[WCAG22]` o `[ENS]`; el registro completo está en la pestaña Fuentes.

Caso de referencia usado en todo el tema (contexto Ayuntamiento de Madrid, supuesto simplificado): el **servicio municipal de cita previa y consulta de expedientes**. Tiene dos caras. Por fuera, una **aplicación web pública** con la que cualquier vecino —incluidas personas mayores, con discapacidad visual, auditiva, motriz o cognitiva, y personas con baja competencia digital— pide cita en una Oficina de Atención a la Ciudadanía, consulta el estado de un expediente y descarga documentos. Por dentro, el **puesto de trabajo del empleado municipal** que atiende esa cita, gestiona el expediente y maneja datos personales de vecinos. Este supuesto encadena de forma natural las cuatro materias del tema: el servicio público debe ser **accesible y usable** (§1 y §2), el puesto desde el que se tramita debe preservar la **confidencialidad y la disponibilidad** de la información (§3) y la aplicación que sostiene todo debe haberse **desarrollado de forma segura** (§4).

DATO CLAVE

Las cuatro secciones del tema comparten un mismo hilo conductor: **la calidad de un sistema de información no es solo que funcione**. Un servicio público electrónico debe poder **usarlo cualquiera** (accesibilidad y usabilidad), debe **proteger la información** que maneja en el puesto donde se trabaja con ella (confidencialidad y disponibilidad) y debe haberse **construido pensando en el atacante** desde el primer día (desarrollo seguro). Las tres exigencias son, además, **obligaciones jurídicas** para el sector público español: RD 1112/2018, ENS (RD 311/2022) y RGPD (art. 25 y 32) respectivamente.

1. Accesibilidad, diseño universal y usabilidad

Antes de entrar en normas y criterios conviene separar cuatro conceptos que en el lenguaje corriente se confunden:

Concepto	Definición operativa	¿Es exigible por ley?
Accesibilidad	Condición que deben cumplir los entornos, productos y servicios para ser **comprensibles, utilizables y practicables por todas las personas**, en condiciones de seguridad y comodidad y de la forma más autónoma y natural posible `[TRLGDPD]`. Es un requisito de **entrada**: o se puede usar, o no.	**Sí**, en el sector público (`[RD1112-2018]`) y, desde la Ley 11/2023, en un catálogo amplio de productos y servicios privados `[LEY11-2023]`.
Usabilidad	**Grado** en que un sistema puede ser utilizado por **usuarios específicos** para alcanzar **objetivos específicos** con **eficacia, eficiencia y satisfacción** en un **contexto de uso específico** `[ISO9241-11]`. Es una **medida de calidad**, no un umbral binario.	**No** con carácter general, aunque los pliegos de contratación suelen incorporarla como requisito de calidad.
Experiencia de usuario (UX)	**Percepciones y respuestas** de una persona derivadas del uso o del uso previsto de un sistema: incluye emociones, creencias, preferencias, comportamientos y logros **antes, durante y después** del uso `[ISO9241-210]`. Es más amplia que la usabilidad.	No.
Diseño universal (o *diseño para todas las personas*)	**Estrategia de diseño**: concebir productos, entornos, programas y servicios para que puedan ser utilizados por **todas las personas, en la mayor medida posible, sin necesidad de adaptación ni diseño especializado** `[CDPD]` `[TRLGDPD]`. Es el **método** que produce accesibilidad.	Es el principio rector que las normas anteriores imponen.

DATO CLAVE

La relación entre los cuatro conceptos: **el diseño universal es la estrategia**, **la accesibilidad es el resultado exigible**, **la usabilidad es el grado de calidad de uso** y **la experiencia de usuario es la vivencia completa**. Un sitio puede ser accesible (cumple WCAG AA) y a la vez poco usable (el usuario tarda demasiado en encontrar lo que busca); y puede ser muy usable para la mayoría y radicalmente inaccesible para quien navega con lector de pantalla `[WAI]` `[ISO9241-11]`.

Existe además una figura jurídica complementaria: los **ajustes razonables**. Son las modificaciones y adaptaciones **individualizadas** que no impongan una carga desproporcionada y que se adoptan

cuando el diseño universal, pese a haberse aplicado, no resuelve la situación de una persona concreta `[TRLGDPD]` `[CDPD]`. La relación entre ambos es de subsidiariedad: **primero diseño universal para todos; el ajuste razonable solo cuando aquel no basta**, y nunca como sustituto sistemático suyo.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Aplicar **diseño universal** a la cita previa municipal es que el formulario funcione con teclado, con lector de pantalla, con texto ampliado al 200 % y con lenguaje claro **para todo el mundo desde el principio**. Un **ajuste razonable** sería habilitar una atención telefónica asistida para un vecino concreto cuya situación no queda cubierta pese a ello. Lo que **no** es admisible es la ruta inversa: publicar una sede inaccesible y ofrecer el teléfono como «alternativa», porque eso vulnera el derecho a relacionarse electrónicamente con la Administración en igualdad de condiciones `[LPACAP]` `[RD1112-2018]`.

1.1. Principios de usabilidad y experiencia de usuario

La definición canónica de usabilidad es la de la norma **ISO 9241-11:2018**, que la descompone en tres atributos y la condiciona a un contexto `[ISO9241-11]`:

- **Eficacia** (*effectiveness*): exactitud e integridad con que los usuarios alcanzan los objetivos. Se mide, por ejemplo, con la **tasa de éxito** en una tarea (¿cuántos vecinos consiguen pedir la cita?).
- **Eficiencia** (*efficiency*): recursos empleados en relación con los resultados obtenidos: **tiempo**, número de pasos, número de errores cometidos.
- **Satisfacción** (*satisfaction*): en qué medida las respuestas físicas, cognitivas y emocionales del usuario ante el uso son positivas. Se mide con cuestionarios normalizados.
- **Contexto de uso**: la combinación de **usuarios, tareas, equipamiento y entorno** físico y social. La misma aplicación puede ser usable en un despacho y no serlo en la calle, con sol y una mano ocupada.

> **DATO CLAVE**
>
> La usabilidad **no es una propiedad absoluta del producto**, sino una propiedad **relativa al contexto de uso**: los mismos tres atributos (eficacia, eficiencia y satisfacción) pueden dar resultados opuestos con usuarios o entornos distintos `[ISO9241-11]`. Por eso toda evaluación de usabilidad empieza por describir el contexto.

Los siete principios de interacción de ISO 9241-110:2020 `[ISO9241-110]` concretan la definición anterior en criterios de diseño verificables:

1. **Idoneidad para la tarea**: el diálogo apoya el trabajo real del usuario sin exigirle acciones ajenas a su objetivo.
2. **Carácter autodescriptivo**: en cada momento se entiende dónde se está, qué se puede hacer y qué ocurrirá a continuación.
3. **Conformidad con las expectativas**: el sistema se comporta de forma coherente con las convenciones conocidas y consigo mismo.
4. **Facilidad de aprendizaje**: el sistema guía y permite descubrir su funcionamiento con un coste bajo.
5. **Controlabilidad**: el usuario dirige el ritmo y la secuencia de la interacción, y puede deshacer.
6. **Robustez frente a errores de uso**: los errores se previenen, se toleran y se corrigen sin pérdida de trabajo.
7. **Compromiso del usuario** (*user engagement*): el sistema motiva a continuar la interacción con una presentación cuidada y una respuesta adecuada.

Junto a la norma ISO, la práctica profesional maneja dos catálogos heurísticos clásicos. Las **10 heurísticas de Nielsen** `[NIELSEN]` son la base de la *evaluación heurística*, técnica de inspección experta barata y muy rentable:

#	Heurística	Traducción operativa
1	Visibilidad del estado del sistema	El sistema informa siempre de lo que está pasando (indicadores de progreso, confirmaciones).
2	Correspondencia entre el sistema y el mundo real	Lenguaje del usuario, no jerga interna ni códigos de expediente sin explicar.
3	Control y libertad del usuario	«Salidas de emergencia» claras: cancelar, deshacer, volver atrás.
4	Consistencia y estándares	Lo mismo se llama y se comporta igual en todo el sitio; se respetan las convenciones de la plataforma.
5	Prevención de errores	Mejor impedir el error que avisarlo: campos con formato guiado, confirmación de acciones destructivas.
6	Reconocer antes que recordar	Las opciones están a la vista; no se obliga a memorizar datos entre pantallas.
7	Flexibilidad y eficiencia de uso	Atajos para el usuario experto sin penalizar al novato.
8	Diseño estético y minimalista	Nada compite con la información realmente relevante.
9	Ayuda a reconocer, diagnosticar y recuperarse de los errores	Mensajes en lenguaje llano que dicen **qué ha pasado y qué hacer**, sin códigos crípticos.
10	Ayuda y documentación	Disponible, buscable, orientada a la tarea y concreta.

Las **ocho reglas de oro de Shneiderman** `[SHNEIDERMAN]` insisten en aspectos parcialmente coincidentes —consistencia, atajos, realimentación informativa, diálogos que concluyen, prevención de errores, deshacer con facilidad, control interno del usuario y reducción de la carga de memoria a corto plazo— y son el otro catálogo citado con frecuencia. De Donald Norman `[NORMAN]` procede el vocabulario del diseño de interacción: **affordance** (lo que un objeto sugiere que se puede hacer con él), **significante** (la señal que indica dónde actuar), **restricción**, **correspondencia** (*mapping*) y **modelo conceptual**.

El proceso que garantiza estos principios es el **diseño centrado en las personas** de **ISO 9241-210:2019** `[ISO9241-210]`, definido como un ciclo **iterativo** de cuatro actividades:

1. **Comprender y especificar el contexto de uso** (quiénes, para qué, dónde, con qué).
2. **Especificar los requisitos** de usuario y de la organización.
3. **Producir soluciones de diseño** (bocetos, prototipos de fidelidad creciente).

4. **Evaluar los diseños frente a los requisitos**, con usuarios reales, y volver al paso que corresponda.

> DATO CLAVE
>
> La norma **ISO 9241-210** exige que el proceso sea **iterativo** y que la evaluación se haga **con usuarios reales**, no solo por inspección de expertos. Un ciclo lineal que evalúe únicamente al final no es diseño centrado en las personas `[ISO9241-210]`.

Los métodos de evaluación se agrupan en tres familias, complementarias y no sustitutivas:

- **Inspección** (sin usuarios): evaluación heurística, recorrido cognitivo (*cognitive walkthrough*), revisión de estándares. Baratas y tempranas; detectan problemas evidentes.
- **Prueba con usuarios** (*test de usabilidad*): observación de personas representativas realizando tareas reales, con métricas de éxito, tiempo y errores, y pensamiento en voz alta. Es la técnica más fiable; con **cinco participantes** por perfil se detecta ya la mayor parte de los problemas graves `[NIELSEN]`.
- **Métodos de indagación y analítica**: entrevistas, cuestionarios normalizados, análisis de registros de uso, mapas de calor y pruebas A/B en producción.

> EJERCICIO RESUELTO
>
> *Un vecino abandona la cita previa en el paso 3 de 5. La analítica muestra que el 62 % de los abandonos ocurren en la pantalla «Seleccione el tipo de trámite», que presenta una lista desplegable de 140 entradas con la denominación administrativa literal de cada procedimiento. ¿Qué principios se están incumpliendo y qué se corrige?* **Solución**: se incumplen la heurística 2 (correspondencia con el mundo real: el vecino no busca «Comunicación previa de inicio de actividad económica», busca «abrir un negocio»), la 6 (reconocer antes que recordar: 140 entradas exceden la capacidad de exploración) y la 8 (diseño minimalista). Correcciones: buscador con sugerencias sobre sinónimos en lenguaje corriente, agrupación por categorías vitales («vivienda», «vehículos», «negocio»), denominación doble (nombre común + denominación oficial como texto secundario) y trámites más frecuentes destacados. La medida de éxito es la tasa de finalización, no la opinión del área gestora.

1.2. Fundamentos del diseño universal y diseño para todos

El **diseño universal** nace en el ámbito de la arquitectura con **Ronald L. Mace** y el *Center for Universal Design* de la Universidad Estatal de Carolina del Norte, que en **1997** publica los **siete principios** que siguen siendo la referencia `[CUD]`:

#	Principio	Contenido	Traducción al software
1	**Uso equitativo**	El diseño es útil y comercializable para personas con distintas capacidades; evita segregar o estigmatizar.	Un solo sitio para todos, no una «versión accesible» aparte y peor mantenida.
2	**Flexibilidad de uso**	Se acomoda a un amplio rango de preferencias y capacidades.	Funciona con ratón, teclado, voz o pantalla táctil; permite ampliar el texto y cambiar el contraste.
3	**Uso simple e intuitivo**	El uso es fácil de entender con independencia de la experiencia, los conocimientos o el nivel de concentración.	Lenguaje claro, pasos numerados, sin jerga administrativa innecesaria.
4	**Información perceptible**	La información se comunica eficazmente sea cual sea la capacidad sensorial del usuario.	Nunca un solo canal: texto **y** color **y** icono; subtítulos y transcripciones.
5	**Tolerancia al error**	Se minimizan los riesgos y las consecuencias de acciones accidentales.	Confirmación antes de anular una cita; posibilidad de deshacer; se conserva lo escrito.
6	**Escaso esfuerzo físico**	Se usa con eficiencia y comodidad, con mínima fatiga.	Objetivos táctiles amplios; sin gestos complejos obligatorios; sin límites de tiempo estrictos.
7	**Tamaño y espacio adecuados**	Espacio suficiente para el acceso y el uso, sea cual sea el tamaño corporal, la postura o la movilidad.	Diseño adaptable (*responsive*), sin desplazamiento horizontal, zonas de pulsación suficientes.

DATO CLAVE

Los **siete principios del diseño universal** son de **1997**, del *Center for Universal Design* (Ronald L. Mace), y su enunciado —uso equitativo, flexibilidad, uso simple e intuitivo, información perceptible, tolerancia al error, escaso esfuerzo físico y tamaño y espacio adecuados— `[CUD]`.

En el ordenamiento español, la terminología está fijada por el **Real Decreto Legislativo 1/2013** (texto refundido de la Ley General de derechos de las personas con discapacidad) `[TRLGDPD]`, heredero de la Ley 51/2003 (LIONDAU). Sus definiciones clave son:

- **Accesibilidad universal**: condición que deben cumplir entornos, procesos, bienes, productos y servicios, así como objetos, instrumentos, herramientas y dispositivos, **para ser comprensibles, utilizables y practicables por todas las personas** en condiciones de seguridad y comodidad y de la forma más autónoma y natural posible. Presupone la estrategia de *diseño universal* y se entiende sin perjuicio de los ajustes razonables.
- **Diseño universal o diseño para todas las personas**: la actividad por la que se conciben o proyectan **desde el origen**, y siempre que ello sea posible, entornos, procesos, bienes, productos, servicios, objetos, instrumentos, dispositivos o herramientas de forma que **puedan ser utilizados por todas las personas**, en la mayor extensión posible, sin necesidad de adaptación ni de diseño especializado.
- **Ajustes razonables**: modificaciones y adaptaciones necesarias y adecuadas del ambiente físico, social y actitudinal, **que no impongan una carga desproporcionada o indebida**, cuando se requieran en un caso particular de manera eficaz y práctica.

Este vocabulario procede a su vez de la **Convención de la ONU sobre los derechos de las personas con discapacidad** (2006), ratificada por España, que define el diseño universal en su **artículo 2** y obliga a los Estados a asegurar el acceso a **los sistemas y las tecnologías de la información y las comunicaciones** en su **artículo 9** `[CDPD]`. Es el fundamento último de toda la cadena normativa que se estudia en §2.3: la accesibilidad digital no es una buena práctica técnica, es la **ejecución de un derecho**.

Conviene también manejar el **modelo social de la discapacidad**, que sustenta esta normativa: la discapacidad no se entiende como un atributo del individuo, sino como el resultado de la **interacción entre una deficiencia y las barreras del entorno**. Una persona ciega no es incapaz de pedir una cita: es la **web sin texto alternativo** la que se lo impide. Reformular el problema así explica por qué la obligación recae sobre quien diseña, no sobre quien usa.

Las **tecnologías de apoyo** (o productos de apoyo) son el otro extremo de la relación: lectores de pantalla (NVDA, JAWS, VoiceOver, TalkBack), magnificadores, líneas braille, teclados y ratones adaptados, punteros de cabeza, conmutadores, software de reconocimiento de voz y de predicción de texto, y subtitulado en vivo. El **diseño accesible es la condición para que estas tecnologías funcionen**: un lector de pantalla no puede leer lo que no se ha etiquetado, ni un control por conmutador puede activar lo que no es accesible por teclado.

> DATO CLAVE
>
> El diseño universal **no elimina** las tecnologías de apoyo ni los ajustes razonables: los hace **eficaces y excepcionales** respectivamente. La secuencia correcta es **diseño universal → tecnología de apoyo (compatible) → ajuste razonable individual**, y no al revés `[CDPD]` `[TRLGDPD]`.

Un último concepto transversal: el **beneficio universal** (a veces llamado «efecto bordillo rebajado»). Las soluciones concebidas para personas con discapacidad benefician a toda la población: los subtítulos sirven a quien ve un vídeo en un espacio ruidoso o en un idioma que no domina; el contraste alto, a quien mira el móvil bajo el sol; el lenguaje claro, a cualquiera con prisa. Es el argumento decisivo frente a la objeción de coste: **la accesibilidad no es un extra para una minoría, es calidad para todos**.

1.3. Modelos de calidad e ISO/IEC 9241 e ISO/IEC 25010

Las normas que enmarcan este bloque pertenecen a dos familias distintas que conviene no confundir.

La serie ISO 9241 (*Ergonomía de la interacción persona-sistema*) es una norma de **ergonomía**, orientada al **proceso y a la interacción**. Sus partes más citadas son:

Parte	Objeto
ISO 9241-11:2018	Definición y conceptos de **usabilidad**: eficacia, eficiencia y satisfacción en un contexto de uso `[ISO9241-11]`.
ISO 9241-110:2020	**Principios de interacción**: los siete principios del diálogo `[ISO9241-110]`.
ISO 9241-171:2008	**Guía de accesibilidad del software**: requisitos y recomendaciones para que las aplicaciones sean accesibles `[ISO9241-171]`.
ISO 9241-210:2019	**Diseño centrado en las personas** para sistemas interactivos: el ciclo iterativo de cuatro actividades `[ISO9241-210]`.

La familia ISO/IEC 25000 (SQuaRE) es una norma de **calidad del producto software**, orientada al **producto y a su medición**. Sustituye y amplía a la antigua ISO/IEC 9126. Se organiza en divisiones: 2500n (gestión de la calidad), **2501n (modelos de calidad)**, 2502n (medición), 2503n (requisitos) y 2504n (evaluación) `[ISO25000]`.

Su pieza central es **ISO/IEC 25010**, el **modelo de calidad del producto**. La edición vigente, **ISO/IEC 25010:2023**, anula y sustituye a la de 2011 y define **nueve características** `[ISO25010]`:

Característica	Subcaracterísticas
Adecuación funcional	Completitud, corrección y pertinencia funcional.
Eficiencia de desempeño	Comportamiento temporal, utilización de recursos, capacidad.
Compatibilidad	Coexistencia, interoperabilidad.
Capacidad de interacción (antes «usabilidad»)	Reconocibilidad de la adecuación, aprendizabilidad, operabilidad, protección contra errores de usuario, involucración del usuario, **inclusividad**, **asistencia al usuario** y auto-descriptividad.
Fiabilidad	Ausencia de fallos (antes «madurez»), **disponibilidad**, tolerancia a fallos, capacidad de recuperación.
Seguridad (*security*)	**Confidencialidad, integridad, no repudio, responsabilidad (*accountability*), autenticidad** y resistencia.
Mantenibilidad	Modularidad, reusabilidad, analizabilidad, capacidad para ser modificado, capacidad para ser probado.
Flexibilidad (antes «portabilidad»)	Adaptabilidad, escalabilidad, instalabilidad, reemplazabilidad.
Protección (*safety*)	Restricción operativa, identificación de riesgos, protección ante fallos, advertencia de peligro, integración segura.

DATO CLAVE

En **ISO/IEC 25010:2023** la **accesibilidad** ya no figura como subcaracterística: la edición de 2011 la situaba dentro de la usabilidad, y la de 2023 cubre su contenido con la **inclusividad** y la **asistencia al usuario**, dentro de la **capacidad de interacción**. La **disponibilidad** sigue siendo subcaracterística de la **fiabilidad**, y **confidencialidad e integridad** lo son de la **seguridad**. Las tres piezas que dan título a este tema (accesibilidad, confidencialidad y disponibilidad) se sitúan, por tanto, en **tres características distintas** del modelo `[ISO25010]`.

La familia SQuaRE distingue además tres modelos complementarios: **calidad del producto** (25010, el anterior), **calidad en uso** (desde 2023 en la norma propia ISO/IEC 25019, con tres características: beneficio —que incluye la usabilidad entendida como eficacia, eficiencia y satisfacción, el puente con ISO 9241-11—, ausencia de riesgo y aceptabilidad; la cobertura del contexto, que figuraba en la edición de 2011, desaparece) y **calidad de los datos** (ISO/IEC 25012). Y

define el proceso de **evaluación** en ISO/IEC 25040, con la secuencia establecer requisitos → especificar la evaluación → diseñar el plan → ejecutar las medidas → concluir.

DATO CLAVE

Regla mnemotécnica de diferenciación: **ISO 9241 mide el proceso y la interacción** (ergonomía, «cómo se diseña y cómo se dialoga»); **ISO/IEC 25010 mide el producto terminado** (calidad del software, «qué propiedades tiene lo construido»). La usabilidad aparece en las dos, pero con perspectivas distintas: como resultado del contexto de uso en la primera y como característica medible del producto en la segunda, que en su edición de 2023 la denomina **capacidad de interacción** `[ISO9241-11]` `[ISO25010]`.

RELACIÓN CON OTROS TEMAS

El resto de la familia de normas de gestión —**ISO/IEC 27001** para la seguridad de la información— se relaciona con este tema en su bloque 2 y se desarrolla en el **Tema 32** (conceptos de seguridad de los sistemas de información). El modelo de calidad **ISO/IEC 25010** ya se usó como marco comparativo en el **Tema 24** (desarrollo móvil).

EJEMPLO DE APLICACIÓN EN EL AYTO

En el pliego de contratación de la aplicación de cita previa, los requisitos de calidad se pueden redactar directamente sobre ISO/IEC 25010:2023: *capacidad de interacción* → tasa de finalización de la solicitud de cita ≥ 90 % en prueba con usuarios y conformidad **WCAG 2.2 AA** en la subcaracterística de inclusividad; *fiabilidad* → disponibilidad del servicio ≥ 99,5 % mensual; *seguridad* → conformidad con el nivel de verificación aplicable de OWASP ASVS `[OWASP-ASVS]`. Expresar así los requisitos los hace **verificables en la recepción del contrato**, que es justo lo que un pliego necesita.

2. Acceso y usabilidad de las tecnologías, productos y servicios de la sociedad de la información

La expresión «**servicios de la sociedad de la información**» procede del derecho comunitario y designa todo servicio prestado normalmente a título oneroso, **a distancia**, **por vía electrónica** y **a petición individual** del destinatario. En España la recoge la Ley 34/2002 (LSSI-CE). Trasladada al objeto de este tema, abarca el conjunto de canales por los que la ciudadanía se relaciona hoy con la Administración y con el mercado: **sitios web, sedes electrónicas, aplicaciones móviles, documentos electrónicos, cajeros y máquinas expendedoras de billetes, atención telefónica automatizada y terminales de autoservicio**.

El problema de acceso tiene dos capas superpuestas que no deben confundirse:

- La **brecha digital**, de naturaleza socioeconómica: disponibilidad de conexión y de dispositivo, coste, y sobre todo **competencias digitales**. La Administración la atiende con el deber de **asistencia en el uso de medios electrónicos** que impone la Ley 39/2015 `[LPACAP]` y con las oficinas de asistencia en materia de registros.
- La **barrera de accesibilidad**, de naturaleza técnica y de diseño: la persona tiene conexión, dispositivo y competencia, pero **el producto no es utilizable** con su forma de percibir, operar o comprender. Es la que atacan las normas que siguen.

> DATO CLAVE
>
> No confundir **brecha digital** (falta de medios o de competencias, se combate con asistencia, formación y despliegue) con **barrera de accesibilidad** (defecto de diseño del producto, se combate con normas técnicas exigibles). Ante un caso que mezcle ambas, la respuesta correcta es que requieren **medidas de naturaleza distinta**.

2.1. Pautas de accesibilidad al contenido web WCAG

Las **Web Content Accessibility Guidelines (WCAG)** son las recomendaciones del **W3C**, elaboradas por su iniciativa **WAI** (*Web Accessibility Initiative*), y constituyen la norma de referencia mundial de accesibilidad del contenido web `[WCAG22]` `[WAI]`.

Evolución de las versiones:

Versión	Fecha	Novedades
WCAG 1.0	1999	14 pautas y 65 puntos de verificación, con prioridades 1/2/3. Muy ligada al HTML de la época.
WCAG 2.0	**11 de diciembre de 2008**	Reformulación completa: 4 principios, 12 pautas, **61 criterios de conformidad** verificables e **independientes de la tecnología**. Adoptada como norma internacional **ISO/IEC 40500:2012** `[WCAG20]`.
WCAG 2.1	**5 de junio de 2018**	Añade 17 criterios (total **78**) centrados en **movilidad, baja visión y discapacidad cognitiva**: reflujo, espaciado de texto, orientación, objetivos táctiles, entradas de puntero `[WCAG21]`.
WCAG 2.2	**5 de octubre de 2023**	Añade 9 criterios (foco no oculto, movimientos de arrastre, tamaño del objetivo, ayuda coherente, entrada redundante, autenticación accesible) y **retira el criterio 4.1.1 «Análisis sintáctico»**, ya cubierto por los navegadores modernos. Total: **86 criterios** `[WCAG22]`.
WCAG 3.0	En desarrollo (borrador)	Modelo de conformidad distinto (puntuación por niveles bronce/plata/oro) y alcance más amplio; **no es exigible** y no sustituye a la 2.x.

Estructura normativa de WCAG 2.x:

```
4 PRINCIPIOS (POUR)
 └── 13 PAUTAS (objetivos generales, NO verificables)
      └── CRITERIOS DE CONFORMIDAD (verificables, con nivel A / AA / AAA)
           └── TÉCNICAS suficientes y consultivas + FALLOS comunes  → INFORMATIVAS, no
```

> **DATO CLAVE**
>
> Solo los **criterios de conformidad** son normativos y verificables. Las **pautas** son objetivos generales y las **técnicas** son documentación informativa: se puede cumplir un criterio con una técnica no listada por el W3C, siempre que sea comprobable. Confundir «técnica» con «requisito» es un error clásico `[WCAG22]`.

Los cuatro principios POUR y sus 13 pautas:

1. Perceptible — la información y los componentes deben presentarse de modo que los usuarios puedan percibirlos.

- **1.1 Alternativas textuales**: todo contenido no textual tiene una alternativa textual equivalente (`alt` en imágenes; `alt=""` en imágenes decorativas para que el lector de pantalla las ignore).
- **1.2 Medios tempodependientes**: subtítulos, audiodescripción y transcripciones para audio y vídeo. Los **subtítulos en directo** son criterio de nivel AA.
- **1.3 Adaptable**: el contenido puede presentarse de distintas formas sin perder información ni estructura; exige **marcado semántico** real (encabezados, listas, tablas con encabezados, etiquetas de formulario asociadas) y no depender solo de características sensoriales («pulse el botón redondo de la derecha»).
- **1.4 Distinguible**: contraste, tamaño, color, audio de fondo, reflujo, espaciado. **1.4.1** prohíbe transmitir información **solo mediante el color**; **1.4.3 (AA)** exige un contraste mínimo de **4,5:1** para texto normal y **3:1** para texto grande; **1.4.11 (AA)** exige **3:1** en componentes de interfaz y gráficos; **1.4.4 (AA)** exige poder **ampliar el texto al 200 %** sin pérdida de contenido ni funcionalidad; **1.4.10 (AA, *reflujo*)** exige que el contenido se reorganice en una sola columna sin desplazamiento en dos dimensiones.

2. Operable — los componentes de la interfaz y la navegación deben ser operables.

- **2.1 Accesible por teclado**: **toda** la funcionalidad debe poder usarse solo con teclado y sin **trampas de foco** (*keyboard trap*).
- **2.2 Tiempo suficiente**: los límites de tiempo deben poder desactivarse, ajustarse o prorrogarse; el contenido en movimiento o que se actualiza solo debe poder pausarse.
- **2.3 Convulsiones y reacciones físicas**: nada debe destellar más de **tres veces por segundo**.
- **2.4 Navegable**: mecanismo para **saltar bloques** repetidos, títulos de página descriptivos, orden del foco lógico, propósito del enlace comprensible, encabezados y etiquetas informativos y **foco visible**. WCAG 2.2 añade que el foco **no quede oculto** por elementos superpuestos (2.4.11, AA).
- **2.5 Modalidades de entrada**: gestos, movimiento, tamaño del objetivo. WCAG 2.2 añade **2.5.7 Movimientos de arrastre** (debe existir alternativa sin arrastrar) y **2.5.8 Tamaño del objetivo (mínimo)**, que fija **24 × 24 píxeles CSS** en nivel AA (el nivel AAA, 2.5.5, exige 44 × 44).

3. Comprensible — la información y el manejo de la interfaz deben ser comprensibles.

- **3.1 Legible**: **idioma de la página** declarado (`lang`) y de las partes en otro idioma; en AAA, explicación de abreviaturas y palabras inusuales.
- **3.2 Predecible**: el foco o el cambio de un control **no** provocan por sí solos un cambio de contexto; la navegación y la identificación son coherentes en todo el sitio. WCAG 2.2 añade **3.2.6 Ayuda coherente** (nivel A): si hay un mecanismo de ayuda, debe aparecer en el mismo sitio en todas las páginas.

- **3.3 Entrada de datos asistida**: identificación de errores, **etiquetas o instrucciones**, sugerencia ante error y prevención de errores en operaciones jurídicas o financieras (revisar, corregir o confirmar antes de enviar). WCAG 2.2 añade **3.3.7 Entrada redundante** (no volver a pedir en el mismo proceso información ya facilitada) y **3.3.8 Autenticación accesible (mínimo, AA)**, que **prohíbe exigir una prueba de función cognitiva** —recordar una contraseña, transcribir caracteres, resolver un rompecabezas— sin ofrecer un método alternativo, y que obliga a permitir **pegar** en los campos de contraseña.

4. Robusto — el contenido debe ser suficientemente robusto para ser interpretado por una amplia variedad de agentes de usuario, incluidas las tecnologías de apoyo.

- **4.1 Compatible**: **4.1.2 Nombre, función, valor** exige que cada componente de interfaz exponga a las tecnologías de apoyo su nombre accesible, su función y su estado; es el criterio que sostiene el uso correcto de **WAI-ARIA** `[WAI-ARIA]`. **4.1.3 Mensajes de estado** (AA, introducido en 2.1) exige que los avisos que no reciben el foco (por ejemplo, «se han encontrado 12 resultados») se comuniquen mediante *live regions*.

> DATO CLAVE
>
> **WCAG 2.2 tiene 86 criterios de conformidad**: 31 de nivel A, 24 de nivel AA y 31 de nivel AAA. **La conformidad es acumulativa**: el nivel AA exige cumplir **todos** los criterios A **y** AA. El W3C advierte de que **no se recomienda exigir AAA** para sitios completos, porque no es alcanzable para todo tipo de contenido; por eso el nivel legalmente exigido es **AA** `[WCAG22]`.

Los **cinco requisitos de conformidad** de WCAG 2.x son: (1) alcanzar un **nivel** completo, (2) que la conformidad se predique de **páginas completas**, (3) que abarque los **procesos completos** (si un paso de la solicitud de cita no es conforme, no lo es todo el proceso), (4) usar **tecnologías compatibles con la accesibilidad** para todo lo que aporte información, y (5) que las tecnologías no compatibles **no interfieran**.

> DATO CLAVE
>
> Dos reglas prácticas: **la conformidad se declara de páginas completas** (no vale «esta parte sí y esta no») y **de procesos completos** (una sola pantalla no conforme rompe la conformidad de todo el trámite) `[WCAG22]`.

Además de WCAG, el W3C mantiene dos recomendaciones hermanas que completan el trío, cada una con su ámbito: **ATAG 2.0**, sobre las **herramientas de autor** —el gestor de contenidos debe ser accesible **y** debe ayudar a producir contenido accesible— `[ATAG20]`, y **UAAG 2.0**, sobre los **agentes de usuario**: navegadores y reproductores `[UAAG20]`.

EJERCICIO RESUELTO

En el formulario de cita previa, los campos obligatorios se marcan solo pintando su borde en rojo; el aviso «Debe indicar su NIF» aparece como un texto rojo insertado dinámicamente junto al campo sin recibir el foco; y el desplegable de distrito envía el formulario al seleccionar una opción. Identifique los criterios incumplidos. **Solución**: (a) marcar lo obligatorio solo con color incumple **1.4.1 Uso del color** (nivel A) —hay que añadir un texto o un icono con alternativa textual—; (b) el mensaje insertado dinámicamente que no recibe foco incumple **4.1.3 Mensajes de estado** (AA) si no se anuncia mediante `role="alert"` o una región activa, y **3.3.1 Identificación de errores** (A) si no describe el error en texto; (c) enviar el formulario al cambiar el desplegable incumple **3.2.2 Al recibir entradas** (A), porque un cambio de configuración provoca por sí solo un cambio de contexto. Corrección: asterisco y texto «(obligatorio)», mensaje de error en región activa asociada al campo mediante `aria-describedby`, y botón explícito de envío.

2.2. Requisitos de accesibilidad TIC y norma EN 301 549

WCAG cubre el **contenido web**, pero la accesibilidad exigible a un organismo público abarca mucho más: aplicaciones de escritorio, documentos ofimáticos, un teléfono de atención, un cajero automático de pago de tasas o el propio hardware del puesto. Ese espacio lo cubre la norma europea **EN 301 549** — *Requisitos de accesibilidad para productos y servicios TIC* — elaborada conjuntamente por **ETSI, CEN y CENELEC** a petición de la Comisión Europea `[EN301549]`.

Su papel jurídico es doble: es la **norma armonizada** que da presunción de conformidad con la Directiva (UE) 2016/2102, y es la norma de referencia para la **contratación pública accesible** en la Unión.

Estructura por capítulos (imprescindible saber qué cubre cada uno):

Capítulo	Objeto
4	**Requisitos funcionales de rendimiento**: uso sin visión, sin percepción del color, sin audición, sin capacidad vocal, con destreza o fuerza limitadas, con alcance limitado, minimizando la fotosensibilidad y con función cognitiva limitada. Es el «para qué» de todo lo demás.
5	**Requisitos genéricos**: activación de funciones de accesibilidad, biometría, conservación de la información de accesibilidad en las conversiones, uso sin tecnologías de apoyo.
6	**Comunicación bidireccional con voz**: ancho de banda de voz, comunicación de texto en tiempo real (**RTT**), vídeo para lengua de signos, identificación de la persona que llama.
7	**Vídeos con audio**: subtítulos, audiodescripción y sus controles.
8	**Hardware**: puertos y conectores, teclados físicos, indicadores táctiles, terminales de autoservicio (cajeros, quioscos).
9	**Web**: **incorpora directamente los criterios A y AA de WCAG** como requisitos de la norma.
10	**Documentos no web**: PDF, ofimática y otros documentos electrónicos; se apoya en los mismos criterios WCAG adaptados y en **PDF/UA** `[PDF-UA]`.
11	**Software**: aplicaciones de escritorio y móviles, incluida la interoperabilidad con las **tecnologías de apoyo** (API de accesibilidad de la plataforma) y las preferencias de usuario del sistema.
12	**Documentación y servicios de apoyo**: manuales accesibles y servicio de atención capaz de responder sobre accesibilidad.
13	**Servicios de retransmisión o de acceso**: servicios de intermediación (relé) y acceso a servicios de emergencia.

DATO CLAVE

La relación entre las dos normas: **la EN 301 549 no sustituye a WCAG, la incorpora**. Su capítulo 9 remite a los criterios **A y AA de WCAG** para el contenido web; los capítulos 10 y 11 los adaptan a documentos y software; y los capítulos 4-8, 12 y 13 añaden **requisitos que WCAG no cubre** (hardware, telefonía, RTT, documentación y servicios de apoyo). Por eso la norma europea es la referencia de la **contratación pública**, y no WCAG a secas `[EN301549]`.

La versión **v3.2.1 (2021)** es la citada como armonizada en el marco de la Directiva 2016/2102; su anexo A explica la correspondencia entre cada requisito y las obligaciones de la Directiva, y su **anexo C** ofrece un modelo de informe de evaluación. En España la norma se ha publicado como **UNE-EN 301 549**. Un dato relevante para la práctica: los requisitos de la EN 301 549 se formulan como **cláusulas comprobables** («si el producto tiene X, entonces debe…»), de modo que los **no aplicables** deben declararse explícitamente como tales, no ignorarse.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Si el Ayuntamiento licita simultáneamente el rediseño de la web de cita previa, la aplicación móvil, la renovación de los **tótems de autoservicio** de las Oficinas de Atención a la Ciudadanía y el nuevo servicio de **atención telefónica**, el pliego no puede limitarse a exigir «WCAG 2.2 AA»: debe exigir **conformidad con la EN 301 549** en los capítulos aplicables a cada lote —9 para la web, 11 para la app, 8 para los tótems, 6 y 13 para la telefonía— y pedir el **informe de evaluación** correspondiente como documentación de entrega `[EN301549]`.

2.3. Marco normativo en la Administración Pública

La cadena normativa que obliga a un ayuntamiento español tiene cinco eslabones y conviene memorizarla en orden:

1. **Convención de la ONU sobre los derechos de las personas con discapacidad (2006)**, ratificada por España en 2007 y con rango de tratado internacional: define el **diseño universal** (art. 2) y obliga a garantizar el acceso a las TIC (art. 9) `[CDPD]`.
2. **Real Decreto Legislativo 1/2013**, texto refundido de la Ley General de derechos de las personas con discapacidad: incorpora al derecho interno las definiciones de accesibilidad universal, diseño para todas las personas y ajustes razonables, y establece el régimen sancionador `[TRLGDPD]`.
3. **Directiva (UE) 2016/2102**, sobre accesibilidad de los sitios web y aplicaciones móviles **de los organismos del sector público**: fija el nivel exigible por remisión a la norma armonizada, la declaración de accesibilidad, el mecanismo de reclamación y la obligación de seguimiento e informe `[DIR2016-2102]`.
4. **Real Decreto 1112/2018**, que la transpone en España `[RD1112-2018]`. Es **la norma nuclear de este epígrafe**.
5. **Directiva (UE) 2019/882 (*European Accessibility Act*)**, transpuesta por la **Ley 11/2023**: extiende requisitos de accesibilidad a **productos y servicios del sector privado** —comercio electrónico, servicios bancarios de consumo, transporte de viajeros, libros electrónicos, servicios de comunicaciones electrónicas y audiovisuales, terminales de autoservicio—, con aplicación general desde el **28 de junio de 2025** `[DIR2019-882]` `[LEY11-2023]`.

Contenido esencial del RD 1112/2018:

- **Ámbito subjetivo** (art. 2): Administración General del Estado, comunidades autónomas, **entidades locales**, entidades de derecho público vinculadas, universidades públicas, asociaciones de estas entidades y entidades privadas que presten servicios públicos o reciban financiación pública en los términos que el propio real decreto detalla.
- **Ámbito objetivo**: sitios web, **intranets y extranets** y **aplicaciones para dispositivos móviles**, así como los documentos y contenidos que alojan.
- **Requisito técnico** (art. 4): conformidad con la **norma UNE-EN 301 549** en su versión vigente, lo que en la práctica supone el **nivel AA de WCAG** para la parte web.
- **Excepciones tasadas** (art. 3.3): quedan fuera, entre otros, los contenidos de terceros que el organismo ni financia ni desarrolla ni controla; las retransmisiones **en directo** sujetas a límites temporales; los archivos ofimáticos publicados **antes del 23 de septiembre de 2018** que no sean necesarios para un trámite en curso; los mapas en línea (siempre que se dé alternativa accesible a la información esencial de navegación); y las reproducciones de piezas de patrimonio cuya accesibilidad sea incompatible con su conservación.
- **Carga desproporcionada** (art. 7): puede alegarse **motivadamente**, valorando tamaño, recursos y naturaleza del organismo frente al beneficio estimado para las personas con discapacidad. **Nunca puede fundarse en la falta de prioridad, de tiempo o de conocimientos**, y obliga a ofrecer una **alternativa accesible** y a declararlo en la declaración de accesibilidad.
- **Declaración de accesibilidad** (art. 15) y **unidad responsable de accesibilidad** (art. 16), que se desarrollan en §2.4.
- **Plazos de aplicación** (disposición transitoria): sitios web publicados **a partir del 20 de septiembre de 2018** → exigible desde el **23 de septiembre de 2019**; sitios anteriores → **23 de septiembre de 2020**; **aplicaciones móviles** → **23 de junio de 2021**. A día de hoy, por tanto, la exigencia es **plena para todo el sector público**.
- **Revisión, seguimiento y régimen de quejas** (arts. 17 y siguientes), con informe periódico a la Comisión Europea conforme a la metodología de la **Decisión (UE) 2018/1524** `[DEC2018-1524]`.

> DATO CLAVE
>
> Tres datos del RD 1112/2018: el nivel exigido es **AA** por remisión a la **UNE-EN 301 549**; toda entidad obligada debe designar una **unidad responsable de accesibilidad** (art. 16); y la **carga desproporcionada** es una excepción **motivada y declarada**, que **no puede justificarse por falta de prioridad, de tiempo o de conocimiento** y que obliga a ofrecer una alternativa `[RD1112-2018]`.

Junto a esta cadena específica, otras normas concurren sobre el mismo objeto: la **Ley 39/2015**, que reconoce el derecho a relacionarse electrónicamente y el deber de asistencia `[LPACAP]`; el **ENI** (RD 4/2010), que impone condiciones de accesibilidad a los documentos y servicios

electrónicos interoperables [ENI]; la normativa de contratación pública, que obliga a incorporar criterios de accesibilidad en los pliegos siempre que el objeto vaya a ser utilizado por personas físicas; y el **RGPD**, cuyo principio de **transparencia** exige que la información al interesado sea **concisa, inteligible y de fácil acceso, en lenguaje claro y sencillo**, lo que es, literalmente, un requisito de comprensibilidad [RGPD].

> RELACIÓN CON OTROS TEMAS
>
> El **Tema 23** desarrolla las aplicaciones y el desarrollo web (HTML semántico, front-end multiplataforma y multidispositivo), sobre el que se apoyan técnicamente la mayor parte de los criterios WCAG; el **Tema 24** trata la accesibilidad en el desarrollo **móvil** (capítulo 11 de la EN 301 549); y el **Tema 39** desarrolla los Esquemas Nacionales de Seguridad e Interoperabilidad, con los que este marco se cruza en la sede electrónica.

2.4. Evaluación, auditoría y declaración de accesibilidad

Metodología de evaluación. El W3C publica **WCAG-EM 1.0** [WCAG-EM], metodología de evaluación de la conformidad de un **sitio completo** en cinco pasos:

1. **Definir el alcance** de la evaluación: qué sitio, qué nivel de conformidad, en qué navegadores y tecnologías de apoyo.
2. **Explorar el sitio**: identificar páginas y funcionalidades clave, tipos de página, tecnologías empleadas y **procesos completos**.
3. **Seleccionar una muestra representativa**: páginas estructuradas (portada, formularios, resultados, error, ayuda, documentos) más una **muestra aleatoria**, cubriendo todos los procesos de principio a fin.
4. **Auditar la muestra**: comprobar cada criterio con herramientas automáticas **y** revisión manual **y** pruebas con tecnologías de apoyo.
5. **Informar los resultados**: puntuación, incumplimientos, evidencias y recomendaciones.

Tipos de comprobación y sus límites:

- **Automática** (analizadores como los basados en reglas **ACT** [ACT-RULES], extensiones de navegador, rastreadores de sitio completo): rápida, barata y repetible; imprescindible para vigilar regresiones en integración continua. Pero **solo detecta una parte de los criterios** —habitualmente se cita en torno a un tercio—, porque la mayoría exige juicio humano: una herramienta ve que **falta** el atributo `alt`, no que el `alt` presente diga «imagen1.jpg».
- **Manual experta**: revisión de código y de comportamiento contra cada criterio; navegación **solo con teclado**; comprobación de contraste; verificación de la estructura de encabezados; revisión con **lector de pantalla**.

- **Con usuarios reales** con distintas discapacidades: no es exigible por la norma, pero es la única que revela problemas de uso efectivo que ningún criterio formal captura.

> DATO CLAVE
>
> Una web puede **superar el 100 % de las comprobaciones automáticas y ser inaccesible**. Las herramientas automáticas detectan solo una fracción de los criterios; la evaluación válida a efectos del RD 1112/2018 combina **revisión automática, revisión manual experta y prueba con tecnologías de apoyo** `[WCAG-EM]` `[OBSERVATORIO]`.

La declaración de accesibilidad (art. 15 del RD 1112/2018, con modelo fijado por la **Decisión (UE) 2018/1523** `[DEC2018-1523]`) es el documento público —enlazado de forma **visible y accesible desde todas las páginas**, habitualmente en el pie— que debe contener:

Elemento	Detalle
Grado de cumplimiento	**Plenamente conforme** (cumple todos los requisitos), **parcialmente conforme** (cumple la mayoría pero no todos) o **no conforme** (no se ha evaluado o hay incumplimientos generalizados).
Contenido no accesible	Enumeración de lo que no cumple, agrupado por causa: **falta de conformidad**, **carga desproporcionada** (motivada) o **contenido fuera del ámbito** de aplicación.
Alternativas y contacto	Alternativas accesibles ofrecidas y datos de contacto de la unidad responsable.
Fecha y método	Fecha de preparación o de la última revisión y **método empleado**: **autoevaluación** o **evaluación por un tercero**.
Mecanismo de comunicación y reclamación	Vía para notificar incumplimientos o solicitar información en formato accesible, y procedimiento de **queja** y **reclamación** ante la unidad responsable, con plazos de respuesta.

La declaración debe **revisarse periódicamente** (al menos con carácter anual y siempre que el sitio cambie sustancialmente), y su ausencia o desactualización es en sí misma un incumplimiento.

La unidad responsable de accesibilidad (art. 16) es obligatoria en cada organismo. Sus funciones: coordinar y aplicar la política de accesibilidad, **responder las comunicaciones y reclamaciones**, promover la formación y la concienciación, y elaborar los informes de seguimiento. En España, el **Observatorio de Accesibilidad Web** de la Administración General del Estado publica la metodología de seguimiento, herramientas de validación y los resultados de las revisiones periódicas de los portales públicos `[OBSERVATORIO]`.

EJEMPLO DE APLICACIÓN EN EL AYTO

La sede electrónica y el portal municipal publican su **declaración de accesibilidad** conforme al modelo europeo, con el grado de cumplimiento, la fecha y el método de la última revisión y el enlace al mecanismo de comunicación; y el Ayuntamiento tiene designada su **unidad responsable de accesibilidad**, a la que se dirigen las quejas `[MADRID-A11Y]` `[RD1112-2018]`. Un vecino que no pueda completar la cita previa con su lector de pantalla puede **presentar una queja** por ese cauce y, si no obtiene respuesta o esta es insatisfactoria, **reclamar**; la unidad debe responder en el plazo reglamentario.

EJERCICIO RESUELTO

El área gestora propone declarar la sede «plenamente conforme» porque la herramienta automática no devuelve errores, y alegar carga desproporcionada para los 4.000 PDF históricos publicados en 2015. ¿Es correcto? **Solución**: (a) **no** puede declararse plenamente conforme apoyándose solo en una herramienta automática: hace falta revisión manual y con tecnologías de apoyo, y la declaración debe indicar el método real empleado; declarar un grado superior al real es un incumplimiento en sí mismo. (b) Para los PDF de 2015 **ni siquiera hace falta alegar carga desproporcionada**: los archivos ofimáticos publicados **antes del 23 de septiembre de 2018** que no sean necesarios para un trámite administrativo en curso están **excluidos del ámbito** por el art. 3.3, y así debe reflejarse —como «contenido fuera del ámbito de aplicación», no como carga desproporcionada— en el apartado de contenido no accesible de la declaración. La carga desproporcionada exige motivación económica y organizativa y alternativa accesible, y no procede aquí `[RD1112-2018]` `[DEC2018-1523]`.

---

3. Confidencialidad y disponibilidad de la información en puestos de usuario final

3.1. Seguridad en el puesto de usuario final

Se llama **puesto de usuario final** (o *endpoint*) al conjunto formado por el **equipo** desde el que una persona trabaja con la información —ordenador de sobremesa, portátil, tableta, teléfono corporativo, cliente ligero o puesto virtualizado—, su **software**, su **configuración**, los **soportes** que se le conectan y el **entorno físico** en el que está. No es solo la máquina: es la máquina, lo que contiene, quien la usa y dónde está.

Su importancia deriva de una asimetría: mientras el centro de proceso de datos está protegido por capas físicas y lógicas y administrado por especialistas, **el puesto de usuario está fuera, es masivo y lo maneja alguien cuyo trabajo no es la seguridad**. Por eso es, de forma sistemática, el

punto de entrada preferente de los ataques: el correo de *phishing*, el documento con macros, la memoria USB, la contraseña reutilizada o el portátil olvidado en un tren no atacan al servidor, atacan al puesto, y desde él se salta al resto `[ATTACK]` `[ISO27002]`.

Los objetivos de seguridad se enuncian con la **triada CID** y, en el sector público español, con las **cinco dimensiones del ENS** `[ENS]`:

Dimensión	Pregunta que responde	Ejemplo de fallo en el puesto
Confidencialidad	¿Accede solo quien debe?	Un expediente con datos de salud visible en una pantalla sin bloquear en una oficina abierta al público.
Integridad	¿El dato es el que era?	Un fichero de liquidaciones alterado por un programa malicioso o por un error de manipulación.
Disponibilidad	¿Está cuando se necesita?	Documentos guardados solo en el disco local de un portátil que se avería.
Autenticidad	¿Es de quien dice ser?	Un correo suplantando a la Intervención General que solicita un cambio de cuenta bancaria.
Trazabilidad	¿Se sabe quién hizo qué y cuándo?	Uso de una cuenta genérica compartida por varias personas: ninguna actuación es imputable.

> DATO CLAVE
>
> El ENS `[ENS]` maneja **cinco dimensiones** de seguridad: **disponibilidad, integridad, confidencialidad, autenticidad y trazabilidad** (regla mnemotécnica **D-I-C-A-T**). Las tres primeras forman la triada clásica; **autenticidad y trazabilidad** son la aportación característica del esquema español y las que sostienen la validez jurídica de la actuación administrativa electrónica.

Las **amenazas típicas del puesto** se agrupan en cuatro familias:

1. **Ataques dirigidos a la persona**: *phishing* y *spear phishing*, fraude del CEO, *vishing* (telefónico) y *smishing* (SMS), suplantación de proveedores. Explotan la confianza, la urgencia y la autoridad, no un fallo técnico.
2. **Código malicioso**: **ransomware** (cifra la información y exige rescate), troyanos de acceso remoto, ladrones de credenciales (*infostealers*), *keyloggers*, mineros, gusanos que se propagan por la red local.
3. **Fallos y descuidos**: pérdida o robo del dispositivo, envío a destinatario equivocado, publicación indebida, borrado accidental, uso de servicios personales en la nube para

documentos de trabajo (*shadow IT*), soportes extraíbles sin control.

4. **Amenazas físicas y del entorno**: acceso no autorizado a la oficina, **espionaje visual** (*shoulder surfing*), documentos en la impresora compartida, retirada de un equipo sin borrado seguro del disco.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> El puesto de la Oficina de Atención a la Ciudadanía concentra casi todas: atiende con **público delante de la pantalla** (espionaje visual), maneja **datos personales de vecinos** —incluidas, en algunos trámites, categorías especiales como los datos de salud de una solicitud de tarjeta de estacionamiento para personas con movilidad reducida—, recibe **correos externos** con documentación adjunta de la ciudadanía (vector de código malicioso) e imprime documentos en una impresora compartida del área. Cada una de esas condiciones exige un control distinto, y ninguno de ellos es un antivirus.

3.1.1. Preservación de la confidencialidad en puestos de usuario final

La confidencialidad se protege combinando controles de **cuatro naturalezas** —organizativos, físicos, técnicos y de personas—, siguiendo la clasificación de **ISO/IEC 27002:2022** `[ISO27002]`. Ninguno basta por separado.

a) Clasificación de la información. Es el punto de partida: no se puede proteger de forma proporcionada lo que no se ha clasificado. Un esquema habitual en la Administración distingue **pública**, **de uso interno**, **restringida** (datos personales ordinarios) y **confidencial** (categorías especiales de datos, información con clasificación de seguridad). La clasificación determina **quién accede, cómo se almacena, cómo se transmite, cuánto tiempo se conserva y cómo se destruye**.

b) Controles físicos y del entorno:

- **Política de puesto de trabajo despejado y pantalla limpia** (*clean desk / clear screen*): no dejar documentos con datos personales a la vista, guardar bajo llave lo sensible al ausentarse, y no dejar credenciales anotadas.
- **Bloqueo de sesión**: manual al levantarse (combinación de teclado) y **automático por inactividad** (típicamente a los pocos minutos), con desbloqueo mediante credencial.
- **Filtros de privacidad** en pantallas orientadas al público y colocación del monitor fuera del campo de visión del mostrador.
- **Impresión segura** (*pull printing*): el documento no sale hasta que la persona se identifica en la impresora; evita hojas con datos personales olvidadas en la bandeja.
- **Destrucción segura** de papel (destructora de corte cruzado) y **borrado seguro de soportes** antes de reutilizar o retirar un equipo, conforme a las categorías *clear*, *purge* y *destroy* de **NIST SP 800-88** `[NIST-800-88]`. **Formatear no es borrar**: en un disco magnético la información

sigue siendo recuperable, y en un SSD el borrado exige órdenes específicas del propio dispositivo o el cifrado previo del soporte (*crypto-erase*).

c) Controles técnicos (se desarrollan en §3.2 y §3.3): control de acceso y mínimo privilegio, cifrado del disco y de los soportes extraíbles, cifrado del tráfico, control de puertos USB, prevención de fuga de datos (DLP), gestión centralizada de la configuración y del inventario, y protección frente a código malicioso.

d) Controles sobre las personas:

- **Acuerdos de confidencialidad** y deber de secreto, que **subsiste tras finalizar la relación** de servicio.
- **Formación y concienciación continuada**, con simulaciones de *phishing* y comunicación de lecciones aprendidas. Es el control con mejor relación coste-eficacia frente a la ingeniería social.
- **Normativa de uso** de los sistemas de información: qué se puede instalar, qué uso personal se admite, qué está prohibido (servicios personales de almacenamiento para documentos de trabajo, reenvío de correo corporativo a cuentas privadas), y qué consecuencias tiene el incumplimiento `[PSI-MADRID]`.
- **Procedimiento de notificación de incidentes**: quién avisa, a quién, en cuánto tiempo. Es crítico para cumplir el plazo de **72 horas** de notificación de brechas de datos personales a la autoridad de control del **art. 33 del RGPD** `[RGPD]`.

e) Teletrabajo y dispositivos móviles. El puesto ha dejado de estar dentro del perímetro. Los controles adicionales son: **acceso remoto cifrado** (VPN o acceso *zero trust* con verificación de identidad y de estado del dispositivo), **cifrado obligatorio** del disco del portátil, **prohibición de redes wifi abiertas sin túnel**, gestión mediante **MDM/UEM** con capacidad de **borrado remoto** en caso de pérdida, y separación entre perfil corporativo y personal en dispositivos de uso mixto (BYOD).

> DATO CLAVE
>
> En el ámbito laboral, la **LOPDGDD** `[LOPDGDD]` reconoce en su Título X el **derecho a la intimidad frente al uso de dispositivos digitales** (art. 87): el empleador puede acceder a los contenidos **solo para controlar el cumplimiento de las obligaciones laborales y garantizar la integridad de los dispositivos**, y debe haber establecido **criterios de uso previamente**, con participación de la representación de los trabajadores. Los arts. 88-91 regulan la desconexión digital, la videovigilancia, la geolocalización y los derechos digitales en la negociación colectiva. Es decir: **la monitorización del puesto no es libre**, y su legitimidad depende de haber informado antes.

RELACIÓN CON OTROS TEMAS

La **seguridad en el puesto del usuario** desde la óptica de la **red** —seguridad perimetral, acceso remoto seguro y VPN— se desarrolla en el **Tema 36**; los conceptos generales de seguridad, criptografía y firma digital, en el **Tema 32**; y las **copias de seguridad** como sistema, con sus políticas y su virtualización, en el **Tema 26**. Este epígrafe se limita a la perspectiva del puesto.

3.1.2. Garantía de la disponibilidad de la información

La disponibilidad en el puesto se juega sobre una decisión de arquitectura anterior a cualquier control: **dónde reside el dato**.

Regla de oro: en el puesto no debe residir información única. El puesto es el elemento más frágil del sistema —se avería, se pierde, se roba, se infecta— y el que menos garantías de continuidad ofrece. El dato de trabajo debe vivir en el **repositorio corporativo** (unidad de red, gestor documental, aplicación de gestión, servicio corporativo en la nube), donde está respaldado, auditado y accesible desde otro puesto. El disco local es **caché de trabajo**, no archivo.

Esta regla resuelve simultáneamente tres problemas: disponibilidad (si el portátil se rompe, el trabajo sigue desde otro equipo), confidencialidad (el control de acceso se aplica en el repositorio, no en cada disco) y **cumplimiento documental**, porque un expediente administrativo debe estar en el sistema de gestión de expedientes, no en la carpeta personal de quien lo tramita.

Amenazas a la disponibilidad en el puesto y sus contramedidas:

Amenaza	Contramedida principal
Avería de hardware (disco, fuente, placa)	Dato en repositorio corporativo; **puesto estandarizado y reinstalable** en poco tiempo desde imagen; stock de sustitución.
Borrado o modificación accidental	Copias de seguridad con **versionado** e histórico; papelera de red con retención; permisos ajustados.
Ransomware	Segmentación, mínimo privilegio, protección del *endpoint* y, sobre todo, **copias inmutables o desconectadas** verificadas (§3.3.2).
Pérdida o robo del dispositivo	Dato no residente + cifrado del disco + borrado remoto.
Corte de suministro eléctrico o de red	SAI en puestos críticos; conectividad alternativa; **modo de contingencia** documentado para la atención presencial.
Software desactualizado o incompatible	Gestión centralizada de actualizaciones y de la configuración; ventanas de mantenimiento planificadas.
Dependencia de una persona	Documentación, buzones y carpetas **funcionales** (no personales) y procedimientos de sustitución.

Las dos métricas que ordenan todo el diseño de la disponibilidad son:

- **RPO** (*Recovery Point Objective*): **cuánta información se puede permitir perder**, medida en tiempo hacia atrás desde el incidente. Determina la **frecuencia** de las copias. Un RPO de 24 horas significa que una copia diaria basta; un RPO de 15 minutos exige replicación casi continua.
- **RTO** (*Recovery Time Objective*): **cuánto tiempo se puede permitir estar sin el servicio**, medido hacia delante desde el incidente. Determina la **capacidad y el procedimiento de restauración**: no la copia, sino la velocidad a la que se vuelve a trabajar.

> DATO CLAVE
>
> **RPO mira hacia atrás y habla de datos** (¿cuánto puedo perder?); **RTO mira hacia delante y habla de tiempo de servicio** (¿cuánto puedo tardar en volver?). Reducir el RPO cuesta en frecuencia y almacenamiento; reducir el RTO cuesta en infraestructura de recuperación. Confundirlos es un error frecuente.

Junto a ellas se manejan el **MTBF** (tiempo medio entre fallos, mide la fiabilidad del componente), el **MTTR** (tiempo medio de reparación) y la **disponibilidad** expresada en porcentaje anual: un 99,9 % admite unas **8,8 horas** de indisponibilidad al año, y un 99,99 %, unos **53 minutos**.

EJERCICIO RESUELTO

La Oficina de Atención a la Ciudadanía puede trabajar con un desfase máximo de dos horas en la información de citas y no puede estar más de 30 minutos sin poder atender. ¿Qué RPO y qué RTO se fijan, y qué implica cada uno? **Solución**: **RPO = 2 horas** → la copia o la replicación de la base de datos de citas debe ejecutarse al menos cada dos horas; una copia nocturna sería insuficiente. **RTO = 30 minutos** → no basta con tener la copia: hace falta un procedimiento de restauración probado que quepa en media hora (sistema en alta disponibilidad o conmutación a un nodo secundario), más un **procedimiento manual de contingencia** —listado impreso de citas del día— que permita atender mientras se recupera el servicio. Obsérvese que el RTO, no el RPO, es el que obliga a invertir en infraestructura.

3.2. Control de acceso y protección criptográfica

3.2.1. Autenticación de usuarios y principio de mínimo privilegio

El control de acceso se descompone en cuatro pasos que conviene no mezclar:

1. **Identificación**: el sujeto declara quién es (nombre de usuario, número de empleado, certificado).
2. **Autenticación**: demuestra que es quien dice ser mediante uno o varios **factores**.
3. **Autorización**: el sistema determina **qué puede hacer** ese sujeto ya autenticado sobre cada recurso.
4. **Trazabilidad** (*accounting* o rendición de cuentas): se registra lo que hizo, de modo que sea **imputable** a una persona concreta.

DATO CLAVE

Identificación ≠ autenticación ≠ autorización. Decir quién soy es identificación; demostrarlo es autenticación; poder hacer algo es autorización. Y sin **cuentas nominativas** no hay trazabilidad: por eso las **cuentas genéricas compartidas** están proscritas en el ENS salvo justificación excepcional, y por eso una actuación realizada con ellas no puede imputarse a nadie `[ENS]`.

Los tres tipos de factor de autenticación:

Factor	Naturaleza	Ejemplos	Debilidad característica
Algo que se sabe	Conocimiento	Contraseña, PIN, frase de paso.	Se puede robar por *phishing*, adivinar o reutilizar.
Algo que se tiene	Posesión	Tarjeta criptográfica, DNIe, llave FIDO2, aplicación de código temporal (TOTP), certificado en el dispositivo.	Se puede perder o sustraer.
Algo que se es	Inherencia	Huella dactilar, rostro, iris, patrón de voz.	**No es revocable**: si se compromete la plantilla biométrica, no se puede «cambiar» el dedo.

La **autenticación multifactor (MFA)** exige **dos o más factores de naturaleza distinta**: contraseña + código de la aplicación es MFA; contraseña + pregunta de seguridad **no lo es**, porque ambos son conocimiento. Es el control individual que más ataques de robo de credenciales neutraliza.

> DATO CLAVE
>
> No todos los segundos factores son igual de fuertes. **NIST SP 800-63B** `[NIST-800-63B]` define tres niveles de garantía (**AAL1, AAL2 y AAL3**) y considera el **SMS un canal restringido** por su exposición al *SIM swapping* y a la interceptación. La autenticación **resistente al phishing** —**FIDO2/WebAuthn** `[WEBAUTHN]` o certificado en tarjeta criptográfica— es superior porque la credencial está **ligada criptográficamente al dominio legítimo** y no puede entregarse a un sitio suplantado, ni siquiera por un usuario engañado.

Contraseñas: lo que hoy recomiendan las guías. El criterio ha cambiado respecto a la doctrina clásica `[NIST-800-63B]`:

- **La longitud importa más que la complejidad**: se favorecen frases de paso largas frente a reglas rígidas de mayúsculas y símbolos, que empujan a patrones predecibles (`Madrid2026!`).
- **No forzar caducidad periódica sin motivo**: el cambio obligatorio cada 30 o 60 días degrada la calidad de las contraseñas (incrementos triviales). Se cambia **cuando hay indicio de compromiso**.
- **Comprobar contra listas de contraseñas filtradas** y bloquear las comunes.
- **Nunca reutilizar** entre servicios corporativos y personales; usar **gestor de contraseñas** corporativo.

- En el servidor, **almacenar solo el resumen** con funciones diseñadas para ello (Argon2, scrypt, bcrypt o PBKDF2) con **sal única por usuario** y coste ajustado — nunca cifrado reversible ni un resumen rápido sin sal `[OWASP-CHEAT]`.
- **Limitar los intentos** (bloqueo temporal progresivo) para frenar la fuerza bruta y el relleno de credenciales (*credential stuffing*).

Modelos de autorización:

- **DAC** (discrecional): el propietario del recurso decide quién accede. Es el modelo de las carpetas compartidas; flexible y difícil de auditar.
- **MAC** (obligatorio): el sistema impone el acceso según etiquetas de clasificación; propio de entornos con información clasificada.
- **RBAC** (basado en roles): los permisos se asignan a **roles** —«tramitador de licencias», «jefe de negociado», «administrador de la aplicación»— y las personas se asignan a roles. Es el modelo **estándar en la Administración**, porque hace la autorización **auditable, revisable y estable** frente a la rotación de personas.
- **ABAC** (basado en atributos): la decisión se calcula con atributos del sujeto, del recurso, de la acción y del contexto (hora, ubicación, estado del dispositivo). Es el modelo de las arquitecturas *zero trust*.

El principio de mínimo privilegio —formulado por Saltzer y Schroeder en 1975 `[SALTZER75]` y recogido como requisito mínimo por el ENS `[ENS]`— establece que cada sujeto y cada proceso deben operar con **los permisos estrictamente necesarios para su función y durante el tiempo estrictamente necesario**. En el puesto se traduce en:

- El usuario **no es administrador local** de su equipo. Es la medida que más eficazmente limita la instalación de programas no autorizados y el alcance del código malicioso: sin privilegios, el ransomware cifra los ficheros del usuario, pero no compromete el sistema ni se propaga con la misma facilidad.
- Las tareas administrativas se realizan con **cuentas separadas y nominativas**, distintas de la cuenta ordinaria de trabajo, y no se usan para navegar ni leer correo.
- Los permisos se conceden **por rol**, se revisan **periódicamente** y se **retiran de inmediato** al cambiar de puesto o cesar (el control de **bajas** es el que más se descuida: cuentas de personal que ya no está siguen activas durante meses).
- **Segregación de funciones**: quien inicia una operación no es quien la aprueba; quien desarrolla no es quien despliega en producción.
- Principio complementario de **necesidad de conocer** (*need to know*): tener el nivel de acceso no basta, hace falta además necesitarlo para la tarea concreta.

EJEMPLO DE APLICACIÓN EN EL AYTO

Una tramitadora de licencias no debe poder consultar el padrón completo, sino únicamente los datos de las personas afectadas por los expedientes que tiene asignados; y los accesos deben quedar registrados de forma nominativa, de modo que una consulta indebida —a los datos de un vecino conocido, por ejemplo— sea **detectable e imputable**. Esto es a la vez **mínimo privilegio + necesidad de conocer + trazabilidad**, y es exactamente lo que exige el principio de **minimización** del RGPD y la medida de control de acceso del ENS `[RGPD]` `[ENS]`.

3.2.2. Cifrado de almacenamiento local y comunicaciones

La criptografía es la última línea de defensa de la confidencialidad: **el control que sigue funcionando cuando todos los demás han fallado** y el soporte ha salido del perímetro.

Cifrado en reposo (*data at rest*). Tres granularidades `[NIST-800-111]`:

Tipo	Qué protege	Uso típico
Cifrado de disco completo (FDE)	Todo el volumen del sistema, incluidos temporales, archivo de paginación e hibernación.	**Obligatorio en todo portátil** y recomendable en sobremesa. Se apoya en el chip **TPM** para custodiar la clave y vincularla al equipo, con desbloqueo mediante credencial del usuario o PIN previo al arranque.
Cifrado de volumen o de contenedor	Un espacio delimitado dentro del disco.	Carpeta o unidad virtual para información especialmente sensible.
Cifrado a nivel de fichero	Documentos concretos, **también cuando salen del equipo**.	Envío de un fichero con datos personales a otra unidad administrativa, cifrado de soportes extraíbles.

Puntos críticos: el FDE protege frente al **robo del equipo apagado**, pero **no** frente a un atacante que se hace con la sesión iniciada (para el sistema en marcha, los ficheros están descifrados) ni frente a código malicioso que se ejecuta con los privilegios del usuario. El **cifrado obligatorio de los soportes extraíbles** —o su bloqueo— es imprescindible: la memoria USB perdida es una causa recurrente de brecha. Y toda estrategia de cifrado exige una **gestión de claves** con custodia y **recuperación** (claves de recuperación depositadas centralmente): sin ella, un olvido convierte la protección de la confidencialidad en una pérdida de disponibilidad.

DATO CLAVE

El **cifrado de disco completo** protege la información **cuando el equipo está apagado o el disco se extrae**. Con la sesión abierta, el sistema entrega los datos descifrados a cualquier proceso autorizado: por eso el cifrado **complementa**, pero **no sustituye**, al control de acceso, al bloqueo de sesión y a la protección frente a código malicioso `[NIST-800-111]`.

Cifrado en tránsito (*data in transit*). El tráfico del puesto debe ir cifrado siempre, dentro y fuera de la organización:

- **TLS** (preferentemente **1.3** `[RFC9846]`) para web, correo y servicios: proporciona confidencialidad, integridad y **autenticación del servidor** mediante certificado. Deben deshabilitarse SSL y las versiones antiguas de TLS, y aplicarse **HSTS** `[RFC6797]` para impedir la degradación a HTTP.
- **VPN** (IPsec o basada en TLS) o acceso *zero trust* para el teletrabajo, con **MFA** en el acceso y comprobación del estado del dispositivo.
- **Protocolos seguros** en sustitución de sus equivalentes en claro: SSH en lugar de Telnet, SFTP/FTPS en lugar de FTP, LDAPS en lugar de LDAP.
- **Correo electrónico**: cifrado del canal (STARTTLS) y, cuando el contenido lo requiera, cifrado **de extremo a extremo** del mensaje o envío del adjunto cifrado con la contraseña comunicada por un canal distinto.

Cifrado en uso y conceptos asociados: **firma electrónica** (integridad, autenticidad y no repudio), **resumen o hash** (integridad), **certificado electrónico** y **PKI** (vinculan una clave pública a una identidad). En el sector público español, la identificación de la ciudadanía se apoya en **certificado electrónico, DNIe y Cl@ve**, y la del empleado público en certificado de empleado público o tarjeta criptográfica.

RELACIÓN CON OTROS TEMAS

Los fundamentos criptográficos —cifrado simétrico y asimétrico, funciones resumen, PKI, firma digital y sus mecanismos— se desarrollan en el **Tema 32**; los protocolos **HTTPS y SSL/TLS** en el **Tema 35**; y la seguridad perimetral, el acceso remoto y las **VPN** en el **Tema 36**. Aquí interesan solo en cuanto controles aplicados al puesto de usuario.

EJERCICIO RESUELTO

Un portátil municipal con expedientes descargados se sustrae del coche de un inspector. ¿Es una brecha de datos personales notificable? **Solución**: hay que distinguir. Si el disco estaba **cifrado con FDE**, el equipo estaba **apagado** y la clave de cifrado no era accesible (custodiada por TPM y protegida por credencial robusta), el incidente afecta a la **disponibilidad** —el inspector ha perdido su herramienta— pero **no compromete la confidencialidad**, porque la información es ininteligible para el tercero; el RGPD `[RGPD]` prevé precisamente que en tal caso puede no ser necesaria la comunicación a los interesados, aunque el incidente **debe documentarse internamente** y valorarse la notificación a la autoridad de control. Si el disco **no** estaba cifrado, o el equipo se sustrajo **con la sesión iniciada**, hay compromiso de confidencialidad de datos personales y procede evaluar la notificación a la autoridad de control en **72 horas** y, si el riesgo para los derechos es alto, la comunicación a los afectados. Medidas posteriores en ambos casos: revocación de credenciales y certificados del equipo, **borrado remoto** si el MDM lo permite, y revisión de por qué había expedientes residiendo en local (§3.1.2).

3.3. Seguridad operativa y prevención de pérdida de datos

3.3.1. Protección frente a código malicioso en el endpoint

Se denomina **código dañino** o **malware** a todo programa diseñado para ejecutar acciones no autorizadas en un sistema. Las familias que hay que saber distinguir:

Familia	Rasgo definitorio
Virus	Se **inserta en otro programa o fichero** y se propaga cuando el anfitrión se ejecuta.
Gusano (*worm*)	Se propaga **por sí mismo** a través de la red, sin anfitrión ni intervención del usuario.
Troyano	Se presenta como software legítimo y **oculta una carga maliciosa**; no se replica.
Ransomware	**Cifra** la información y exige un rescate; en su modalidad de **doble extorsión**, además **exfiltra** los datos y amenaza con publicarlos, de modo que tener copia de seguridad ya no evita el daño reputacional ni la brecha de datos personales.
Spyware e infostealer	Recopila información del equipo: credenciales guardadas en el navegador, *cookies* de sesión, documentos.
Keylogger	Registra las pulsaciones de teclado.
Rootkit	Se instala en capas profundas del sistema para **ocultar su presencia** y la de otros componentes.
Adware y cryptojacking	Publicidad intrusiva o minado de criptomoneda con los recursos del equipo.
Puerta trasera (*backdoor*)	Acceso alternativo persistente que elude la autenticación.

Vectores de entrada al puesto: adjunto o enlace de correo (el más frecuente), documento con **macros**, descarga desde un sitio comprometido (*drive-by*), soporte USB, explotación de una vulnerabilidad no parcheada en el navegador o en el sistema, software pirata o instalado desde fuentes no oficiales, y **cadena de suministro** (actualización legítima manipulada).

Tecnologías de protección y su evolución:

- **Antivirus por firmas**: compara con un catálogo de patrones conocidos. Eficaz y barato contra lo ya identificado; **ciego ante el código nuevo** o polimórfico, y depende de la actualización constante del catálogo.
- **Detección heurística y estática**: busca características sospechosas en el fichero sin ejecutarlo.
- **Análisis de comportamiento** en tiempo de ejecución: detecta **lo que el programa hace** — cifrar masivamente ficheros, inyectarse en otro proceso, contactar con un servidor de mando y

control— con independencia de su firma. Es la única defensa realista frente al ransomware nuevo.

- **Entorno aislado** (*sandbox*): ejecuta el fichero sospechoso en un entorno controlado antes de entregarlo al usuario.
- **EDR/XDR** (*Endpoint Detection and Response*): agente que registra la telemetría del puesto, detecta patrones de ataque, permite **investigar** el incidente y **responder** de forma centralizada (aislar el equipo de la red, matar el proceso, revertir cambios). Es el estándar actual en organizaciones medianas y grandes.

Medidas complementarias, tanto o más importantes que el producto:

1. **Actualización y gestión de parches**: sistema operativo, navegador, ofimática, lectores de PDF, complementos y firmware, con un ciclo definido y priorización por criticidad (**CVSS** `[CVSS]`) y por explotación activa conocida.
2. **Mínimo privilegio** (§3.2.1): sin administrador local, la mayoría del código malicioso ve muy reducido su alcance.
3. **Control de aplicaciones** (listas de permitidos) y **bloqueo de macros** procedentes de Internet.
4. **Filtrado en el correo y en la navegación**: análisis de adjuntos, reescritura de enlaces, bloqueo de categorías y de dominios recién registrados.
5. **Segmentación de red**: impide que un puesto comprometido alcance directamente servidores o el resto de puestos (movimiento lateral).
6. **Copias de seguridad** verificadas y aisladas (§3.3.2): la **única** medida que garantiza recuperación frente a un cifrado consumado.
7. **Formación**: la mayoría de las intrusiones empiezan por una acción humana inducida.
8. **Plan de respuesta a incidentes** ensayado: aislar, contener, erradicar, recuperar y aprender, con los cauces de notificación —**CCN-CERT** en el sector público `[CCN-STIC]`, autoridad de protección de datos si hay datos personales— identificados de antemano.

> DATO CLAVE
>
> Frente al **ransomware**, la protección del *endpoint* reduce la probabilidad, pero **lo único que garantiza la recuperación es la copia de seguridad**, siempre que esté **fuera del alcance del atacante** (desconectada o inmutable) y **se haya probado su restauración**. Y como el ransomware moderno practica **doble extorsión** —cifra y además exfiltra—, tener copias **no exime** de tratar el incidente como una posible **brecha de datos personales** notificable `[RGPD]`.

3.3.2. Copias de seguridad y prevención de pérdida de datos

Tipos de copia:

Tipo	Qué copia	Ventaja	Inconveniente
Completa (*full*)	Todos los datos del conjunto.	Restauración simple: basta una copia.	Lenta y voluminosa.
Diferencial	Lo cambiado **desde la última copia completa**.	Restauración con **dos** elementos: la completa + la última diferencial.	Crece de tamaño cada día hasta la siguiente completa.
Incremental	Lo cambiado **desde la última copia de cualquier tipo**.	La más rápida y la que menos ocupa.	Restauración con la completa + **toda la cadena** de incrementales: más lenta y más frágil.
Sintética / permanente incremental	Consolida las incrementales en una completa virtual en el propio sistema de copia.	Restauración rápida sin cadena larga.	Requiere un producto que lo soporte.
Instantánea (*snapshot*)	Estado puntual del volumen o de la máquina virtual.	Muy rápida, útil antes de un cambio.	**No es una copia de seguridad**: depende del mismo almacenamiento.

DATO CLAVE

Diferencia clave: la **diferencial** se mide siempre desde la **última completa** y se restaura con **dos piezas**; la **incremental** se mide desde la **última copia de cualquier tipo** y se restaura con la completa **más toda la cadena**. La incremental ahorra tiempo y espacio en la copia; la diferencial lo ahorra en la restauración.

La regla 3-2-1 y su refuerzo. La práctica de referencia establece mantener **3** copias de los datos (la original más dos), en **2** tipos de soporte distintos, con **1** de ellas **fuera de las instalaciones**. Frente al ransomware se refuerza con **1 copia inmutable o desconectada** (*air-gapped*, WORM) y **0 errores tras verificación**, porque un atacante con privilegios buscará primero **cifrar o borrar las copias**.

Requisitos de una política de copias completa: alcance (qué se copia y qué no), **RPO y RTO** por tipo de información (§3.1.2), frecuencia y ventana de ejecución, **retención** (cuánto tiempo se guarda cada copia, con esquemas de generaciones diario/semanal/mensual/anual), ubicación, **cifrado de la copia** —una copia sin cifrar es una fuga de datos empaquetada—, control de acceso

propio y separado del de producción, monitorización de los trabajos y, sobre todo, **pruebas periódicas de restauración documentadas**.

> DATO CLAVE
>
> **Una copia que no se ha restaurado nunca no es una copia de seguridad: es una hipótesis.** La prueba periódica de restauración es un requisito expreso de las buenas prácticas y del ENS, y el fallo más común en organizaciones que creen estar protegidas `[ENS]` `[ISO27002]`.

En el puesto de usuario concretamente, la política debe responder a tres preguntas: ¿se copia el disco local del portátil, o se garantiza que no hay dato único en él? (lo segundo es preferible); ¿qué pasa con los perfiles y la configuración cuando se sustituye un equipo?; y ¿cómo se recupera un fichero borrado por error sin tener que restaurar un sistema entero? (versionado e histórico en el repositorio corporativo).

Prevención de pérdida y fuga de datos (DLP). Mientras la copia de seguridad protege frente a la **pérdida** de la información, el **DLP** protege frente a su **salida no autorizada**. Un sistema DLP:

1. **Clasifica** la información (por patrones —NIF, IBAN, número de historia clínica—, por etiquetas o por huella digital del documento).
2. **Vigila** los canales de salida: correo, web y almacenamiento en la nube, dispositivos extraíbles, impresión, portapapeles, captura de pantalla.
3. **Actúa**: registra, avisa al usuario, exige justificación, cifra automáticamente o **bloquea** la operación.

Se despliega en tres puntos: **en el puesto** (agente), **en la red** (inspección del tráfico de salida) y **en el servicio** (correo y repositorios en la nube). Sus límites conocidos: falsos positivos que entorpecen el trabajo, incapacidad de inspeccionar tráfico cifrado no intermediado, y elusión mediante fotografía de la pantalla. Se complementa con **IRM/gestión de derechos** (el documento lleva sus permisos consigo aunque salga), **marcas de agua** y control de puertos.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> Un empleado intenta enviar a su correo personal una hoja de cálculo con 2.400 registros del padrón «para seguir trabajando en casa». El DLP detecta el patrón de NIF repetido, **bloquea el envío**, informa al usuario del motivo y registra el intento. El incidente se resuelve con formación y con la habilitación de un acceso remoto adecuado —que es la causa real del comportamiento—, no solo con la sanción: **un control que impide trabajar sin ofrecer alternativa se acaba eludiendo**, que es justo lo que advierte el principio de **aceptabilidad psicológica** de Saltzer y Schroeder `[SALTZER75]`.

3.3.3. Esquema Nacional de Seguridad en el puesto de usuario final

El **Esquema Nacional de Seguridad**, regulado por el **Real Decreto 311/2022** `[ENS]`, es el marco obligatorio de seguridad para el sector público español y para las entidades privadas que le prestan servicios. Su finalidad es crear las condiciones de confianza en el uso de los medios electrónicos mediante medidas que garanticen las **cinco dimensiones** (§3.1).

Los principios básicos que lo informan son: la **seguridad como proceso integral** (personas, procesos y tecnología, no solo productos); la **gestión de la seguridad basada en los riesgos**; la **prevención, detección, respuesta y conservación**; la **existencia de líneas de defensa** (defensa en profundidad); la **vigilancia continua y reevaluación periódica**; y la **diferenciación de responsabilidades** entre el responsable de la información, el del servicio, el de la seguridad y el del sistema.

Los requisitos mínimos (art. 12) abarcan la organización e implantación del proceso de seguridad, el análisis y la gestión de riesgos, la gestión de personal, la profesionalidad, la **autorización y control de los accesos**, la protección de las instalaciones, la adquisición de productos y servicios de seguridad, el **mínimo privilegio**, la integridad y actualización del sistema, la **protección de la información almacenada y en tránsito**, la prevención frente a otros sistemas interconectados, el **registro de la actividad y detección de código dañino**, la gestión de incidentes, la **continuidad de la actividad** y la mejora continua.

Categorización del sistema. Cada sistema se valora en las cinco dimensiones con nivel **BAJO, MEDIO o ALTO** según el perjuicio que causaría un incidente; la **categoría del sistema** (**BÁSICA, MEDIA o ALTA**) es la del nivel más alto alcanzado en cualquiera de sus dimensiones. La categoría determina qué medidas del **Anexo II** son exigibles y con qué refuerzos.

> DATO CLAVE
>
> Distinguir **nivel** de **categoría**: el **nivel** (bajo/medio/alto) se predica de **cada dimensión** de seguridad; la **categoría** (básica/media/alta) se predica del **sistema** y es la del **nivel más alto** de sus dimensiones. Una sola dimensión valorada en nivel alto convierte todo el sistema en categoría **ALTA** `[ENS]`.

El Anexo II organiza las medidas en tres bloques: **marco organizativo** (`org` : política, normativa, procedimientos y proceso de autorización), **marco operacional** (`op` : planificación, **control de acceso**, explotación, servicios externos, servicios en la nube, continuidad y monitorización) y **medidas de protección** (`mp` : instalaciones, personal, **equipos**, comunicaciones, **soportes de información**, aplicaciones informáticas, información y servicios).

Las que inciden directamente en el **puesto de usuario final** son, agrupadas por el objetivo que persiguen:

Objetivo	Medida del ENS (grupo)	Traducción práctica
Que solo acceda quien debe	Control de acceso (`op.acc`): identificación, requisitos de acceso, segregación de funciones, gestión de derechos, **mecanismo de autenticación**	Cuenta nominativa, MFA, RBAC, revisión de permisos y baja inmediata al cese.
Que el entorno físico no delate la información	Protección de los equipos (`mp.eq`): **puesto de trabajo despejado**, **bloqueo de puesto de trabajo**, **protección de equipos portátiles**	Mesa despejada, bloqueo automático, cifrado y control del portátil fuera de la oficina.
Que el soporte que sale siga protegido	Protección de los soportes de información (`mp.si`): etiquetado, **criptografía**, custodia, transporte y **borrado y destrucción**	Cifrado de USB y de copias, destrucción certificada al retirar discos.
Que no entre ni actúe código dañino	Explotación (`op.exp`): configuración de seguridad, **gestión de la configuración**, mantenimiento y **actualizaciones**, **protección frente a código dañino**, registro de actividad	Bastionado, parcheo, EDR, registro de la actividad de los usuarios.
Que la información sobreviva	Protección de la información (`mp.info`): calificación, cifrado, firma electrónica, **copias de seguridad** · Continuidad (`op.cont`)	Copias verificadas, plan de continuidad y análisis de impacto.
Que se sepa qué ha pasado	Monitorización (`op.mon`) y registro de actividad	Detección de intrusión, métricas y trazas imputables a personas.

Cada medida se aplica con **exigencia creciente** según la categoría del sistema, y el ENS prevé además **refuerzos** concretos y **perfiles de cumplimiento específicos** —entre ellos, los orientados a **entidades locales**— que adaptan el conjunto a la realidad de organizaciones con menos recursos. La conformidad se acredita mediante **autoevaluación** (categoría básica) o **auditoría de certificación** por entidad acreditada (categorías media y alta), con **auditoría al menos cada dos años**, y el CCN publica las guías **CCN-STIC** de implantación y bastionado `[CCN-ENS]` `[CCN-STIC]` .

RELACIÓN CON OTROS TEMAS

Los **principios básicos del ENS y del ENI** se desarrollan de forma completa en el **Tema 39**; la **seguridad física y lógica, las amenazas y las técnicas criptográficas** en el **Tema 32**; y la **administración del sistema operativo y su actualización** en el **Tema 27**. Aquí el ENS se aborda exclusivamente en su proyección sobre el puesto de trabajo.

EJERCICIO RESUELTO

El sistema de gestión de expedientes de licencias del Ayuntamiento maneja datos personales ordinarios; su indisponibilidad durante una jornada causaría un perjuicio apreciable pero reparable, y una divulgación indebida causaría un perjuicio grave a los interesados. ¿Qué categoría ENS resulta y qué implica para el puesto? **Solución**: valorados los niveles —disponibilidad **medio**, integridad **medio**, **confidencialidad alto**, autenticidad **medio**, trazabilidad **medio**—, la **categoría del sistema es ALTA**, porque se toma el nivel **más alto** de cualquier dimensión `[ENS]`. Consecuencias para el puesto: exigencia reforzada del control de acceso (autenticación multifactor), cifrado de la información en los equipos y soportes, registro y **monitorización** de accesos con revisión periódica, medidas reforzadas de continuidad y **auditoría de certificación** bienal por entidad acreditada, no autoevaluación.

4. Conceptos de seguridad en el desarrollo de los sistemas

4.1. Ciclo de vida de desarrollo seguro

4.1.1. Modelos e integración de la seguridad en el desarrollo

Durante décadas la seguridad del software se trató como una **fase final**: se construía la aplicación y, antes de ponerla en producción, se le hacía una auditoría o se colocaba delante un cortafuegos. Ese modelo fracasa por dos razones: los defectos de **diseño** no se pueden parchear desde fuera, y el coste de corregir crece de forma acusada con la fase en que se detecta el defecto —de un cambio de una línea en la especificación se pasa a un rediseño, una migración de datos y una ventana de parada en producción.

El **ciclo de vida de desarrollo seguro** (**SSDLC**, *Secure Software Development Life Cycle*) responde integrando actividades de seguridad **en todas las fases**, con el criterio del **desplazamiento a la izquierda** (*shift left*): cuanto antes, mejor.

Fase del ciclo de vida	Actividades de seguridad
Requisitos	Requisitos de seguridad explícitos y verificables (a partir de **ASVS** `[OWASP-ASVS]`, del ENS y del RGPD); clasificación de los datos que se tratarán; requisitos legales de accesibilidad y de protección de datos.
Diseño / arquitectura	**Modelado de amenazas** (§4.1.2); aplicación de los principios de diseño seguro (§4.2.1); definición de la superficie de ataque, de los límites de confianza y del modelo de autorización; **privacidad desde el diseño** `[RGPD]`.
Implementación	Estándares de **codificación segura**; bibliotecas y marcos aprobados; revisión de código entre pares con lista de comprobación de seguridad; análisis estático (**SAST**) en el propio entorno de desarrollo.
Verificación / pruebas	**DAST**, análisis de composición (**SCA**), *fuzzing*, pruebas de casos de abuso, **prueba de penetración** antes de la puesta en producción.
Despliegue	Bastionado de la configuración, gestión de secretos, revisión de la configuración por defecto, firma de artefactos, segregación de entornos.
Operación y mantenimiento	Gestión de vulnerabilidades y de parches, **monitorización y registro**, respuesta a incidentes, revisión periódica de dependencias, gestión del fin de vida.
Retirada	Migración o **destrucción segura** de los datos, revocación de credenciales, baja de integraciones.

DATO CLAVE

El principio del **shift left**: la seguridad es **más barata y más eficaz cuanto antes se introduce**. Un requisito de autorización mal planteado detectado en la fase de requisitos se corrige con una frase; detectado en producción, obliga a rediseñar el modelo de permisos, migrar datos y notificar posiblemente una brecha. Pero *shift left* **no significa «solo al principio»**: la seguridad es una actividad de **todas** las fases, incluida la operación `[NIST-SSDF]` `[MS-SDL]`.

Modelos de referencia que hay que saber identificar:

- **Microsoft SDL** `[MS-SDL]`: el modelo pionero (2004). Estructura prácticas obligatorias por fase —formación, requisitos de seguridad y privacidad, **modelado de amenazas**, uso de funciones aprobadas, análisis estático y dinámico, *fuzzing*, revisión final de seguridad y **plan de respuesta a incidentes**— y es el origen del método **STRIDE**.

- **NIST SP 800-218 (SSDF)** `[NIST-SSDF]`: marco de referencia agnóstico, organizado en cuatro grupos de prácticas: **PO** (*Prepare the Organization*: preparar personas, procesos y herramientas), **PS** (*Protect the Software*: proteger el código y los artefactos frente a manipulación), **PW** (*Produce Well-Secured Software*: diseñar, codificar y verificar) y **RV** (*Respond to Vulnerabilities*: identificar, corregir y aprender). Es la referencia que la Administración estadounidense exige a sus proveedores y la más citada hoy en contratación.
- **OWASP SAMM 2.0** `[OWASP-SAMM]`: modelo de **madurez** prescriptivo, con cinco funciones de negocio —**Gobierno, Diseño, Implementación, Verificación y Operaciones**—, cada una con tres prácticas y con **tres niveles de madurez**. Sirve para medir dónde está una organización y planificar la mejora.
- **BSIMM** `[BSIMM]`: modelo **descriptivo**, construido observando lo que realmente hacen programas de seguridad reales; se usa para compararse con el sector, no para prescribir.
- **ISO/IEC 27034** `[ISO27034]`: norma de seguridad de aplicaciones que introduce el concepto de *Application Security Controls* y su gestión a lo largo del ciclo de vida.
- **OWASP ASVS** `[OWASP-ASVS]`: no es un modelo de proceso sino un **catálogo de requisitos verificables**, organizado por capítulos (autenticación, sesión, control de acceso, validación, criptografía, registro, ficheros, API, configuración) y en **tres niveles** de verificación crecientes. Es la herramienta idónea para **redactar los requisitos de seguridad de un pliego** y para definir el alcance de una auditoría.

> DATO CLAVE
> Diferencia entre los cuatro que más se confunden: **SAMM** es **prescriptivo** (qué deberías hacer y en qué orden madurar), **BSIMM** es **descriptivo** (qué hacen otros), **SSDF** es un **marco de prácticas** de referencia y **ASVS** es un **catálogo de requisitos verificables** de la aplicación. Los tres primeros hablan del **proceso**; ASVS habla del **producto** `[OWASP-SAMM]` `[BSIMM]` `[NIST-SSDF]` `[OWASP-ASVS]`.

DevSecOps es la traducción del SSDLC a los entornos de entrega continua: las comprobaciones de seguridad se **automatizan dentro de la cadena de integración y despliegue** (análisis estático y de dependencias en cada confirmación, análisis dinámico sobre el entorno de preproducción, revisión de la configuración como código, escaneo de imágenes de contenedor) y se definen **puertas de calidad** que detienen el despliegue si se supera un umbral de severidad. La clave organizativa es que la seguridad deja de ser un departamento que dice «no» al final y pasa a ser **una responsabilidad compartida y automatizada**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Aplicado a la aplicación de cita previa, un SSDLC mínimo pero real consiste en: requisitos de seguridad tomados del nivel aplicable de ASVS y de las medidas del ENS correspondientes a la categoría del sistema; modelado de amenazas en el diseño (§4.1.2); **SAST y SCA automáticos en cada confirmación** del repositorio; **DAST** semanal sobre el entorno de preproducción; **prueba de penetración** por un tercero antes de la puesta en producción y tras cada cambio mayor; y, en operación, revisión mensual de dependencias y procedimiento de respuesta ante una vulnerabilidad publicada. Todo ello es exigible **contractualmente** al proveedor y verificable en la recepción.

4.1.2. Análisis de requisitos y modelado de amenazas

Requisitos de seguridad. Un requisito de seguridad es tan específico y verificable como uno funcional. La diferencia con los requisitos funcionales está en su formulación: mientras estos describen **lo que el sistema debe hacer**, aquellos describen **lo que no debe poder ocurrir** y **cómo se comprueba**.

- Mal formulado: «la aplicación será segura», «se cumplirá el RGPD».
- Bien formulado: «toda operación sobre un expediente verificará en el servidor que el usuario autenticado tiene asignado ese expediente, y el intento fallido se registrará con identificador de usuario, expediente y marca de tiempo»; «las contraseñas se almacenarán con Argon2id con sal única por usuario»; «la sesión caducará por inactividad a los 15 minutos y su identificador se regenerará tras la autenticación».

Junto a ellos se documentan los **casos de abuso** (*abuse cases*): la contrapartida negativa de los casos de uso. Si un caso de uso es «el vecino consulta su expediente», el caso de abuso es «un usuario cambia el identificador del expediente en la URL y consulta el de otro vecino». Los casos de abuso alimentan directamente las pruebas de seguridad.

En el sector público hay tres fuentes obligatorias de requisitos: el **ENS** (medidas exigibles según la categoría del sistema) `[ENS]`, el **RGPD** —**protección de datos desde el diseño y por defecto** del art. 25, seguridad del tratamiento del art. 32 y, cuando el tratamiento entrañe alto riesgo, **evaluación de impacto** del art. 35— `[RGPD]` `[AEPD-GUIA]`, y el **RD 1112/2018** de accesibilidad (§2.3), que también es un requisito no funcional verificable.

DATO CLAVE

El **art. 25 del RGPD** impone dos obligaciones distintas: **protección de datos desde el diseño** (*by design*: las medidas se incorporan al determinar los medios de tratamiento, no después) y **protección de datos por defecto** (*by default*: sin intervención del usuario, solo se tratan los datos **necesarios** para cada finalidad, con la mínima accesibilidad y el mínimo plazo de conservación). Es el fundamento jurídico del desarrollo seguro en el sector público `[RGPD]`.

Modelado de amenazas. Es la actividad de seguridad de **mayor rendimiento** de todo el ciclo, porque se hace sobre el diseño —cuando cambiar cuesta poco— y encuentra fallos **arquitectónicos** que ninguna herramienta automática detecta. Adam Shostack la resume en **cuatro preguntas** `[SHOSTACK]`:

1. **¿En qué estamos trabajando?** → diagrama de flujo de datos con procesos, almacenes, flujos, entidades externas y, sobre todo, **límites de confianza** (*trust boundaries*): cada línea que separa dos zonas con distinto nivel de confianza es donde se concentran las amenazas.
2. **¿Qué puede salir mal?** → aplicación sistemática de **STRIDE** a cada elemento.
3. **¿Qué vamos a hacer al respecto?** → mitigar, transferir, evitar o **aceptar** el riesgo de forma consciente y documentada.
4. **¿Lo hemos hecho suficientemente bien?** → validación, y repetición del modelado cuando el diseño cambia.

El modelo STRIDE clasifica las amenazas en seis categorías, cada una de las cuales niega una propiedad de seguridad:

Categoría	Amenaza	Propiedad negada	Contramedida típica
S — *Spoofing*	Suplantación de identidad	**Autenticidad**	Autenticación fuerte, MFA, certificados, firma.
T — *Tampering*	Manipulación de datos o de código	**Integridad**	Firma y resumen, control de acceso de escritura, validación en servidor, TLS.
R — *Repudiation*	Negación de una acción realizada	**No repudio**	Registro de auditoría íntegro y sellado, firma electrónica.
I — *Information disclosure*	Revelación de información	**Confidencialidad**	Cifrado en tránsito y en reposo, control de acceso, minimización, mensajes de error genéricos.
D — *Denial of service*	Denegación de servicio	**Disponibilidad**	Limitación de peticiones, cuotas, dimensionamiento, protección perimetral.
E — *Elevation of privilege*	Elevación de privilegios	**Autorización**	Mínimo privilegio, validación de autorización en cada operación, aislamiento.

DATO CLAVE

Las seis letras de **STRIDE** y su emparejamiento con la propiedad que niegan — *Spoofing*/autenticidad, *Tampering*/integridad, *Repudiation*/no repudio, *Information disclosure*/confidencialidad, *Denial of service*/disponibilidad, *Elevation of privilege*/autorización `[SHOSTACK]` `[MS-SDL]`.

Otros métodos citados: **DREAD** (valoración del riesgo por daño, reproducibilidad, explotabilidad, usuarios afectados y descubribilidad; hoy poco usado por su subjetividad), **PASTA** (proceso en siete etapas orientado al riesgo de negocio), **attack trees** (árboles de ataque, que descomponen un objetivo del atacante en pasos) y **LINDDUN**, el equivalente de STRIDE para amenazas de **privacidad**, especialmente útil cuando hay datos personales.

Para **priorizar** lo encontrado se usa el riesgo (**probabilidad × impacto**) y, cuando ya existe una vulnerabilidad concreta, la puntuación **CVSS** `[CVSS]`, que combina métricas **base** (vector de ataque, complejidad, privilegios requeridos, interacción del usuario, alcance e impacto en CID), métricas **de amenaza** (madurez del exploit) y métricas **ambientales** (criticidad del activo en el entorno concreto). El resultado va de **0,0 a 10,0**, con las bandas ninguna (0,0), baja (0,1-3,9), media (4,0-6,9), alta (7,0-8,9) y **crítica (9,0-10,0)**.

EJERCICIO RESUELTO

Modele las amenazas del flujo «consulta del estado de un expediente» de la aplicación municipal. **Solución (resumen)**: el diagrama tiene una entidad externa (vecino), un proceso (aplicación web), un almacén (base de datos de expedientes) y dos **límites de confianza**: el que separa el navegador del servidor y el que separa la aplicación de la base de datos. Aplicando STRIDE: **S** → alguien se hace pasar por el vecino (contramedida: Cl@ve o certificado, sesión robusta); **T** → manipulación del identificador del expediente en la petición (validación de **autorización en el servidor** para cada consulta, no confiar en el identificador recibido); **R** → el vecino niega haber presentado una solicitud (registro con sello de tiempo y, en actos con efectos jurídicos, firma electrónica); **I** → un error de la aplicación devuelve la traza con la consulta SQL y la ruta del servidor (**mensajes de error genéricos** al usuario, detalle solo al registro); **D** → automatización que satura el buscador de expedientes (limitación de peticiones por IP y por sesión); **E** → un usuario ordinario alcanza la pantalla de administración porque el enlace no aparece en su menú pero la ruta no comprueba el rol (**comprobar el rol en el servidor en cada operación**, no ocultar en el cliente). Obsérvese que cuatro de las seis mitigaciones son **decisiones de diseño**, no configuraciones.

4.2. Principios y prácticas de codificación segura

4.2.1. Principios de diseño seguro y defensa en profundidad

Los **ocho principios de Saltzer y Schroeder** (1975) siguen siendo la base conceptual del diseño seguro `[SALTZER75]`:

Principio	Enunciado	Aplicación práctica
Mínimo privilegio	Cada elemento opera con los permisos estrictamente necesarios.	La aplicación se conecta a la base de datos con un usuario que solo puede ejecutar lo que necesita, no como propietario del esquema.
Economía de mecanismo	El diseño de seguridad debe ser **lo más simple posible**.	Un mecanismo simple es auditable; uno complejo esconde fallos.
Valores por defecto seguros (*fail-safe defaults*)	La decisión por defecto es **denegar**; el acceso se concede explícitamente.	Lista blanca de permisos, no lista negra de prohibiciones.
Mediación completa	**Cada** acceso a **cada** objeto se verifica, siempre.	No cachear una decisión de autorización tomada al iniciar sesión: comprobar en cada operación.
Diseño abierto	La seguridad **no** debe depender del secreto del diseño, sino del secreto de la **clave**.	Es el rechazo de la «seguridad por oscuridad»: los algoritmos criptográficos son públicos y auditados.
Separación de privilegios	Exigir **más de una condición** para conceder el acceso.	Doble factor; doble firma para operaciones críticas.
Mínimo mecanismo común	Compartir lo menos posible entre usuarios.	Aislamiento entre inquilinos, procesos y sesiones.
Aceptabilidad psicológica	El mecanismo debe ser **fácil de usar correctamente**.	Un control incómodo se elude; la vía segura debe ser también la vía cómoda.

DATO CLAVE

Diseño abierto (*open design*) es la formulación clásica del rechazo a la **seguridad por oscuridad**: la robustez debe residir en la **clave**, no en el desconocimiento del algoritmo o de la arquitectura por parte del atacante (formulación que se remonta al **principio de Kerckhoffs**). Ocultar la versión del servidor es una medida higiénica menor, **no** un control de seguridad `[SALTZER75]`.

A ellos se añaden principios modernos de uso corriente:

- **Defensa en profundidad**: múltiples capas independientes, de modo que el fallo de una no comprometa el conjunto. En la aplicación de cita previa: validación en el servidor **y** consultas parametrizadas **y** usuario de base de datos con permisos mínimos **y** cortafuegos de aplicación **y** registro y monitorización. Es el principio de **líneas de defensa** del ENS `[ENS]`.
- **Fallar de forma segura** (*fail securely*): si algo falla, el estado resultante debe ser el **denegado**. Un `try/catch` que ante una excepción de comprobación de permisos deje pasar la operación es el antipatrón exacto.
- **Reducción de la superficie de ataque**: cada función, puerto, servicio, parámetro o cuenta que no se necesita se elimina; lo que no existe no se puede atacar.
- **No confiar nunca en la entrada** (*trust boundary*): todo lo que cruza un límite de confianza es sospechoso, incluida la entrada procedente de otro sistema interno.
- **Separación de responsabilidades y de entornos**: desarrollo, preproducción y producción aislados, **sin datos reales en entornos no productivos** (o con datos anonimizados, exigencia derivada del RGPD).
- **Seguridad por defecto**: la configuración de fábrica es la más restrictiva; abrir requiere una decisión consciente.
- **Zero trust**: no hay red «interna de confianza»; cada petición se autentica y se autoriza con independencia de su origen.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicando **mediación completa** y **fallar de forma seguro** al portal de expedientes: no basta con que el menú del vecino solo muestre sus expedientes (eso es **ocultar en el cliente**, no autorizar). Cada petición al servidor debe comprobar que el expediente solicitado pertenece al usuario autenticado; y si el servicio de identidad no está disponible y no puede comprobarse el rol, la respuesta correcta es **denegar el acceso**, no conceder el mínimo «para no bloquear el servicio».

4.2.2. Validación y sanitización de entradas y salidas

Casi todas las vulnerabilidades clásicas de inyección tienen un mismo origen: **el sistema no distingue entre datos y código**. El usuario envía algo que se interpreta como instrucción —una consulta SQL, una etiqueta de guion, un mandato del sistema operativo, un fragmento de LDAP— en lugar de tratarse como texto inerte.

Reglas de validación de entrada `[OWASP-CHEAT]` `[OWASP-PROACTIVE]`:

1. **Validar siempre en el servidor.** La validación en el cliente es **usabilidad**, no seguridad: el atacante no usa el formulario, envía la petición directamente.

2. **Lista blanca** (*allow list*) antes que lista negra: aceptar solo lo que encaja con lo previsto —tipo, longitud, rango, formato, conjunto de valores admitidos— en lugar de intentar enumerar lo peligroso, enumeración que siempre queda incompleta.
3. **Canonicalizar antes de validar**: normalizar la codificación (UTF-8, `%2e%2e%2f`, dobles codificaciones, rutas relativas) **antes** de comprobar, o el atacante evadirá la comprobación con una representación alternativa del mismo valor.
4. **Validar tipo y dominio semántico**, no solo formato: que un identificador de expediente tenga la forma correcta no significa que **ese** usuario pueda verlo (eso es autorización, §4.2.3).
5. **Límites explícitos**: longitud máxima de cada campo, tamaño máximo de la petición y del fichero, número máximo de elementos de una lista. Previene desbordamientos y denegaciones de servicio.
6. **Ficheros subidos**: validar tipo real (no solo la extensión ni el `Content-Type` declarado), tamaño y contenido; **renombrar** con un nombre generado; almacenar **fuera de la raíz web**; nunca permitir su ejecución; analizarlos con antivirus.

La defensa correcta contra la inyección no es «sanear la entrada», es separar código y datos en el punto de uso. Cada tecnología tiene su mecanismo:

- **SQL → consultas parametrizadas** (sentencias preparadas). La consulta se compila con marcadores y los valores viajan aparte, sin poder alterar la estructura:

```
// VULNERABLE: concatenación — el valor puede cerrar la cadena y añadir SQL
String sql = "SELECT * FROM expedientes WHERE nif = '" + nif + "'";

// CORRECTO: sentencia preparada — el valor nunca se interpreta como código
String sql = "SELECT * FROM expedientes WHERE nif = ?";
try (PreparedStatement ps = conn.prepareStatement(sql)) {
    ps.setString(1, nif);
    ResultSet rs = ps.executeQuery();
}
```

```
# CORRECTO en Python (DB-API): parámetros, no formato de cadena
cur.execute("SELECT * FROM expedientes WHERE nif = %s", (nif,))
```

- **HTML/JavaScript → codificación contextual de la salida**: el mismo dato se codifica de forma distinta según dónde se inserte (cuerpo HTML, atributo, URL, dentro de un guion, hoja de estilo). Los marcos modernos escapan por defecto; el peligro está en las construcciones que

desactivan ese escapado (`innerHTML`, `dangerouslySetInnerHTML`, `v-html`, salidas «sin filtrar» de un motor de plantillas).

```
// VULNERABLE: inserta HTML interpretado (XSS si el comentario contiene <script>)
elemento.innerHTML = comentarioDelVecino;

// CORRECTO: inserta texto, nunca marcado
elemento.textContent = comentarioDelVecino;
```

- Si es imprescindible admitir HTML del usuario (un editor enriquecido), la única vía aceptable es una **biblioteca de saneamiento** consolidada que aplique lista blanca de etiquetas y atributos; **nunca** expresiones regulares propias.
- **Sistema operativo** → evitar la invocación de intérpretes de mandatos; si es inevitable, usar API que reciban el programa y sus argumentos **como lista**, nunca una cadena concatenada.
- **LDAP, XPath, NoSQL, plantillas del servidor** → API parametrizadas o escapado específico de cada lenguaje; el mismo razonamiento se aplica.
- **XML** → deshabilitar la resolución de **entidades externas** para evitar el ataque **XXE**, que permite leer ficheros del servidor o provocar peticiones internas.
- **Redirecciones y rutas** → no construir rutas de fichero ni URL de redirección con entrada del usuario sin validar contra una lista de valores permitidos (**recorrido de directorios** y **redirección abierta**).

> DATO CLAVE
>
> La frase que resume el epígrafe: **validar la entrada (lista blanca, en el servidor, tras canonicalizar) y codificar la salida según el contexto**. La inyección SQL se evita con **consultas parametrizadas**, no con el filtrado de comillas; el XSS se evita con **codificación contextual** y **CSP**, no con listas negras de la palabra «script» `[OWASP-CHEAT]`.

Los tres tipos de **XSS** que conviene distinguir: **almacenado** (la carga se guarda en el servidor —un comentario— y afecta a todos los que la ven; el más grave), **reflejado** (la carga viaja en la petición y se devuelve en la respuesta; requiere engañar a la víctima para que siga un enlace) y **basado en DOM** (nunca llega al servidor: el guion del cliente escribe en el documento un valor tomado de la URL o del almacenamiento local).

4.2.3. Gestión segura de sesiones, autenticación y autorización

3.2.3.1. Mecanismos de autenticación y control de acceso en aplicaciones

Autenticación en la aplicación. Los requisitos mínimos `[OWASP-ASVS]` `[NIST-800-63B]`:

- **Almacenamiento de credenciales**: nunca en claro ni cifradas de forma reversible. Función de derivación diseñada para contraseñas —**Argon2id**, **scrypt**, **bcrypt** o **PBKDF2**— con **sal única por usuario** y parámetros de coste ajustados al hardware actual.
- **Mensajes de error genéricos**: «usuario o contraseña incorrectos», nunca «ese usuario no existe», que permitiría **enumerar cuentas**. El mismo criterio se aplica a la recuperación de contraseña y al alta.
- **Tiempo de respuesta constante** en la comprobación, para no revelar por el retardo si el usuario existe.
- **Protección frente a fuerza bruta y relleno de credenciales**: limitación de intentos con retardo progresivo, bloqueo temporal, y desafío adicional ante patrones sospechosos (teniendo en cuenta el criterio **3.3.8 de WCAG 2.2**, que exige que la autenticación no imponga pruebas cognitivas sin alternativa accesible — §2.1).
- **MFA** para cuentas con privilegios y para operaciones sensibles; preferentemente resistente al *phishing* (**FIDO2/WebAuthn** `[WEBAUTHN]`).
- **Recuperación de contraseña segura**: token aleatorio de un solo uso, de vida corta, enviado por un canal verificado, que **no revela** si la cuenta existe y que **invalida las sesiones activas** al completarse el cambio.
- **Delegación de la identidad** cuando sea posible: en el sector público español, **Cl@ve**, certificado electrónico o DNIe, mediante **OpenID Connect** sobre **OAuth 2.0** `[RFC6749]`, evitando gestionar credenciales propias.

> DATO CLAVE
>
> No confundir los dos protocolos: **OAuth 2.0 es un marco de *autorización* delegada** (permite a una aplicación acceder a un recurso en nombre del usuario mediante un *token* de acceso), mientras que **OpenID Connect** es la **capa de autenticación** construida **sobre** OAuth 2.0 que añade el ***ID token*** con la identidad del usuario. Usar OAuth 2.0 «a secas» para autenticar es un error clásico de diseño `[RFC6749]`.

Para aplicaciones que se ejecutan en el navegador o en el móvil —**clientes públicos**, que no pueden guardar un secreto— el flujo correcto es el **código de autorización con PKCE** `[RFC7636]` `[RFC9700]`: el cliente genera un verificador aleatorio, envía su resumen en la petición inicial y presenta el verificador al canjear el código, de modo que un código interceptado resulta inservible.

Autorización en la aplicación. Es, según el propio OWASP, **el primer riesgo de las aplicaciones web** (A01:2021, *Broken Access Control*) `[OWASP-TOP10]`. Reglas:

1. **Denegar por defecto**: si no hay una regla que conceda el acceso, se deniega.
2. **Comprobar en el servidor y en cada operación** (**mediación completa**). Ocultar un botón, deshabilitar un campo o no incluir un enlace en el menú **no es autorización**.

3. **Autorización a nivel de objeto**, no solo de función: no basta con comprobar que el usuario tiene el rol «consulta de expedientes»; hay que comprobar que **ese expediente concreto** le corresponde. Su ausencia produce las **referencias directas a objetos inseguras** (IDOR), la vulnerabilidad más frecuente y más fácil de explotar: basta cambiar un número en la URL.
4. **Modelo centralizado y único**: un único componente de decisión reutilizado por toda la aplicación, no comprobaciones dispersas y divergentes en cada controlador.
5. **RBAC/ABAC** coherente con la organización, con revisión periódica de las asignaciones (§3.2.1).
6. **Registrar los fallos de autorización** y alertar ante patrones (un usuario que prueba cien identificadores consecutivos).
7. **Proteger también las API**: los servicios que consume el cliente son la superficie real de ataque, y deben aplicar exactamente las mismas comprobaciones que la interfaz.

> EJERCICIO RESUELTO
>
> *La consulta de expedientes usa la URL* `/expedientes/ver?id=48213`*. Un vecino cambia el número y ve el expediente de otra persona. Clasifique la vulnerabilidad y proponga la corrección.* **Solución**: es un **control de acceso roto** con **referencia directa a objeto insegura** (IDOR), categoría **A01:2021** de OWASP `[OWASP-TOP10]` y **elevación de privilegios** en STRIDE. La corrección **no** es ocultar el identificador ni cifrarlo (eso sería seguridad por oscuridad y no impide el ataque a otro identificador válido): la corrección es **comprobar en el servidor, en cada petición, que el expediente solicitado pertenece al usuario autenticado**, denegar en caso contrario con un mensaje genérico y **registrar** el intento. Como medida complementaria —no sustitutiva— pueden usarse identificadores no predecibles (UUID) para dificultar la enumeración masiva.

3.2.3.2. Manejo seguro de tokens y control de sesiones

HTTP no tiene estado: la **sesión** es el mecanismo que permite reconocer al mismo usuario entre peticiones. Como sustituye a la credencial, **el identificador de sesión vale exactamente lo mismo que la contraseña**, y quien lo roba entra sin autenticarse.

Sesiones basadas en cookie del servidor (modelo clásico y el más recomendable para aplicaciones web con navegador):

- Identificador **generado con un generador criptográficamente seguro**, de longitud suficiente e impredecible; **nunca** derivado del usuario ni secuencial.
- **Regenerar el identificador al autenticarse** y al cambiar de nivel de privilegio: es la defensa contra la **fijación de sesión** (*session fixation*), en la que el atacante impone a la víctima un identificador que él ya conoce.
- **Nunca en la URL** (quedaría en el historial, en los registros del servidor y en la cabecera `Referer`).

- Atributos obligatorios de la cookie:

```
Set-Cookie: SESSIONID=<valor-aleatorio>; Path=/; HttpOnly; Secure; SameSite=Lax
```

Atributo	Efecto
`HttpOnly`	El guion del cliente no puede leer la cookie: limita el robo de sesión mediante **XSS**.
`Secure`	La cookie solo viaja por HTTPS.
`SameSite` (`Lax` o `Strict`)	La cookie no se envía en peticiones de origen cruzado: mitiga el **CSRF**.
`Path` y `Domain`	Restringen el alcance al mínimo necesario.

- **Caducidad**: **por inactividad** (con aviso previo y posibilidad de prórroga, para cumplir el criterio 2.2.1 de WCAG) y **absoluta**.
- **Cierre de sesión real**: el `logout` debe **invalidar la sesión en el servidor**, no limitarse a borrar la cookie en el cliente.
- **CSRF**: además de `SameSite` , **token antifalsificación** por sesión o por formulario en toda operación que modifique estado, y uso correcto de los métodos HTTP (una operación que cambia datos nunca debe ser `GET`).

Sesiones basadas en *token* (JWT). El **JSON Web Token** `[RFC7519]` es un *token* **autocontenido**: lleva los datos (*claims*) y una firma, de modo que el servidor puede validarlo sin consultar un almacén de sesiones. Esa misma virtud es su riesgo: **no se puede revocar por sí solo**.

Requisitos de uso seguro `[RFC8725]` :

- **Rechazar el algoritmo** `none` y **no aceptar el algoritmo indicado por el propio token**: el servidor fija de antemano el algoritmo y la clave admitidos. Aceptar `alg: none` fue una vulnerabilidad masiva en las primeras bibliotecas.
- **Validar siempre** firma, **emisor** (`iss`), **audiencia** (`aud`) y **caducidad** (`exp`), con margen de reloj mínimo.
- **Vida corta** para el *token* de acceso (minutos) y **token de refresco** de vida más larga, **almacenado y revocable en el servidor**, con rotación y detección de reutilización.
- **No incluir datos personales ni secretos** en el cuerpo: el JWT va **firmado, no cifrado**, y su contenido es legible por cualquiera que lo posea (salvo que se use JWE).

- **Lista de revocación** o identificador de sesión asociado cuando se necesite cerrar sesión de forma efectiva (cambio de contraseña, baja del empleado).
- **Almacenamiento en el cliente**: guardar el *token* en `localStorage` lo expone a cualquier **XSS**; la alternativa preferible en aplicaciones web es una **cookie** `HttpOnly` + `Secure` + `SameSite`, complementada con protección CSRF.

> DATO CLAVE
>
> Diferencia entre los dos modelos: la **sesión en servidor** es **revocable de inmediato** (basta borrarla del almacén) pero exige estado compartido; el **JWT** es **sin estado y escalable** pero **no revocable** hasta su caducidad, por lo que exige vidas cortas y un mecanismo adicional de revocación. Y en ambos casos: **el identificador de sesión o el *token* equivalen a la credencial** `[RFC7519]` `[RFC8725]`.

4.2.4. Registro de auditoría y tratamiento de excepciones

Registro de auditoría (*logging*). Su función es triple: **detectar** un incidente, **investigarlo** después y sostener el **no repudio** de las actuaciones. Sin registro no hay respuesta posible: la organización se entera del ataque por terceros y no puede determinar su alcance. Es, por eso, la categoría **A09:2021 «Fallos de registro y monitorización»** del OWASP Top 10 `[OWASP-TOP10]` y un requisito expreso del ENS `[ENS]`.

Qué registrar `[OWASP-CHEAT]`: intentos de autenticación **con éxito y fallidos**; cambios de contraseña, de perfil y de permisos; **fallos de autorización**; operaciones sobre datos sensibles (consulta, modificación, exportación, borrado); cambios de configuración; uso de funciones administrativas; errores del sistema y excepciones no controladas; inicio y parada de los servicios y de los propios registros.

Qué debe contener cada asiento: **cuándo** (marca de tiempo con zona horaria, con relojes **sincronizados** por NTP entre sistemas), **quién** (identificador de usuario, nunca la contraseña), **desde dónde** (dirección de origen, dispositivo), **qué** (acción y recurso afectado), **con qué resultado** (éxito o fallo y motivo) y un identificador de correlación que permita seguir una operación a través de varios sistemas.

Qué NO debe registrarse jamás: contraseñas, identificadores de sesión y *tokens*, claves criptográficas, datos de tarjetas de pago, contenido íntegro de documentos con categorías especiales de datos, ni volcados con información personal innecesaria. El registro es un fichero que se copia, se consulta y se conserva: **un registro indiscreto es una brecha de datos esperando ocurrir**, y el propio RGPD obliga a aplicarle los principios de minimización y limitación del plazo de conservación `[RGPD]`.

Cómo protegerlo: escritura en un sistema **centralizado y separado** (SIEM) al que la aplicación solo pueda **añadir**; protección de **integridad** (solo anexar, firma o sellado); control de acceso

propio; **retención** definida conforme a la normativa; y **alertas** sobre patrones relevantes, porque un registro que nadie mira no detecta nada. La monitorización debe generar avisos ante ráfagas de fallos de autenticación, fallos de autorización repetidos, exportaciones masivas o uso de funciones administrativas fuera de horario.

> DATO CLAVE
>
> El error más habitual del registro no es registrar poco: es **registrar lo que no se debe** (credenciales, *tokens*, datos personales excesivos) y **no vigilar lo que sí se registra**. Registro **completo pero minimizado**, **protegido frente a manipulación**, con relojes sincronizados y **con alertas activas**: esas son las cuatro condiciones `[OWASP-TOP10]` `[ENS]`.

Tratamiento de excepciones y errores. El principio rector es **fallar de forma segura y callada hacia fuera, ruidosa hacia dentro**:

- Ante un error inesperado, el sistema debe quedar en el estado **denegado**, nunca conceder acceso ni continuar con datos inconsistentes.
- Al usuario se le devuelve un **mensaje genérico** («No se ha podido completar la operación. Código de referencia: `A7F2-31`»), en lenguaje claro y accesible (§2.1, criterio 3.3.1); el **detalle técnico** —traza, consulta, versión, ruta— va **solo al registro**, correlacionado por ese código.
- Deben **desactivarse en producción** los modos de depuración, las páginas de error detalladas de los marcos de trabajo y los listados de directorio. Su presencia es una **revelación de información** (STRIDE: *Information disclosure*) que da al atacante el mapa del sistema.
- **No capturar excepciones de forma genérica y silenciosa**: un `catch` vacío oculta precisamente el fallo de seguridad que interesa detectar.
- **Liberar recursos** de forma garantizada y no dejar transacciones a medias; la excepción debe dejar el sistema en un estado coherente.

```
// ANTIPATRÓN: se filtra el detalle interno al usuario y se pierde la traza
catch (SQLException e) {
    response.getWriter().println("Error: " + e.getMessage());
}

// CORRECTO: mensaje genérico al usuario, detalle correlacionado al registro
catch (SQLException e) {
    String ref = UUID.randomUUID().toString().substring(0, 8);
    log.error("[{}] Error consultando expediente {}", ref, expedienteId, e);
    mostrarError("No se ha podido completar la operación. Referencia: " + ref);
}
```

EJEMPLO DE APLICACIÓN EN EL AYTO

En el buscador de expedientes, una consulta con un carácter inesperado devolvía una página con la traza completa de la excepción: nombre del servidor, versión del gestor de base de datos, ruta física de la aplicación y la sentencia SQL con el nombre de las tablas. Ningún dato personal se había filtrado, pero el atacante ya tenía **el mapa de la aplicación y la confirmación de que la consulta se construye por concatenación**. La corrección es doble: página de error genérica con código de referencia y detalle solo en el registro, **y** eliminar la concatenación (§4.2.2).

4.3. Vulnerabilidades y verificación de la seguridad

4.3.1. Vulnerabilidades en el desarrollo de software y catálogo OWASP

Conviene fijar primero el vocabulario:

Término	Significado
Debilidad (*weakness*)	**Tipo** de defecto que puede dar lugar a vulnerabilidades. Se cataloga en **CWE** (p. ej. **CWE-89** inyección SQL, **CWE-79** XSS, **CWE-787** escritura fuera de límites) `[CWE]`.
Vulnerabilidad	**Instancia concreta** de una debilidad en un producto y versión concretos. Se identifica con un **CVE** (p. ej. `CVE-AAAA-NNNNN`) y se publica en la **NVD** `[CVE]`.
Exploit	Código o técnica que **aprovecha** una vulnerabilidad.
Amenaza	Suceso potencial que puede causar daño (categorizable con **STRIDE**).
Riesgo	Combinación de **probabilidad** e **impacto** de que una amenaza aproveche una vulnerabilidad.
Día cero (*zero-day*)	Vulnerabilidad para la que **no existe todavía corrección** del fabricante cuando empieza a explotarse.
Severidad	Puntuación normalizada de la gravedad: **CVSS**, de 0,0 a 10,0 `[CVSS]`.

DATO CLAVE

CWE cataloga debilidades (tipos), CVE identifica vulnerabilidades (casos concretos) y CVSS puntúa su severidad. El **CWE Top 25** ordena los tipos de defecto más peligrosos; el **OWASP Top 10** ordena **categorías de riesgo** en aplicaciones web. Son listas de naturaleza distinta y no intercambiables `[CWE]` `[OWASP-TOP10]`.

OWASP Top 10:2021 — el documento de concienciación más citado del sector; ordena las **categorías de riesgo** más críticas en aplicaciones web `[OWASP-TOP10]`:

Código	Categoría	Contenido y ejemplo típico
A01	**Pérdida de control de acceso**	Autorización que falla: **IDOR**, elevación de privilegios, acceso a funciones administrativas por URL directa. Es la **primera** de la lista.
A02	**Fallos criptográficos**	Datos sensibles sin cifrar en tránsito o en reposo, algoritmos obsoletos, contraseñas con resumen rápido y sin sal, claves embebidas en el código.
A03	**Inyección**	SQL, NoSQL, LDAP, mandatos del sistema, plantillas del servidor y **XSS** (que en 2021 se integró en esta categoría).
A04	**Diseño inseguro**	Categoría **nueva en 2021**: el fallo está en el **diseño**, no en la implementación; se combate con **modelado de amenazas** y patrones seguros, no con parches.
A05	**Configuración de seguridad defectuosa**	Credenciales por defecto, servicios y puertos innecesarios, permisos excesivos, mensajes de error detallados, cabeceras de seguridad ausentes, componentes de ejemplo instalados.
A06	**Componentes vulnerables y desactualizados**	Bibliotecas y marcos con vulnerabilidades conocidas y sin actualizar; falta de inventario de dependencias.
A07	**Fallos de identificación y autenticación**	Contraseñas débiles permitidas, sin protección frente a fuerza bruta, gestión de sesión deficiente, recuperación de contraseña insegura, ausencia de MFA.
A08	**Fallos de integridad del software y de los datos**	Categoría **nueva en 2021**: actualizaciones y dependencias sin verificar su origen, **deserialización insegura**, canalizaciones de integración comprometidas (**cadena de suministro**).
A09	**Fallos de registro y monitorización**	Eventos de seguridad no registrados, sin alertas, sin correlación; el ataque pasa inadvertido durante meses.
A10	**Falsificación de peticiones del lado del servidor (SSRF)**	Categoría **nueva en 2021**: el servidor realiza peticiones a una URL controlada por el atacante y alcanza servicios internos no expuestos.

DATO CLAVE

Cuatro datos de la edición **2021**: **A01 es el control de acceso roto** (subió al primer puesto); el **XSS quedó integrado dentro de A03 Inyección**; se incorporaron tres categorías nuevas, **A04 Diseño inseguro**, **A08 Fallos de integridad** y **A10 SSRF**; y el Top 10 es un documento de **concienciación**, no una norma de certificación: para verificar formalmente una aplicación se usa **ASVS** `[OWASP-TOP10]` `[OWASP-ASVS]`.

Otros catálogos de OWASP que conviene identificar por su ámbito: **API Security Top 10** (riesgos propios de las API, donde predominan los fallos de autorización a nivel de objeto y de propiedad), **Mobile Top 10** (aplicaciones móviles, §Tema 24), **Top 10 Proactive Controls** `[OWASP-PROACTIVE]` —la versión «en positivo»: qué hacer, no qué evitar— y las **Cheat Sheets** `[OWASP-CHEAT]`, guías concretas por materia. **CAPEC** `[CAPEC]` cataloga los **patrones de ataque** y **MITRE ATT&CK** `[ATTACK]` las tácticas y técnicas observadas en incidentes reales.

4.3.2. Análisis de seguridad mediante técnicas estáticas y dinámicas

Ninguna técnica encuentra todo. La verificación seria **combina** varias, cada una con su momento del ciclo, su alcance y su punto ciego.

Técnica	Cómo funciona	Momento	Encuentra bien	Punto ciego
SAST (*estático*)	Analiza el **código fuente** o el binario **sin ejecutarlo**, buscando patrones y siguiendo el flujo de datos desde las fuentes de entrada hasta los puntos peligrosos (*taint analysis*).	Desde la primera línea; en cada confirmación.	Inyecciones, criptografía mal usada, secretos embebidos, entrada sin validar.	**No ve el entorno ni la configuración**; genera **muchos falsos positivos**; no detecta fallos de lógica de negocio ni de autorización.
DAST (*dinámico*)	Ataca la **aplicación en ejecución** desde fuera, sin conocer el código (caja negra).	Preproducción, con la aplicación desplegada.	Configuración, cabeceras, gestión de sesión, comportamiento real, errores expuestos.	No ve el código; **cobertura limitada** a lo que consigue recorrer; tardío en el ciclo; puede alterar datos.
IAST (*interactivo*)	**Instrumenta** la aplicación con un agente y observa desde dentro mientras se ejecutan las pruebas funcionales.	Integración y pruebas.	Combina precisión de SAST con realidad de DAST; **pocos falsos positivos**.	Requiere instrumentación y una buena batería de pruebas funcionales que ejercite el código.
SCA (*composición*)	Inventaría las **dependencias de terceros** y las contrasta con las bases de vulnerabilidades.	Continuo.	Componentes vulnerables (**A06**), licencias incompatibles.	No analiza el código propio.
Fuzzing	Envía entradas masivas, aleatorias o malformadas buscando	Pruebas.	Fallos de robustez, desbordamientos, caídas, casos no contemplados.	Necesita mucho tiempo de ejecución y detección

Técnica	Cómo funciona	Momento	Encuentra bien	Punto ciego
	comportamientos anómalos.			automática del fallo.
Revisión manual de código	Lectura experta guiada por lista de comprobación.	Continuo (revisión entre pares).	**Lógica de negocio y autorización**, lo que ninguna herramienta entiende.	Cara, no escalable, depende de la persona.
Prueba de penetración	Ejercicio manual de explotación por un equipo especializado, con alcance y reglas acordadas.	Antes de producción y periódicamente.	Encadenamiento de fallos, impacto real demostrado.	Es una **foto del momento**; no sustituye a los controles continuos.
RASP	Protección en tiempo de ejecución integrada en la aplicación, que detecta y bloquea el ataque en curso.	Producción.	Mitigación mientras se corrige.	Es un paliativo, no una corrección.

DATO CLAVE

Las tres diferencias: **SAST** analiza el código **sin ejecutarlo** (caja blanca, temprano, muchos falsos positivos); **DAST** ataca la aplicación **en ejecución** sin ver el código (caja negra, tardío, pocos falsos positivos pero cobertura parcial); **SCA** analiza las **dependencias de terceros**. Y la advertencia asociada: **ninguna herramienta automática detecta fallos de lógica de negocio ni de autorización**; para eso hacen falta revisión manual y pruebas de penetración `[OWASP-ASVS]`.

Gestión de las vulnerabilidades encontradas: registrar, **priorizar** por riesgo real —CVSS `[CVSS]` **más** exposición del activo y existencia de explotación activa, no CVSS a secas—, asignar responsable y plazo por severidad, corregir, **verificar la corrección** y analizar la causa raíz para que no reaparezca. Y una vía de **divulgación responsable** publicada (fichero `security.txt`, buzón de contacto) para que quien encuentre un fallo desde fuera pueda comunicarlo sin exponerlo.

4.3.3. Bastionado de aplicaciones y gestión de dependencias

Bastionado (*hardening*) es reducir la superficie de ataque de la aplicación y de su entorno de ejecución hasta el mínimo funcionalmente necesario. Actúa sobre la categoría **A05** del Top 10 `[OWASP-TOP10]` y se apoya, en el sector público español, en las guías **CCN-STIC** de configuración segura `[CCN-STIC]`.

Medidas de bastionado de la aplicación:

1. **Eliminar lo innecesario**: módulos, servicios, puertos, cuentas de ejemplo, aplicaciones de demostración, documentación instalada, herramientas de administración accesibles desde Internet.
2. **Cambiar todas las credenciales por defecto** y eliminar cuentas genéricas.
3. **Desactivar depuración y trazas detalladas** en producción; desactivar el listado de directorios; ocultar versiones en las cabeceras.
4. **Cabeceras de seguridad HTTP**:

```
Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'none'
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(), camera=(), microphone=()
```

Cabecera	Función
`Content-Security-Policy`	Declara de qué orígenes puede cargarse cada tipo de recurso; es la mitigación estructural del **XSS** y, con `frame-ancestors`, del *clickjacking*.
`Strict-Transport-Security`	Obliga al navegador a usar HTTPS durante el periodo indicado `[RFC6797]`.
`X-Content-Type-Options: nosniff`	Impide que el navegador adivine el tipo de contenido e interprete como guion algo que no lo es.
`Referrer-Policy`	Evita filtrar en la cabecera `Referer` rutas internas o identificadores.
`Permissions-Policy`	Desactiva capacidades del navegador (cámara, micrófono, ubicación) que la aplicación no necesita.

1. **Configuración de CORS restrictiva**: orígenes explícitos, nunca el comodín junto con credenciales.
2. **Cifrado obligatorio** con configuración TLS moderna y renovación automatizada de certificados.

3. **Ejecución con el mínimo privilegio**: el proceso de la aplicación no corre como administrador ni como propietario del esquema de base de datos; contenedores sin usuario privilegiado, con sistema de ficheros de solo lectura donde sea posible.
4. **Gestión de secretos**: **jamás** en el repositorio de código ni en ficheros de configuración versionados. Almacén de secretos (bóveda) o variables inyectadas en el despliegue, con **rotación** y auditoría. Un secreto que ha estado en un repositorio se considera comprometido aunque se borre después: el historial lo conserva.
5. **Cortafuegos de aplicación (WAF)** y limitación de peticiones como capa adicional —**nunca** como sustituto de la corrección del código.
6. **Segregación de entornos** y ausencia de datos reales en desarrollo y pruebas.

Gestión de dependencias. El software moderno es en su mayor parte **código de terceros**: una aplicación web típica arrastra centenares de bibliotecas transitivas. De ahí las categorías **A06** (componentes vulnerables) y **A08** (integridad y cadena de suministro) del Top 10 `[OWASP-TOP10]`.

- **Inventario**: mantener un **SBOM** (*Software Bill of Materials*) en formato normalizado —**SPDX** o **CycloneDX** `[SBOM]` —, que permite responder en horas, y no en semanas, a la pregunta «¿nos afecta la vulnerabilidad publicada esta mañana?».
- **Análisis continuo (SCA)** contra las bases de vulnerabilidades, integrado en la canalización de construcción.
- **Fijar versiones** (ficheros de bloqueo) y **verificar la integridad** de los artefactos descargados mediante resumen o firma; usar un **repositorio interno** que actúe de intermediario y filtre.
- **Política de actualización**: distinguir la actualización **de seguridad** (urgente, priorizada por severidad y explotación) de la **evolutiva**; conocer el **versionado semántico** `[SEMVER]` para anticipar los cambios incompatibles.
- **Criterios de selección** de una dependencia nueva: mantenimiento activo, comunidad, historial de vulnerabilidades, licencia compatible y necesidad real —muchas dependencias se incorporan para resolver un problema trivial y multiplican la superficie de ataque.
- **Riesgos específicos de la cadena de suministro**: *typosquatting* (paquete con nombre casi idéntico al legítimo), **confusión de dependencias** (un paquete público suplanta a uno interno con el mismo nombre), compromiso de la cuenta del mantenedor y manipulación de la canalización de construcción. Se mitigan con repositorio interno, verificación de firmas, revisión de las nuevas dependencias y protección de las credenciales de la canalización.
- **Fin de vida**: una dependencia sin mantenimiento es una vulnerabilidad futura garantizada; debe planificarse su sustitución antes de que aparezca el fallo.

EJEMPLO DE APLICACIÓN EN EL AYTO

Se publica una vulnerabilidad crítica en una biblioteca de registro muy extendida. Con **SBOM** y **SCA** implantados, el equipo determina en una mañana que la aplicación de cita previa la incorpora de forma **transitiva** en su versión vulnerable, valora el riesgo (**CVSS** crítico, servicio expuesto a Internet), aplica la actualización en un despliegue de emergencia, **verifica** la corrección con un análisis dirigido y revisa los registros por si hubiera habido explotación previa. Sin inventario de dependencias, el mismo diagnóstico habría exigido revisar manualmente cada proyecto, y la ventana de exposición se habría medido en semanas.

RELACIÓN CON OTROS TEMAS

Los riesgos y controles de seguridad **web** (OWASP Top 10 aplicado al desarrollo web, XSS, CSRF, cabeceras) se desarrollan también en el **Tema 23**; la seguridad de las aplicaciones **móviles** (OWASP Mobile, permisos, almacenamiento) en el **Tema 24**; las **arquitecturas cliente/servidor y de servicios web**, que definen dónde se aplican estos controles, en el **Tema 22**; los fundamentos de **criptografía y firma digital** en el **Tema 32**; y el **ENS y el ENI** en el **Tema 39**. El **Tema 20** aporta los patrones de diseño y el **Tema 18** los fundamentos de programación sobre los que se apoya la codificación segura.

Cierre: las cuatro materias como un solo criterio de calidad

El tema reúne tres materias que las convocatorias presentan juntas por una razón de fondo. Un servicio público electrónico solo está bien construido cuando cumple simultáneamente tres condiciones, y las tres son **obligaciones jurídicas** además de buenas prácticas técnicas:

Condición	Pregunta que responde	Norma que la impone
Accesible y usable	¿Puede usarlo **cualquier persona**, con autonomía?	RD 1112/2018 y UNE-EN 301 549 (nivel **AA** de WCAG) `[RD1112-2018]` `[EN301549]`
Protegido en el puesto	¿La información está **a salvo y disponible** allí donde se trabaja con ella?	ENS (RD 311/2022) y RGPD art. 32 `[ENS]` `[RGPD]`
Desarrollado con seguridad	¿Se **construyó** pensando en el atacante desde el diseño?	RGPD art. 25 (desde el diseño y por defecto) y ENS `[RGPD]` `[ENS]`

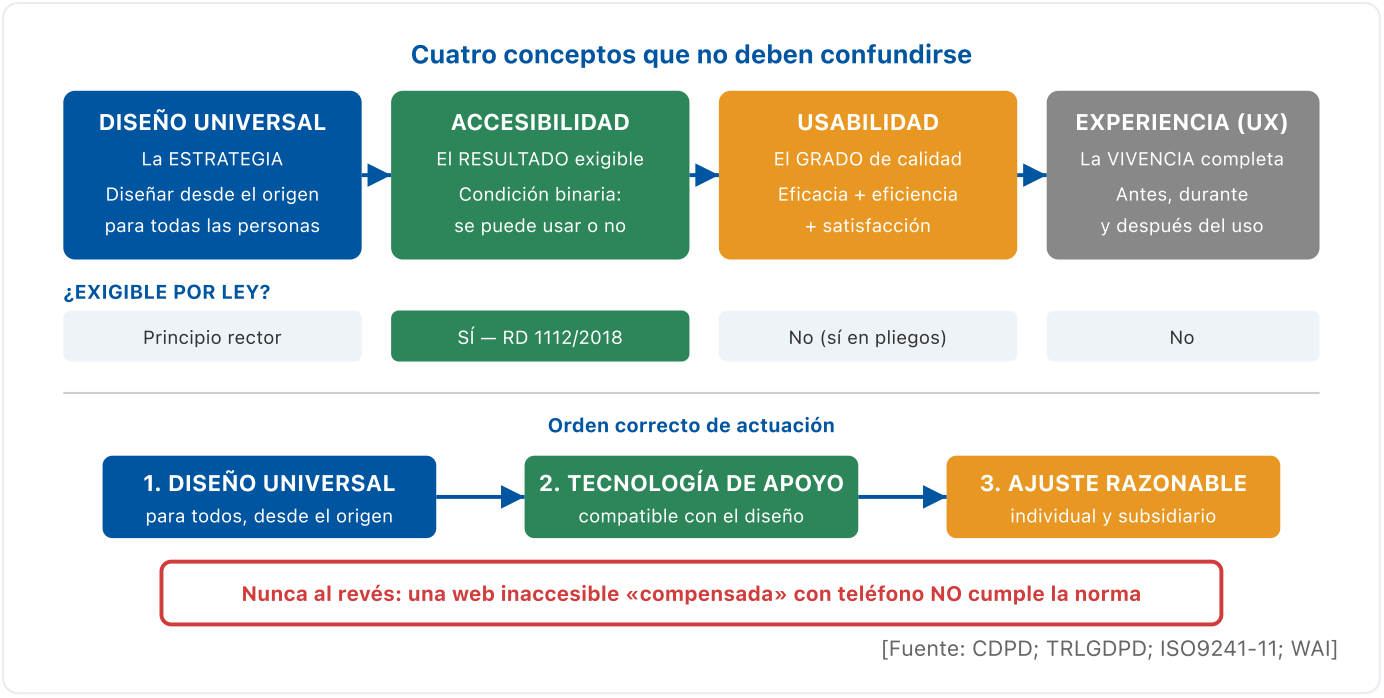
Las tres comparten además una misma lección práctica: **ninguna de ellas se resuelve al final**. La accesibilidad no se «añade» a una web terminada; la seguridad del puesto no se sustituye por un antivirus instalado el último día; y la seguridad del software no se parchea desde fuera cuando el fallo está en el diseño. Las tres son **decisiones tomadas al principio** y sostenidas durante todo el ciclo de vida.

Índice de diagramas

ID	Título	Sección	Tipo
D1	Accesibilidad, usabilidad, UX y diseño universal: cómo se relacionan	§1	Esquema conceptual
D2	Los siete principios del diseño universal	§1.2	Bloques
D3	ISO 9241 e ISO/IEC 25010: qué mide cada norma	§1.3	Comparativa
D4	Los cuatro principios POUR y la estructura normativa de WCAG	§2.1	Jerarquía
D5	Niveles de conformidad y evolución de WCAG	§2.1	Escalera + línea temporal
D6	La cadena normativa de la accesibilidad: de la ONU al RD 1112/2018	§2.3	Flujo normativo
D7	Evaluación, declaración y reclamación de accesibilidad	§2.4	Flujo
D8	Amenazas y controles en el puesto de usuario final	§3.1	Matriz
D9	Control de acceso: cuatro pasos y tres factores	§3.2.1	Flujo + bloques
D10	Cifrado en reposo y en tránsito en el puesto	§3.2.2	Esquema
D11	Copias de seguridad: tipos, regla 3-2-1 y RPO/RTO	§3.3.2	Esquema temporal
D12	El ciclo de vida de desarrollo seguro (SSDLC)	§4.1.1	Flujo por fases
D13	STRIDE: seis amenazas y la propiedad que niega cada una	§4.1.2	Tabla visual
D14	OWASP Top 10:2021 y técnicas de verificación	§4.3	Bloques + comparativa

D1 · Accesibilidad, usabilidad, UX y diseño universal: cómo se relacionan

Sección: §1 — Usabilidad y diseño universal **Propósito**: Fijar de un vistazo la diferencia entre los cuatro conceptos que el tema exige no confundir, y su encadenamiento lógico.



[Fuente: CDPD; TRLGDPD; ISO9241-11; WAI]

D2 · Los siete principios del diseño universal

Sección: §1.2 — Fundamentos del diseño universal y diseño para todos **Propósito**: Memorizar los siete principios de 1997 con su traducción directa al software.

Los 7 principios del diseño universal (CUD, 1997)

1 · USO EQUITATIVO
Útil para todos, sin segregar
→ un solo sitio, no versión aparte

2 · FLEXIBILIDAD DE USO
Se adapta a preferencias
→ ratón, teclado, voz, táctil

3 · SIMPLE E INTUITIVO
Fácil sin experiencia previa
→ lenguaje claro, sin jerga

4 · INFORMACIÓN PERCEPTIBLE
Llega sea cual sea el sentido
→ nunca solo color; subtítulos

5 · TOLERANCIA AL ERROR
Minimiza riesgo y consecuencia
→ confirmar, deshacer, conservar

6 · ESCASO ESFUERZO FÍSICO
Uso cómodo y sin fatiga
→ sin gestos complejos

7 · TAMAÑO Y ESPACIO ADECUADOS PARA EL ACCESO Y EL USO
→ diseño adaptable, sin desplazamiento horizontal, zonas de pulsación suficientes

EL VOCABULARIO ESPAÑOL EQUIVALENTE (RDL 1/2013)

Accesibilidad universal = la condición del resultado	Diseño para todas las personas = la actividad de diseñar	Ajustes razonables = medida individual

[Fuente: CUD; TRLGDPD; CDPD]

D3 · ISO 9241 e ISO/IEC 25010: qué mide cada norma

Sección: §1.3 — Modelos de calidad e ISO/IEC 9241 e ISO/IEC 25010 **Propósito**: Separar las dos familias de normas y localizar exactamente dónde encajan accesibilidad, disponibilidad y confidencialidad dentro del modelo de calidad del producto.

Dos familias de normas, dos objetos distintos

ISO 9241 — ergonomía: mide PROCESO e INTERACCIÓN	ISO/IEC 25000 (SQuaRE) — mide el PRODUCTO
9241-11 · Usabilidad: eficacia + eficiencia + satisfacción	2501n · Modelos de calidad → ISO/IEC 25010
9241-110 · Los 7 principios de interacción	2502n medición · 2503n requisitos · 2504n evaluación
9241-171 · Guía de accesibilidad del software	Tres modelos: calidad del PRODUCTO (25010), calidad EN USO (25019) y de los DATOS (25012)
9241-210 · Diseño centrado en las personas (iterativo)	25040 · proceso de evaluación

Las 9 características de ISO/IEC 25010:2023 y dónde está cada pieza de este tema

Adecuación func. · Eficiencia desemp. · Compatibilidad
Mantenibilidad · Flexibilidad · Protección (safety)

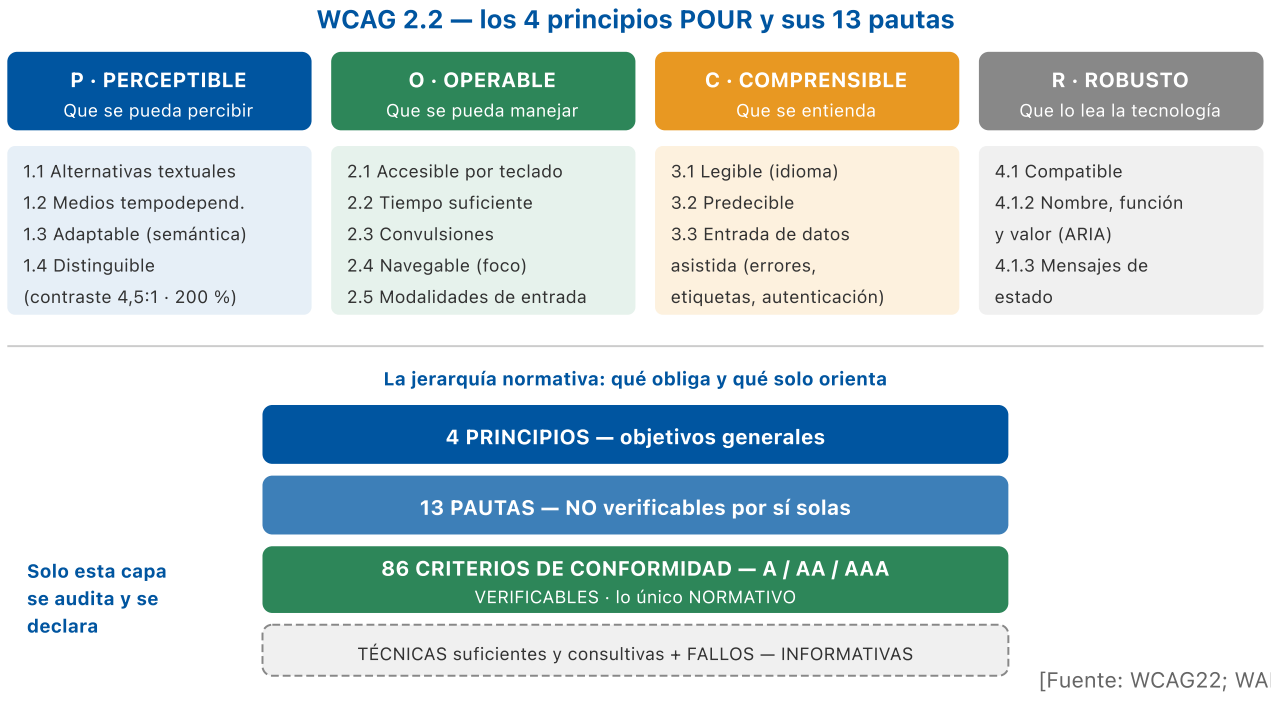
CAPACIDAD DE INTERACCIÓN → INCLUSIVIDAD (subcaracterística)
FIABILIDAD → DISPONIBILIDAD (subcaracterística)
SEGURIDAD → Confidencialidad e integridad

Las tres piezas que dan título a este tema están en 3 lugares distintos
Accesibilidad: en 2023 la cubren inclusividad y asistencia al usuario

[Fuente: ISO9241-11; ISO9241-210; ISO25000; ISO25010]

D4 · Los cuatro principios POUR y la estructura normativa de WCAG

Sección: §2.1 — Pautas de accesibilidad al contenido web WCAG **Propósito**: Fijar la jerarquía principio → pauta → criterio → técnica, y qué parte de ella es normativa.



[Fuente: WCAG22; WAI]

D5 · Niveles de conformidad y evolución de WCAG

Sección: §2.1 — Pautas de accesibilidad al contenido web WCAG **Propósito**: Fijar el carácter acumulativo de los niveles, el nivel legalmente exigible y las fechas y aportaciones de cada versión.

Niveles de conformidad: acumulativos, no alternativos

NIVEL A
31 criterios · mínimo

NIVEL AA
= todos los A + 24 criterios AA
EXIGIDO POR LEY (sector público)

NIVEL AAA
= A + AA + 31 criterios AAA
El W3C NO recomienda
exigirlo para sitios completos

Total WCAG 2.2: 86 criterios de conformidad (31 A + 24 AA + 31 AAA)

Evolución de las versiones

1999	dic 2008	jun 2018	5 oct 2023
WCAG 1.0 14 pautas	WCAG 2.0 · 61 criterios = ISO/IEC 40500:2012	WCAG 2.1 · 78 criterios móvil, baja visión, cognitiva	WCAG 2.2 · 86 criterios +9 nuevos · retira 4.1.1

Conformidad de PÁGINAS COMPLETAS y de PROCESOS COMPLETOS

[Fuente: WCAG20; WCAG21; WCAG22]

D6 · La cadena normativa de la accesibilidad: de la ONU al RD 1112/2018

Sección: §2.3 — Marco normativo en la Administración Pública **Propósito**: Ordenar los cinco eslabones normativos y el contenido esencial del real decreto que obliga a un ayuntamiento.

De la Convención de la ONU al deber de un ayuntamiento

2006 · ONU
Convención CDPD
art. 2 diseño universal
art. 9 acceso a las TIC

→

2013 · ESPAÑA
RDL 1/2013
accesibilidad universal,
diseño para todos

→

2016 · UE
Directiva 2016/2102
webs y apps del
SECTOR PÚBLICO

→

2018 · ESPAÑA
RD 1112/2018
transposición
→ nivel AA

→

2019/2023
Dir. 2019/882 (EAA)
Ley 11/2023
→ sector PRIVADO

Qué obliga exactamente el RD 1112/2018 a una entidad local

REQUISITO TÉCNICO
UNE-EN 301 549 → WCAG nivel AA

ÁMBITO
webs, intranets, extranets y apps

UNIDAD RESPONSABLE
obligatoria en cada organismo

DECLARACIÓN
modelo Decisión (UE) 2018/1523

QUEJA Y RECLAMACIÓN
mecanismo accesible y con plazo

SEGUIMIENTO E INFORME
Decisión (UE) 2018/1524

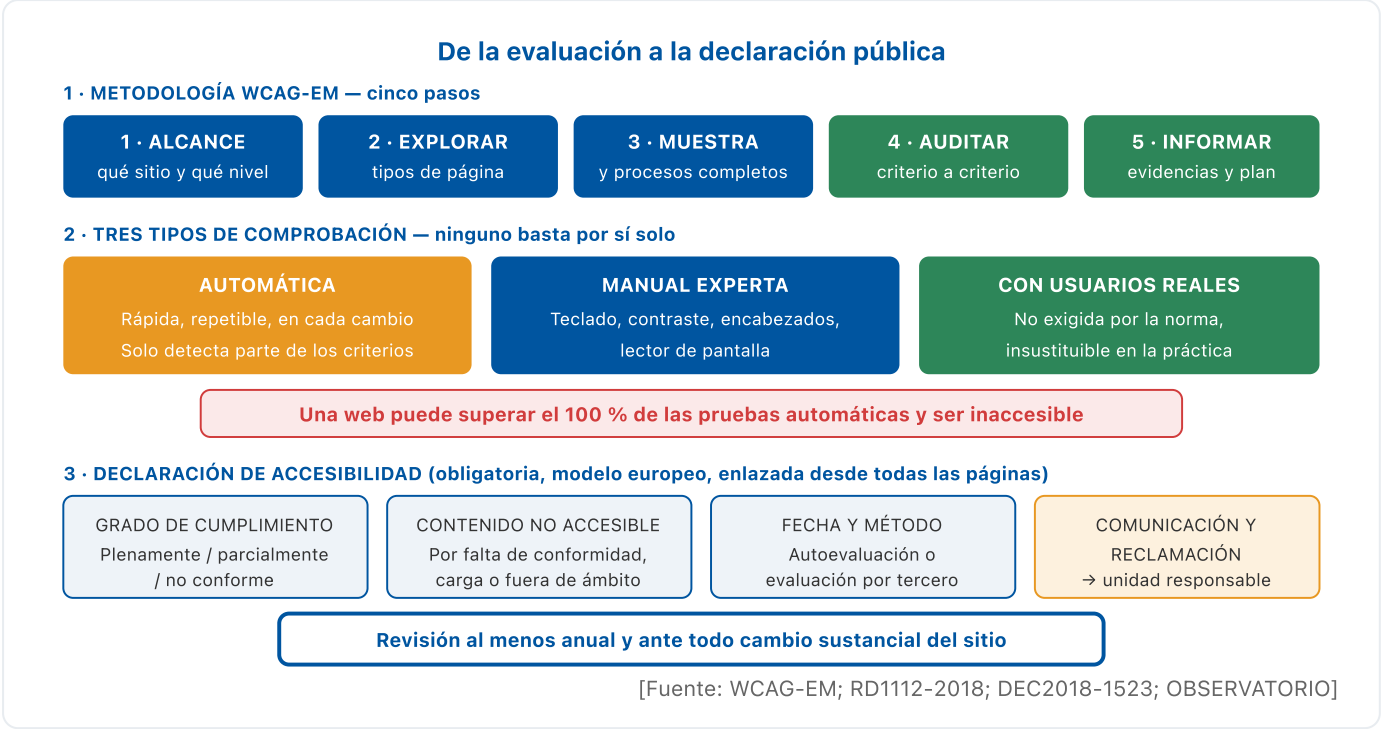
CARGA DESPROPORCIONADA (art. 7)
Motivada, declarada y con alternativa accesible
NUNCA por falta de prioridad, tiempo o conocimiento

PLAZOS (ya vencidos: exigencia plena)
Webs nuevas 23-sep-2019 · anteriores 23-sep-2020
Aplicaciones móviles: 23-jun-2021

[Fuente: CDPD; TRLGDPD; DIR2016-2102; RD1112-2018; LEY11-2023]
Norma técnica de referencia: EN301549

D7 · Evaluación, declaración y reclamación de accesibilidad

Sección: §2.4 — Evaluación, auditoría y declaración de accesibilidad **Propósito**: Encadenar los cinco pasos de WCAG-EM, los tres tipos de comprobación con su alcance real y el contenido obligatorio de la declaración.



[Fuente: WCAG-EM; RD1112-2018; DEC2018-1523; OBSERVATORIO]

D8 · Amenazas y controles en el puesto de usuario final

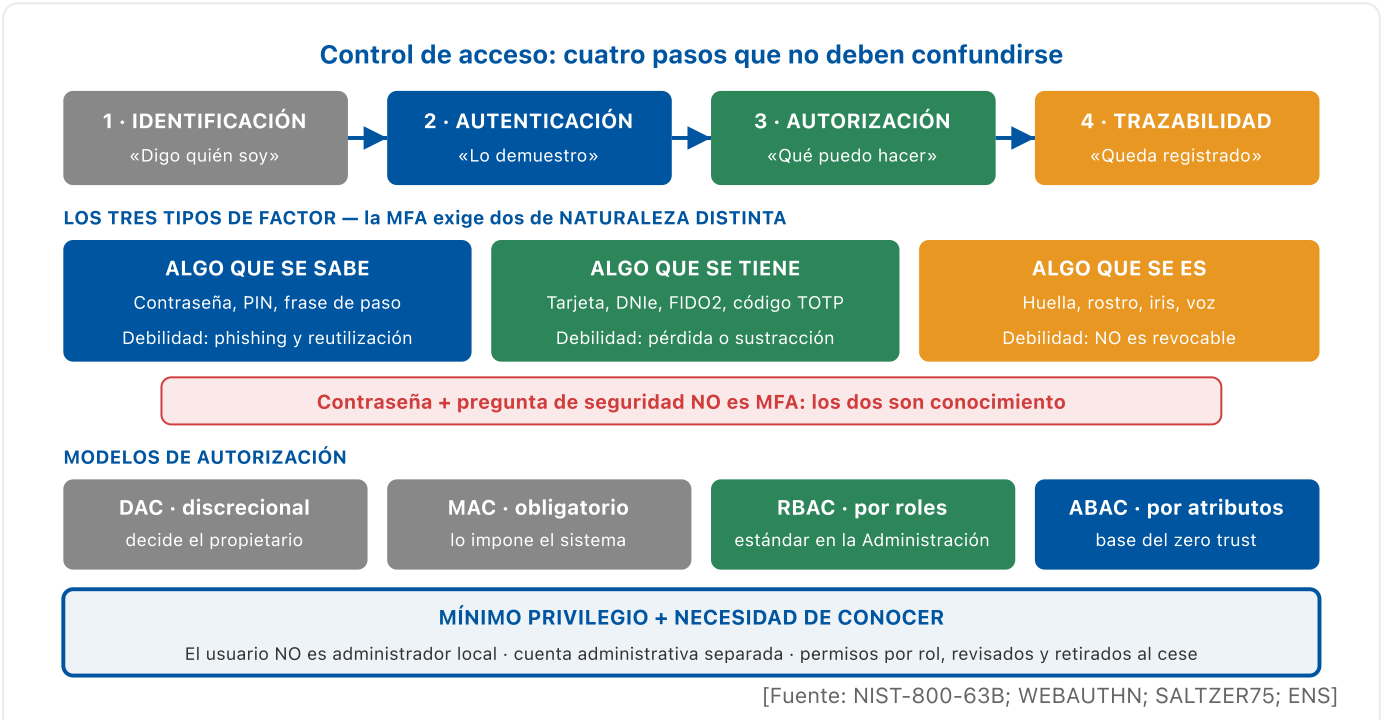
Sección: §3.1 — Seguridad en el puesto de usuario final **Propósito**: Cruzar las cuatro familias de amenazas del puesto con los controles de las cuatro naturalezas de ISO/IEC 27002 y con las dimensiones de seguridad del ENS.



[Fuente: ISO27002; ENS; ATTACK]

D9 · Control de acceso: cuatro pasos y tres factores

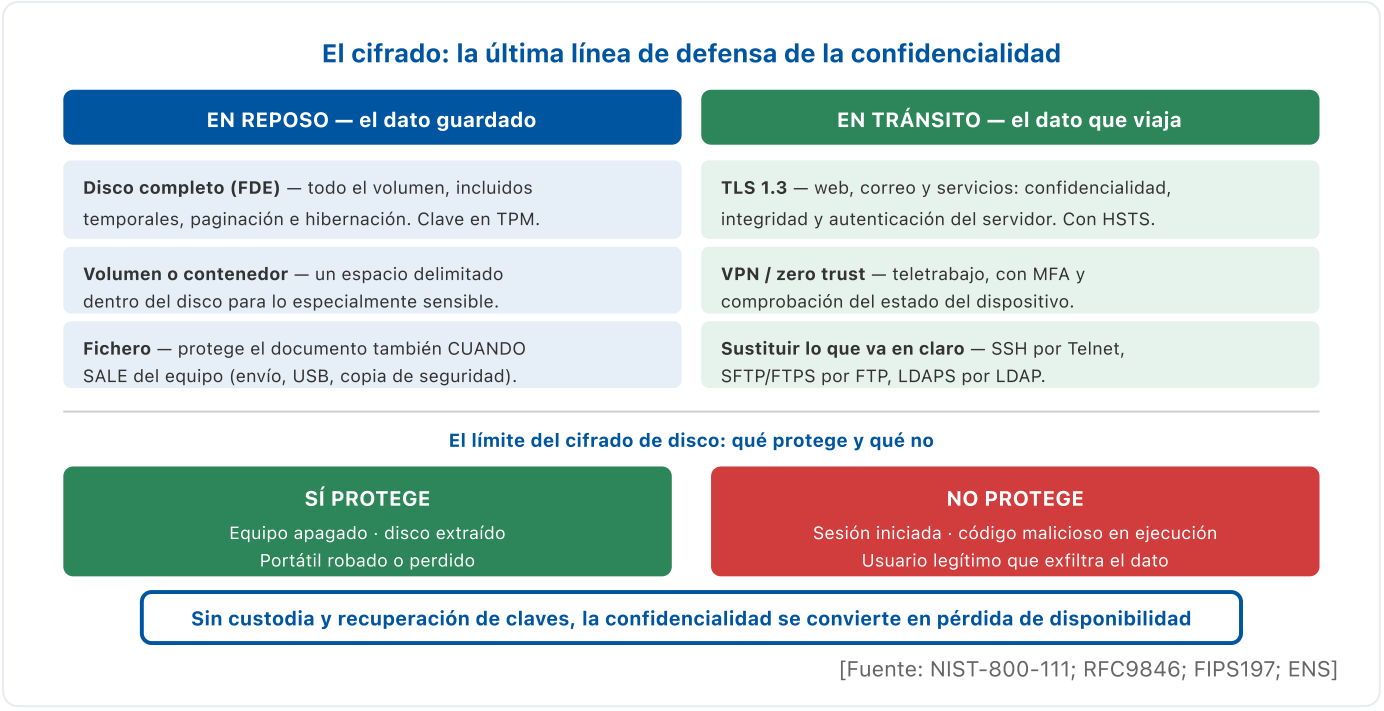
Sección: §3.2.1 — Autenticación de usuarios y principio de mínimo privilegio **Propósito**: Separar identificación, autenticación, autorización y trazabilidad, y ordenar los factores y modelos de autorización.



[Fuente: NIST-800-63B; WEBAUTHN; SALTZER75; ENS]

D10 · Cifrado en reposo y en tránsito en el puesto

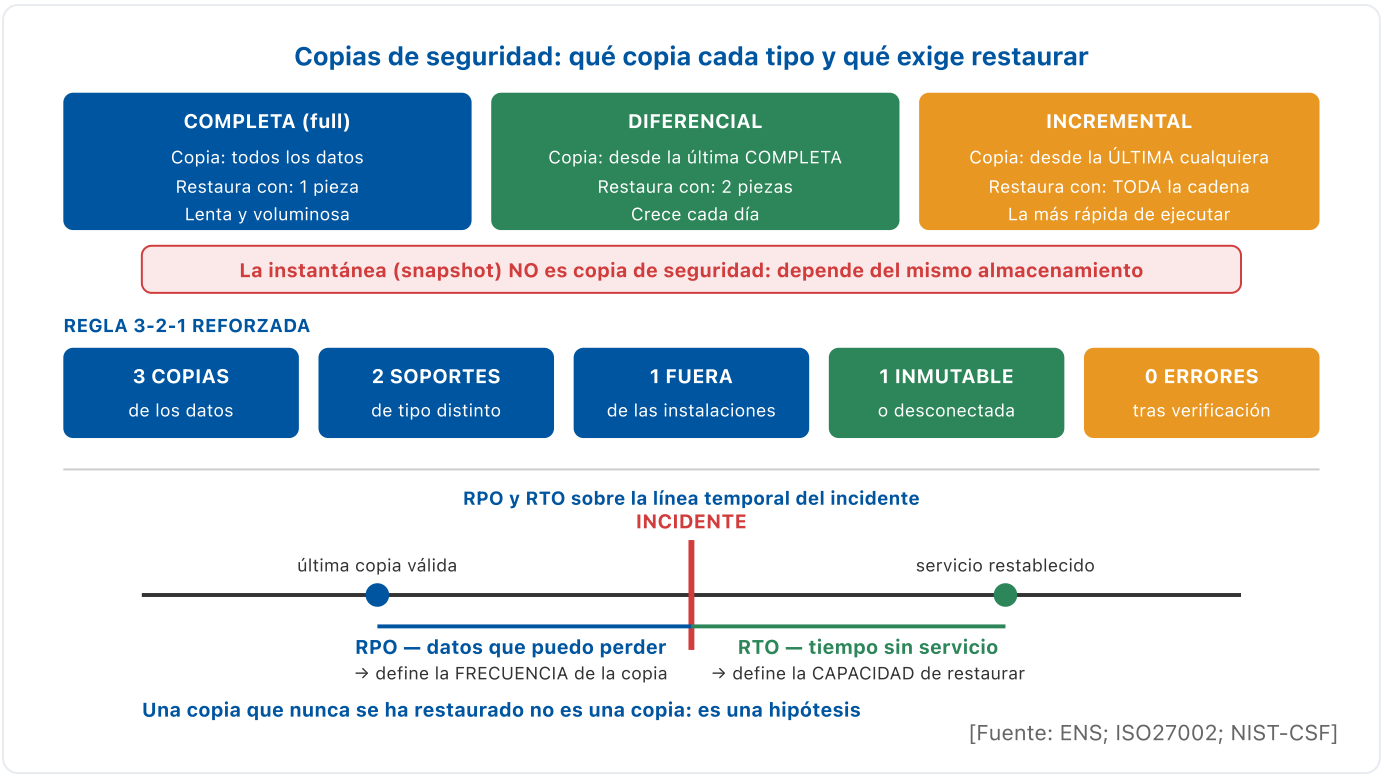
Sección: §3.2.2 — Cifrado de almacenamiento local y comunicaciones **Propósito**: Situar las tres granularidades del cifrado en reposo, los protocolos del cifrado en tránsito y, sobre todo, el límite real del cifrado de disco completo.



[Fuente: NIST-800-111; RFC9846; FIPS197; ENS]

D11 · Copias de seguridad: tipos, regla 3-2-1 y RPO/RTO

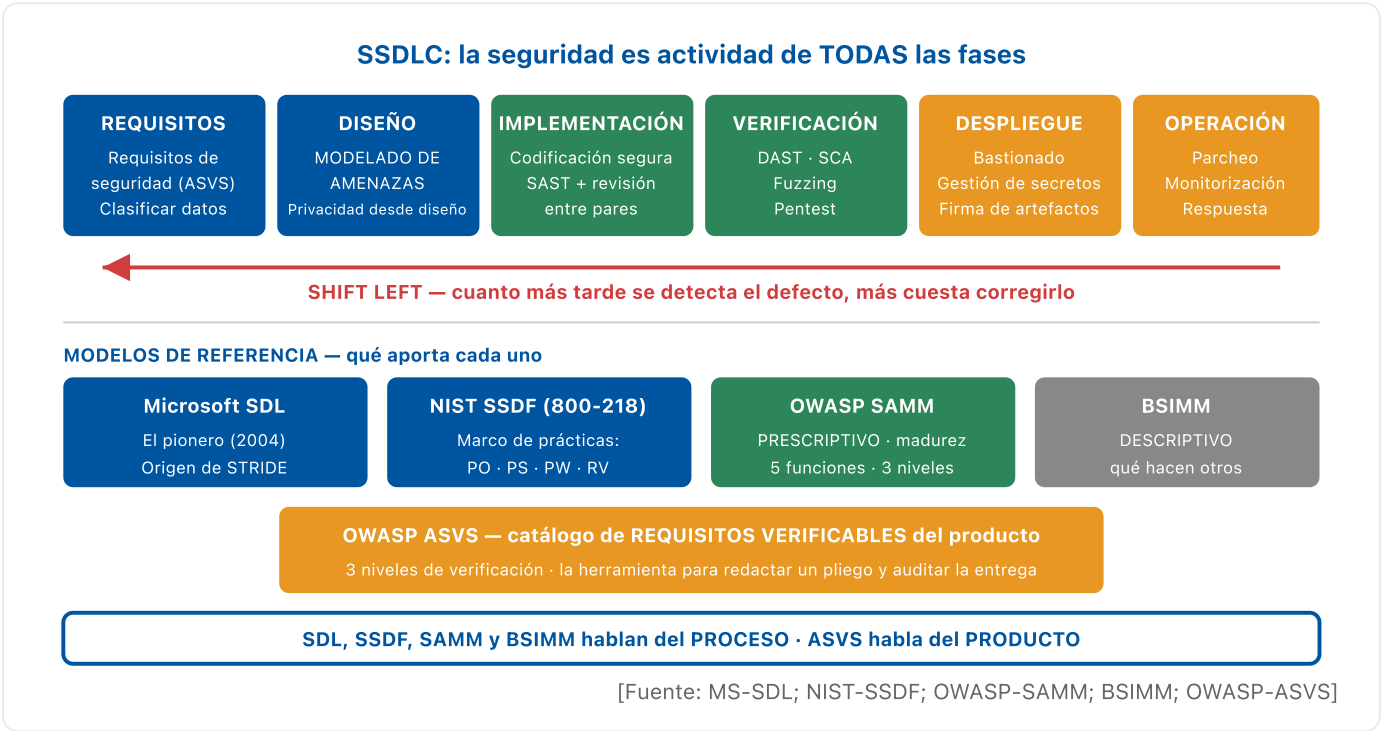
Sección: §3.3.2 — Copias de seguridad y prevención de pérdida de datos **Propósito**: Distinguir completa, diferencial e incremental por lo que copian y por lo que exige su restauración, y fijar RPO y RTO sobre la línea temporal del incidente.



[Fuente: ENS; ISO27002; NIST-CSF]

D12 · El ciclo de vida de desarrollo seguro (SSDLC)

Sección: §4.1.1 — Modelos e integración de la seguridad en el desarrollo **Propósito**: Ver la seguridad como actividad de todas las fases y situar los modelos de referencia según lo que aportan.



[Fuente: MS-SDL; NIST-SSDF; OWASP-SAMM; BSIMM; OWASP-ASVS]

D13 · STRIDE: seis amenazas y la propiedad que niega cada una

Sección: §4.1.2 — Análisis de requisitos y modelado de amenazas **Propósito**: Memorizar el emparejamiento amenaza-propiedad-contramedida y las cuatro preguntas del modelado.

STRIDE — cada amenaza niega una propiedad de seguridad

AMENAZA	PROPIEDAD QUE NIEGA	CONTRAMEDIDA TÍPICA
S · Spoofing — suplantación	AUTENTICIDAD	MFA, certificados, firma electrónica
T · Tampering — manipulación	INTEGRIDAD	Resumen y firma, TLS, validación
R · Repudiation — repudio	NO REPUDIO	Registro íntegro y sellado de tiempo
I · Information disclosure	CONFIDENCIALIDAD	Cifrado, control de acceso, error genérico
D · Denial of service	DISPONIBILIDAD	Limitación de peticiones, cuotas
E · Elevation of privilege	AUTORIZACIÓN	Mínimo privilegio, comprobar en servidor

Las cuatro preguntas del modelado de amenazas

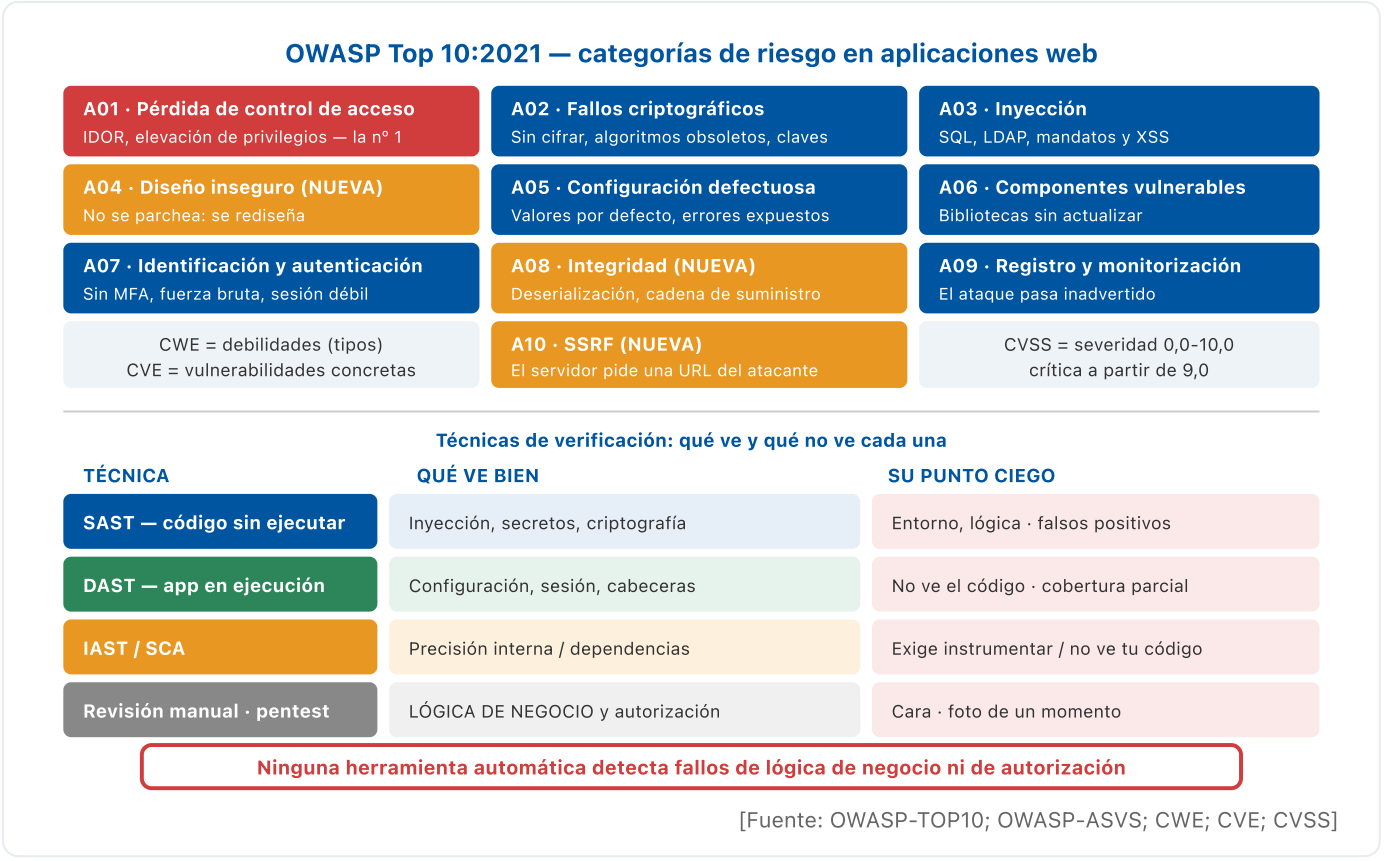
1 · ¿En qué trabajamos? → 2 · ¿Qué puede salir mal? → 3 · ¿Qué hacemos? → 4 · ¿Ha bastado?

El paso 1 exige dibujar los LÍMITES DE CONFIANZA: es donde se concentran las amenazas

[Fuente: SHOSTACK; MS-SDL]

D14 · OWASP Top 10:2021 y técnicas de verificación

Sección: §4.3 — Vulnerabilidades y verificación de la seguridad **Propósito**: Fijar las diez categorías de riesgo (señalando las tres nuevas de 2021) y contrastar las técnicas de verificación por lo que ve y por lo que no ve cada una.



Los 14 diagramas son autosuficientes: no dependen de fuentes tipográficas externas ni de imágenes, usan únicamente `system-ui` con reserva `sans-serif`, llevan `role="img"` y `aria-label` descriptivo para lectores de pantalla, y sus clases CSS están sufijadas con el número del diagrama para evitar colisiones de estilo al embeberlos todos en la misma página (lección del Tema 5).

Casos prácticos

Los tres casos recorren el servicio de referencia **cita previa y consulta de expedientes** (ver la pestaña Contenido, «Convenciones»), uno por cada bloque del tema: el **Caso 1** trabaja la **accesibilidad y la usabilidad** del servicio público; el **Caso 2**, la **confidencialidad y la disponibilidad en el puesto** desde el que se tramita; y el **Caso 3**, la **seguridad en el desarrollo** de la aplicación que lo sostiene.

Caso 1 — Auditoría de accesibilidad de la sede de cita previa

Enunciado

El Ayuntamiento ha publicado un nuevo portal de **cita previa** para las Oficinas de Atención a la Ciudadanía. Tras varias quejas vecinales, se encarga una revisión y se detecta lo siguiente:

1. Las imágenes de los iconos de cada tipo de trámite tienen el atributo `alt` con el valor del nombre del fichero (`icono-01.png`, `icono-02.png` …).
2. El calendario de selección de día **solo puede manejarse con el ratón**: no responde a la navegación con teclado.
3. Los campos obligatorios se señalan **únicamente con el borde en rojo**.
4. El vídeo explicativo de cómo pedir cita no tiene subtítulos ni transcripción.
5. La sesión **caduca a los cinco minutos sin previo aviso** y sin posibilidad de prórroga, y el formulario se pierde.
6. El pie de página **no enlaza ninguna declaración de accesibilidad**.

El área gestora propone declarar el portal «plenamente conforme», ya que un analizador automático no ha devuelto errores.

Cuestiones

Cuestión 1 — Clasificación de los incumplimientos (3 puntos). Asigne cada uno de los seis hallazgos al **principio POUR** de WCAG que vulnera e indique la pauta o el criterio afectado.

Cuestión 2 — Nivel exigible y norma aplicable (2 puntos). Indique qué nivel de conformidad es exigible al Ayuntamiento, en virtud de qué norma, y por qué en un pliego debe citarse la EN 301 549 y no solo WCAG.

Cuestión 3 — La propuesta del área gestora (2 puntos). Valore si puede declararse el portal «plenamente conforme» con el argumento expuesto y explique por qué.

Cuestión 4 — Declaración y vía de reclamación (3 puntos). Enumere el contenido mínimo de la declaración de accesibilidad e indique qué figura del organismo debe atender la queja de un vecino que no puede completar la cita con su lector de pantalla.

▾ **Ver solución orientativa**

Solución orientativa

- **C1**: (§2.1)

#	Hallazgo	Principio POUR	Pauta / criterio
1	`alt` con el nombre del fichero	**Perceptible**	1.1 Alternativas textuales (1.1.1, nivel A): la alternativa debe ser **equivalente**, no un relleno. Si el icono es decorativo, `alt=""`.
2	Calendario solo con ratón	**Operable**	2.1 Accesible por teclado (2.1.1, nivel A): toda la funcionalidad debe poder usarse solo con teclado y sin trampas de foco.
3	Obligatorios solo en rojo	**Perceptible**	1.4.1 Uso del color (nivel A); además 3.3.2 Etiquetas o instrucciones (nivel A) por la falta de indicación textual.
4	Vídeo sin subtítulos ni transcripción	**Perceptible**	1.2 Medios tempodependientes (1.2.2 Subtítulos, nivel A; 1.2.3 alternativa o audiodescripción).
5	Sesión que caduca sin aviso ni prórroga	**Operable**	2.2 Tiempo suficiente (2.2.1 Ajuste de tiempo, nivel A): debe poder desactivarse, ajustarse o prorrogarse.
6	Sin declaración de accesibilidad	*No es un criterio WCAG*	Es un incumplimiento **del art. 15 del RD 1112/2018**, no de WCAG: conviene señalar expresamente la distinción.

- **C2**: (§2.2 y §2.3) El nivel exigible es **AA** de WCAG, impuesto por el **RD 1112/2018** por remisión a la norma **UNE-EN 301 549** en su versión vigente. En un pliego debe citarse la **EN 301 549** porque es la **norma armonizada** de referencia en la contratación pública y porque su alcance es mayor: además de incorporar los criterios A y AA de WCAG para la web (cap. 9), cubre documentos no web (cap. 10), software (cap. 11), hardware y terminales de autoservicio (cap. 8), comunicación bidireccional (cap. 6) y documentación y servicios de apoyo (cap. 12). Exigir «WCAG AA» a secas dejaría fuera esos capítulos.

- **C3**: (§2.4) **No.** Es incorrecto por dos motivos. Primero, de hecho: los seis hallazgos demuestran que **hay incumplimientos**, luego el grado real es como mucho **parcialmente conforme**. Segundo, de método: una **herramienta automática detecta solo una parte de los criterios** —no puede juzgar si un `alt` es equivalente, ni si el orden del foco es lógico, ni si un vídeo tiene subtítulos correctos—, por lo que no sostiene por sí sola ninguna declaración. La evaluación válida combina revisión automática, **revisión manual experta** y **prueba con tecnologías de apoyo**. Declarar un grado superior al real es, además, un incumplimiento autónomo, porque la declaración debe reflejar el método realmente empleado.
- **C4**: (§2.4) Contenido mínimo de la declaración, conforme al modelo de la **Decisión (UE) 2018/1523**: (a) **grado de cumplimiento** —plenamente, parcialmente o no conforme—; (b) **contenido no accesible**, distinguiendo si lo es por falta de conformidad, por **carga desproporcionada** motivada o por estar **fuera del ámbito** de aplicación; (c) **alternativas accesibles** ofrecidas y datos de contacto; (d) **fecha de preparación o última revisión y método** empleado (autoevaluación o evaluación por tercero); y (e) **mecanismo de comunicación y reclamación**, con su procedimiento y plazos. La declaración debe estar enlazada de forma **visible y accesible desde todas las páginas** y revisarse al menos anualmente. La queja del vecino la atiende la **unidad responsable de accesibilidad** que el **art. 16 del RD 1112/2018** obliga a designar en cada organismo.

Criterios de evaluación

Criterio	Puntos
Los seis hallazgos correctamente asignados a principio y pauta, distinguiendo el que no es de WCAG	3
Nivel AA identificado, norma correcta citada y justificación del uso de la EN 301 549 en el pliego	2
Rechazo razonado de la declaración «plenamente conforme», con los dos motivos (de hecho y de método)	2
Contenido mínimo de la declaración e identificación de la unidad responsable de accesibilidad	3

Caso 2 — Incidente en el puesto de una Oficina de Atención a la Ciudadanía

Enunciado

En una Oficina de Atención a la Ciudadanía se producen, en la misma semana, tres sucesos:

1. Una empleada recibe un correo aparentemente remitido por el servicio informático municipal que le pide «revalidar su cuenta» en un enlace. Introduce su usuario y contraseña. Al día siguiente se detecta actividad de esa cuenta a las 03:40 desde una dirección extranjera.
2. Un inspector sufre el **robo del portátil** de trabajo, que contenía descargados en el disco local los expedientes de licencias del distrito. El equipo estaba apagado y su disco iba **cifrado con cifrado de disco completo**.
3. Un puesto queda infectado por un **ransomware** que cifra la unidad de red compartida del área. La última copia de seguridad se hizo hace 26 horas y nunca se ha realizado una prueba de restauración.

Adicionalmente, la revisión posterior constata que todos los usuarios de la oficina son **administradores locales** de su equipo, que se usa una **cuenta genérica** («oac-mostrador») en los puestos de atención, y que las pantallas están orientadas hacia el mostrador de público.

Cuestiones

Cuestión 1 — Análisis del primer suceso (2,5 puntos). Identifique el tipo de ataque, la dimensión de seguridad comprometida y **dos medidas** que lo habrían neutralizado, indicando cuál de ellas es la más eficaz y por qué.

Cuestión 2 — El portátil robado (2,5 puntos). Determine qué dimensiones de seguridad se ven afectadas, si se ha producido una brecha de confidencialidad de datos personales y qué actuaciones procede realizar. Señale además el problema de fondo que el incidente revela.

Cuestión 3 — El ransomware (3 puntos). Calcule el RPO efectivo del incidente, valore la política de copias, indique qué debe verificarse antes de dar el servicio por recuperado y explique por qué disponer de copias **no** exime de tratar el suceso como posible brecha de datos personales.

Cuestión 4 — Deficiencias estructurales (2 puntos). Enumere las tres deficiencias detectadas en la revisión, indique qué principio o medida vulnera cada una y proponga su corrección.

▾ **Ver solución orientativa**

Solución orientativa

- **C1**: (§3.1, §3.2.1) Es un ataque de **phishing** (ingeniería social) que ha derivado en el **robo de credenciales** y en un acceso no autorizado. Dimensiones comprometidas: **autenticidad** (un tercero se autentica como la empleada), **confidencialidad** (accede a información que no le corresponde) y **trazabilidad** (las actuaciones se imputan a una persona que no las hizo). Dos medidas: (a) **autenticación multifactor**, preferentemente **resistente al phishing** (FIDO2/WebAuthn o certificado en tarjeta), y (b) **formación y concienciación** con simulaciones periódicas, más filtrado de correo y reescritura de enlaces. La más eficaz es la **MFA resistente al phishing**, porque su credencial está **ligada criptográficamente al dominio legítimo** y no puede entregarse a un sitio suplantado ni siquiera por un usuario engañado; la formación reduce la probabilidad, pero depende del acierto humano en cada correo. Actuación inmediata: revocar la sesión, cambiar la credencial, revisar los registros de acceso de esa cuenta y valorar si hubo acceso a datos personales.

- **C2**: (§3.1.2, §3.2.2) Se afecta con seguridad la **disponibilidad** (el inspector pierde su herramienta y los expedientes que solo estaban en local). La **confidencialidad**, en cambio, **no se compromete** si el cifrado de disco completo estaba correctamente implantado, el equipo estaba **apagado** y la clave no era accesible (custodiada por TPM y protegida por credencial robusta): la información resulta ininteligible para el tercero. Actuaciones: documentar el incidente internamente y valorar la notificación a la autoridad de control —el RGPD contempla que, cuando los datos son ininteligibles para terceros, puede no ser necesaria la comunicación a los interesados—; **revocar** credenciales y certificados alojados en el equipo; ordenar el **borrado remoto** si el sistema de gestión de dispositivos lo permite; y denunciar la sustracción. El problema de fondo que revela el incidente es que **había información única residiendo en el disco local**: el dato de trabajo debe vivir en el repositorio corporativo, siendo el disco caché y no archivo. Si el equipo hubiera sido sustraído **con la sesión iniciada**, o sin cifrado, sí habría compromiso de confidencialidad y procedería evaluar la notificación en **72 horas** y la comunicación a los afectados si el riesgo fuera alto.

- **C3**: (§3.1.2, §3.3.1, §3.3.2) **RPO efectivo = 26 horas**: se pierde el trabajo de más de un día, lo que probablemente excede el RPO comprometido para un servicio de atención. La política de copias es **deficiente** por dos motivos independientes: la **frecuencia** no cubre el RPO necesario y, sobre todo, **nunca se ha probado la restauración**, de modo que la copia es una hipótesis, no una garantía; además debe verificarse que la copia estaba **fuera del alcance del atacante** (inmutable o desconectada), porque el ransomware moderno busca primero cifrar o borrar las copias. Antes de dar el servicio por recuperado hay que:

erradicar el código malicioso y determinar el vector de entrada; **reconstruir** el puesto desde imagen limpia y no simplemente desinfectarlo; **restaurar** desde una copia anterior a la infección y **verificar la integridad** de lo restaurado; **rotar credenciales** que hayan podido quedar expuestas; y **revisar los registros** para acotar el alcance. Tener copias **no exime** de tratar el suceso como posible **brecha de datos personales** porque el ransomware actual practica **doble extorsión**: además de cifrar, **exfiltra** la información, de modo que puede haber compromiso de confidencialidad aunque la disponibilidad se recupere.

- **C4**: (§3.2.1, §3.1.1)

Deficiencia	Qué vulnera	Corrección
Usuarios administradores locales	**Mínimo privilegio** (Saltzer y Schroeder; requisito mínimo del ENS)	Retirar el privilegio administrativo de la cuenta ordinaria; cuentas administrativas **separadas y nominativas**, no usadas para navegar ni leer correo.
Cuenta genérica compartida «oac-mostrador»	**Trazabilidad** (dimensión del ENS) e imputabilidad	Cuentas **nominativas** para todo el personal; si el puesto es compartido, sesión individual con credencial propia.
Pantallas orientadas al público	**Confidencialidad**: espionaje visual	Reorientar los monitores, instalar **filtros de privacidad** y aplicar bloqueo automático de sesión por inactividad y manual al ausentarse.

Criterios de evaluación

Criterio	Puntos
Phishing identificado, dimensiones afectadas y dos medidas con justificación de la más eficaz	2,5
Análisis correcto del portátil cifrado, con la distinción entre disponibilidad y confidencialidad y el problema de fondo del dato residente	2,5
RPO calculado, crítica de la política de copias, pasos de recuperación y razonamiento de la doble extorsión	3
Las tres deficiencias con el principio vulnerado y su corrección	2

Caso 3 — Contratación y verificación del desarrollo de la aplicación

Enunciado

El Ayuntamiento licita el desarrollo de la **nueva aplicación de cita previa y consulta de expedientes**, que tratará datos personales de la ciudadanía y se integrará con el sistema de identidad (Cl@ve y certificado electrónico). En la primera auditoría del producto entregado se detecta que:

1. La consulta de un expediente se realiza con la dirección `/expedientes/ver?id=48213` y **no se comprueba en el servidor** si el expediente pertenece al usuario autenticado.
2. El buscador construye la consulta a la base de datos **concatenando** el texto introducido por el usuario.
3. Ante un error, la aplicación devuelve al navegador la **traza completa** de la excepción, con la versión del gestor de base de datos y la ruta del servidor.
4. La aplicación arrastra una biblioteca de terceros con una **vulnerabilidad crítica publicada**, y el proveedor no dispone de inventario de dependencias.
5. El *token* de sesión (JWT) se guarda en el almacenamiento local del navegador y **no tiene fecha de caducidad**.

Cuestiones

Cuestión 1 — Clasificación de los cinco hallazgos (3 puntos). Asigne cada hallazgo a su categoría del **OWASP Top 10:2021** y a la categoría **STRIDE** correspondiente.

Cuestión 2 — Corrección técnica (3 puntos). Proponga la corrección concreta de los hallazgos 1, 2 y 5, indicando en cada caso por qué la solución «evidente» pero insuficiente no sirve.

Cuestión 3 — Requisitos que debieron figurar en el pliego (2 puntos). Indique **cuatro** exigencias de seguridad que debieron formar parte del contrato para prevenir esta situación, e identifique el catálogo de OWASP idóneo para redactarlas.

Cuestión 4 — Verificación y cadena de suministro (2 puntos). Explique qué técnicas de análisis habrían detectado cada tipo de hallazgo y qué debe implantar el proveedor para responder con rapidez a la publicación de una vulnerabilidad en una dependencia.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§4.1.2, §4.3.1)

#	Hallazgo	OWASP Top 10:2021	STRIDE
1	Sin comprobación de propiedad del expediente (IDOR)	**A01** Pérdida de control de acceso	**E** — Elevación de privilegios
2	Consulta construida por concatenación	**A03** Inyección	**T** — Manipulación (y, según el caso, **I**)
3	Traza completa devuelta al navegador	**A05** Configuración de seguridad defectuosa	**I** — Revelación de información
4	Biblioteca vulnerable sin inventario	**A06** Componentes vulnerables y desactualizados (con vertiente de **A08** en cuanto a integridad de la cadena de suministro)	**T** — Manipulación
5	JWT sin caducidad en almacenamiento local	**A07** Fallos de identificación y autenticación	**S** — Suplantación

- **C2**: (§4.2.2, §4.2.3)

  - **Hallazgo 1**: la corrección es **comprobar la autorización en el servidor, en cada petición**, verificando que el expediente solicitado pertenece al usuario autenticado, denegando por defecto y **registrando** el intento fallido. Lo insuficiente sería **ocultar el enlace en el menú** o cifrar el identificador: ocultar en el cliente no es autorizar, y un identificador opaco sigue siendo válido si se obtiene por otra vía (es seguridad por oscuridad). Usar identificadores no predecibles (UUID) es una medida **complementaria**, para dificultar la enumeración masiva.
  - **Hallazgo 2**: la corrección es usar **consultas parametrizadas** (sentencias preparadas), de modo que la consulta se compile con marcadores y los valores viajen aparte sin poder alterar la estructura. Lo insuficiente sería **escapar comillas** o filtrar palabras reservadas: las listas negras siempre quedan incompletas y el escapado manual depende del motor. Como defensa en profundidad, el usuario con el que la aplicación se conecta a la base de datos debe tener **permisos mínimos**.
  - **Hallazgo 5**: el *token* debe tener **vida corta** con caducidad (`exp`) validada, acompañarse de un **token de refresco revocable en el servidor** con rotación, y almacenarse preferentemente en una **cookie** `HttpOnly` + `Secure` + `SameSite` en lugar del almacenamiento local, complementada con protección **CSRF**. Debe además rechazarse el algoritmo `none` y validarse firma, emisor y audiencia. Lo insuficiente sería **alargar la vida del token** o confiar en que el cliente lo borre al cerrar sesión: un JWT es **autocontenido y no revocable por sí mismo**.

- **C3**: (§4.1.1, §4.1.2) Cuatro exigencias contractuales, entre otras posibles: (a) **conformidad con el nivel aplicable de OWASP ASVS**, verificable en la recepción; (b) **modelado de amenazas** documentado en la fase de diseño y actualizado ante cambios relevantes; (c) **SAST y SCA automáticos en cada confirmación** del repositorio, con puertas de calidad que detengan el despliegue por encima de un umbral de severidad, más **DAST** sobre preproducción; (d) **prueba de penetración por un tercero independiente** antes de la puesta en producción y tras cada cambio mayor, con plan de corrección y verificación. Cabe añadir la entrega de un **SBOM** actualizado, el compromiso de plazos de corrección por severidad y la prohibición de usar datos reales en entornos no productivos. El catálogo idóneo para redactarlas es **OWASP ASVS**, porque es un **catálogo de requisitos verificables** del producto, mientras que el Top 10 es un documento de concienciación y SAMM mide la madurez del proceso del proveedor.

- **C4**: (§4.3.2, §4.3.3) Detección por técnica: el **SAST** habría señalado la concatenación del hallazgo 2 y, posiblemente, el manejo del *token*; el **DAST** habría detectado la traza expuesta del hallazgo 3 y la configuración de la sesión del hallazgo 5; el **SCA** habría identificado inmediatamente la dependencia vulnerable del hallazgo 4; y el hallazgo 1 —fallo de **autorización**— solo lo detectan de forma fiable la **revisión manual de código** y la

prueba de penetración, porque ninguna herramienta automática entiende la lógica de negocio ni sabe qué expediente corresponde a qué persona. Para responder con rapidez a una vulnerabilidad publicada, el proveedor debe implantar: **SBOM** en formato normalizado (SPDX o CycloneDX) mantenido en cada versión, **SCA continuo** integrado en la construcción, **fijación de versiones y verificación de integridad** de los artefactos mediante repositorio interno y firma, una **política de actualización** que distinga la corrección de seguridad de la evolutiva y la priorice por severidad (**CVSS**) y explotación activa, y un procedimiento de **respuesta a vulnerabilidades** con plazos comprometidos y verificación posterior de la corrección.

Criterios de evaluación

Criterio	Puntos
Los cinco hallazgos correctamente clasificados en OWASP Top 10 y en STRIDE	3
Correcciones técnicas correctas de los hallazgos 1, 2 y 5, con la crítica de la solución insuficiente en cada caso	3
Cuatro exigencias contractuales pertinentes y ASVS identificado como catálogo idóneo	2
Técnicas de detección asignadas por hallazgo, con la salvedad del fallo de autorización, y medidas de cadena de suministro	2

Fuentes

Tier 1 — Normas, estándares y textos legales

ID	Referencia
`[WCAG22]`	W3C. *Web Content Accessibility Guidelines (WCAG) 2.2*, Recomendación W3C de 5 de octubre de 2023. w3.org/TR/WCAG22. Norma de referencia mundial de accesibilidad del contenido web: 4 principios (POUR), 13 pautas y criterios de conformidad en niveles A, AA y AAA.
`[WCAG21]`	W3C. *Web Content Accessibility Guidelines (WCAG) 2.1*, Recomendación W3C de 5 de junio de 2018. w3.org/TR/WCAG21. Versión incorporada por la norma armonizada europea vigente.
`[WCAG20]`	W3C. *Web Content Accessibility Guidelines (WCAG) 2.0*, Recomendación W3C de 11 de diciembre de 2008; adoptada como norma internacional **ISO/IEC 40500:2012**.
`[WAI-ARIA]`	W3C. *Accessible Rich Internet Applications (WAI-ARIA) 1.2* y *ARIA Authoring Practices Guide*. w3.org/TR/wai-aria-1.2. Semántica accesible (`role` , `aria-*`) para componentes de interfaz dinámicos.
`[ATAG20]`	W3C. *Authoring Tool Accessibility Guidelines (ATAG) 2.0*. w3.org/TR/ATAG20. Accesibilidad de las **herramientas de autor** (gestores de contenidos, editores).
`[UAAG20]`	W3C. *User Agent Accessibility Guidelines (UAAG) 2.0*. w3.org/TR/UAAG20. Accesibilidad de los **agentes de usuario** (navegadores, reproductores).
`[WCAG-EM]`	W3C WAI. *Website Accessibility Conformance Evaluation Methodology (WCAG-EM) 1.0*. w3.org/TR/WCAG-EM. Metodología de los cinco pasos para evaluar la conformidad de un sitio completo.
`[ACT-RULES]`	W3C. *Accessibility Conformance Testing (ACT) Rules Format 1.0* y catálogo de reglas ACT. w3.org/TR/act-rules-format. Base de la armonización entre herramientas automáticas de evaluación.
`[EN301549]`	ETSI/CEN/CENELEC. **EN 301 549** *Requisitos de accesibilidad para productos y servicios TIC* (v3.2.1, 2021). Norma armonizada europea de accesibilidad TIC; su capítulo 9 incorpora WCAG para web, el 10 para documentos y el 11 para software, con capítulos específicos de hardware (8), comunicación bidireccional (6) y contenidos audiovisuales (7).

ID	Referencia
[ISO09241-11]	ISO 9241-11:2018. *Ergonomics of human-system interaction — Part 11: Usability: Definitions and concepts*. Define usabilidad como **eficacia + eficiencia + satisfacción** en un contexto de uso específico.
[ISO09241-110]	ISO 9241-110:2020. *Part 110: Interaction principles*. Los siete principios de interacción (idoneidad para la tarea, carácter autodescriptivo, conformidad con las expectativas, aprendizaje, controlabilidad, robustez frente a errores de uso y compromiso del usuario).
[ISO09241-210]	ISO 9241-210:2019. *Part 210: Human-centred design for interactive systems*. Proceso iterativo de diseño centrado en el usuario en cuatro actividades.
[ISO09241-171]	ISO 9241-171:2008. *Part 171: Guidance on software accessibility*. Requisitos y recomendaciones de accesibilidad del software.
[ISO025010]	ISO/IEC 25010:2023 (serie SQuaRE). *Modelo de calidad del producto software*, edición vigente, que anula y sustituye a la de 2011: adecuación funcional, eficiencia de desempeño, compatibilidad, **capacidad de interacción** (antes «usabilidad»), fiabilidad, **seguridad**, mantenibilidad, flexibilidad (antes «portabilidad») y protección (*safety*), con sus subcaracterísticas.
[ISO025010-2011]	ISO/IEC 25010:2011 (serie SQuaRE). *System and software quality models*: ocho características (adecuación funcional, eficiencia de desempeño, compatibilidad, usabilidad, fiabilidad, seguridad, mantenibilidad y portabilidad), con la accesibilidad como subcaracterística de la usabilidad. Anulada y sustituida por la ISO/IEC 25010:2023. Se conserva la referencia porque es la que recogen los temarios al uso.
[ISO025019]	ISO/IEC 25019:2023 (serie SQuaRE). *Quality-in-use model*. Con la 25002 y la 25010:2023, anula y sustituye a la 25010:2011, de la que separa el modelo de calidad en uso: beneficio, ausencia de riesgo y aceptabilidad.
[ISO025000]	ISO/IEC 25000 (SQuaRE). *Systems and software Quality Requirements and Evaluation*. Marco general de la familia: modelos de calidad (2501n), medición (2502n), requisitos (2503n) y

ID	Referencia
00]	evaluación (2504n).
[ISO27001]	UNE-EN ISO/IEC 27001. *Sistemas de gestión de la seguridad de la información — Requisitos*. Modelo de gestión basado en riesgos y mejora continua.
[ISO27002]	UNE-EN ISO/IEC 27002:2022. *Controles de seguridad de la información*. 93 controles en cuatro temas (organizativos, personas, físicos y tecnológicos); referencia directa de los controles del puesto de usuario.
[ISO27034]	ISO/IEC 27034. *Application security*. Marco de seguridad de aplicaciones a lo largo de su ciclo de vida.
[ISO29119]	ISO/IEC/IEEE 29119. *Software testing*. Marco de referencia de las pruebas de software, incluidas las de seguridad.
[CDPD]	Instrumento de Ratificación de la **Convención sobre los derechos de las personas con discapacidad** (Nueva York, 13 de diciembre de 2006). Define el **diseño universal** (art. 2) y obliga a garantizar la **accesibilidad** a los sistemas y tecnologías de la información (art. 9).
[TRLGDPD]	Real Decreto Legislativo 1/2013, de 29 de noviembre, texto refundido de la **Ley General de derechos de las personas con discapacidad y de su inclusión social**. Define *accesibilidad universal* y *diseño para todas las personas* (art. 2) y regula las condiciones básicas de accesibilidad.
[DIR2016-2102]	**Directiva (UE) 2016/2102** del Parlamento Europeo y del Consejo, de 26 de octubre de 2016, sobre la accesibilidad de los sitios web y aplicaciones para dispositivos móviles de los organismos del sector público.
[RD1112-2018]	**Real Decreto 1112/2018**, de 7 de septiembre, sobre accesibilidad de los sitios web y aplicaciones para dispositivos móviles del sector público. Transpone la Directiva 2016/2102: exige nivel **AA**, **declaración de accesibilidad**, mecanismo de comunicación y reclamación, y designa la **unidad responsable de accesibilidad** en cada organismo.
[DEC2018-	**Decisión de Ejecución (UE) 2018/1523** de la Comisión, por la que se establece el **modelo de declaración de accesibilidad**.

ID	Referencia
[1523]	
[DEC2018-1524]	**Decisión de Ejecución (UE) 2018/1524** de la Comisión, por la que se establece la **metodología de seguimiento** y las disposiciones de presentación de informes de los Estados miembros.
[DIR2019-882]	**Directiva (UE) 2019/882** (*European Accessibility Act*, EAA), sobre los requisitos de accesibilidad de los productos y servicios. Extiende las exigencias de accesibilidad al **sector privado** (comercio electrónico, banca, transporte, libros electrónicos, servicios de comunicaciones).
[LEY11-2023]	**Ley 11/2023**, de 8 de mayo, de trasposición de Directivas de la Unión Europea, cuyo Libro I traspone la Directiva (UE) 2019/882 sobre requisitos de accesibilidad de los productos y servicios.
[ENS]	**Real Decreto 311/2022**, de 3 de mayo, por el que se regula el **Esquema Nacional de Seguridad**. Principios básicos, requisitos mínimos, categorización de sistemas (Básica/Media/Alta) y medidas del Anexo II (marco organizativo, marco operacional y medidas de protección).
[ENI]	**Real Decreto 4/2010**, de 8 de enero, por el que se regula el **Esquema Nacional de Interoperabilidad**, y sus Normas Técnicas de Interoperabilidad.
[RGPD]	**Reglamento (UE) 2016/679** (RGPD). Art. 5 (principios), **art. 25 (protección de datos desde el diseño y por defecto)**, art. 32 (seguridad del tratamiento), arts. 33-34 (notificación de brechas) y art. 35 (evaluación de impacto).
[LOPDGDD]	**Ley Orgánica 3/2018**, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales. Título X: derechos digitales en el ámbito laboral (arts. 87-91: intimidad ante dispositivos digitales, videovigilancia, geolocalización y desconexión digital).
[LPACAP]	**Ley 39/2015**, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas. Derecho de relación electrónica y asistencia en el uso de medios electrónicos.
[NIST-	NIST. *SP 800-218: Secure Software Development Framework (SSDF) v1.1*. Cuatro grupos de prácticas: preparar la organización (PO), proteger el software (PS), producir software bien

ID	Referencia
`SSDF]`	asegurado (PW) y responder a las vulnerabilidades (RV).
`[NIST-800-63B]`	NIST. *SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management*. Niveles de garantía de autenticación (AAL1-AAL3), tipos de autenticador y recomendaciones sobre contraseñas.
`[NIST-800-111]`	NIST. *SP 800-111: Guide to Storage Encryption Technologies for End User Devices*. Cifrado de disco completo, de volumen y de fichero en el puesto de usuario.
`[NIST-800-88]`	NIST. *SP 800-88 Rev. 1: Guidelines for Media Sanitization*. Borrado seguro (*clear*, *purge*, *destroy*) de soportes al retirar un equipo.
`[NIST-CSF]`	NIST. *Cybersecurity Framework (CSF) 2.0*. Funciones Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar.
`[CWE]`	MITRE. *Common Weakness Enumeration (CWE)* y **CWE Top 25 Most Dangerous Software Weaknesses**. Catálogo canónico de **debilidades** de software. cwe.mitre.org.
`[CVE]`	MITRE / NIST NVD. *Common Vulnerabilities and Exposures (CVE)* y *National Vulnerability Database*. Identificación única de **vulnerabilidades** concretas en productos concretos.
`[CVSS]`	FIRST. *Common Vulnerability Scoring System (CVSS)* v3.1 y v4.0. Métrica de severidad (0,0-10,0) con grupos base, temporal/de amenaza y ambiental.
`[CAPEC]`	MITRE. *Common Attack Pattern Enumeration and Classification*. Catálogo de patrones de ataque, complementario de CWE.
`[ATTACK]`	MITRE. *ATT&CK — Enterprise Matrix*. Base de conocimiento de tácticas y técnicas adversarias observadas, usada para orientar la defensa del puesto de usuario.

ID	Referencia
`[OWASP-TOP10]`	OWASP Foundation. *OWASP Top 10:2021* — los diez riesgos más críticos en aplicaciones web. owasp.org/Top10.
`[OWASP-ASVS]`	OWASP Foundation. *Application Security Verification Standard (ASVS)*. Catálogo de requisitos verificables de seguridad de aplicaciones, organizado en tres niveles de verificación.
`[OWASP-SAMM]`	OWASP Foundation. *Software Assurance Maturity Model (SAMM) 2.0*. Modelo de madurez del desarrollo seguro en cinco funciones de negocio (Gobierno, Diseño, Implementación, Verificación y Operaciones).
`[OWASP-PROACTIVE]`	OWASP Foundation. *Top 10 Proactive Controls*. Controles preventivos que un equipo de desarrollo debe incorporar por defecto.
`[OWASP-CHEAT]`	OWASP Foundation. *Cheat Sheet Series* (Input Validation, Session Management, Password Storage, Logging, XSS Prevention, SQL Injection Prevention…). cheatsheetseries.owasp.org.
`[RFC6749]`	IETF. *RFC 6749: The OAuth 2.0 Authorization Framework*. Delegación de autorización mediante *tokens* de acceso.
`[RFC7636]`	IETF. *RFC 7636: Proof Key for Code Exchange (PKCE)*. Protección del flujo de código de autorización en clientes públicos.
`[RFC7519]`	IETF. *RFC 7519: JSON Web Token (JWT)*. Formato de *token* autocontenido y firmado.
`[RFC8725]`	IETF. *RFC 8725: JSON Web Token Best Current Practices* (BCP 225). Prohíbe aceptar el algoritmo `none` y exige validar emisor, audiencia y caducidad.

ID	Referencia
[RFC9700]	IETF. *RFC 9700: Best Current Practice for OAuth 2.0 Security* (BCP 240). Consolida las recomendaciones de seguridad de OAuth 2.0.
[RFC9846]	IETF. *RFC 9846: The Transport Layer Security (TLS) Protocol Version 1.3* (julio de 2026). Obsoleta los RFC 5077, 5246, 6961, 7627, 8422 y 8446: es la especificación vigente de TLS 1.3 y sustituye a la de 2018. Cifrado de las comunicaciones.
[RFC8446]	IETF. *RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3* (agosto de 2018). Obsoletado por el RFC 9846. Se conserva la referencia porque es la que recogen los temarios al uso.
[RFC6797]	IETF. *RFC 6797: HTTP Strict Transport Security (HSTS)*.
[WEBAUTHN]	W3C. *Web Authentication (WebAuthn) Level 2/3* y FIDO Alliance, *FIDO2/CTAP*. Autenticación con criptografía de clave pública resistente a la suplantación de identidad (*phishing*).
[FIPS197]	NIST. *FIPS 197: Advanced Encryption Standard (AES)*. Algoritmo de cifrado simétrico de referencia.

Tier 2 — Guías metodológicas, catálogos y literatura fundacional

ID	Referencia
`[NIELSEN]`	Nielsen, J. *10 Usability Heuristics for User Interface Design* (1994, revisadas). nngroup.com. Heurísticas de referencia para la evaluación experta de interfaces.
`[SHNEIDERMAN]`	Shneiderman, B. et al. *Designing the User Interface* — las **ocho reglas de oro** del diseño de interfaces.
`[NORMAN]`	Norman, D. A. *The Design of Everyday Things* (rev. 2013). Affordances, significantes, modelo conceptual y diseño centrado en la persona.
`[CUD]`	Center for Universal Design, North Carolina State University (Ronald L. Mace et al., 1997). *The Principles of Universal Design* — los **siete principios** del diseño universal.
`[UDL]`	CAST. *Universal Design for Learning (UDL) Guidelines*. Aplicación del diseño universal al ámbito del aprendizaje.
`[WAI]`	W3C Web Accessibility Initiative. *Introduction to Web Accessibility*, *Easy Checks*, *Evaluation Tools List*, *How to Meet WCAG (Quick Reference)*. w3.org/WAI.
`[SALTZER75]`	Saltzer, J. H. y Schroeder, M. D. *The Protection of Information in Computer Systems* (Proceedings of the IEEE, 1975). Los **ocho principios de diseño seguro** (mínimo privilegio, economía de mecanismo, valores por defecto seguros, mediación completa, diseño abierto, separación de privilegios, mínimo mecanismo común y aceptabilidad psicológica).
`[SHOSTACK]`	Shostack, A. *Threat Modeling: Designing for Security* (2014). Método de las cuatro preguntas y modelo **STRIDE**.
`[MS-SDL]`	Microsoft. *Security Development Lifecycle (SDL)* — prácticas de seguridad integradas en el ciclo de desarrollo; origen del modelo STRIDE.
`[BSIMM]`	Synopsys. *Building Security In Maturity Model (BSIMM)*. Modelo descriptivo de madurez basado en la observación de programas reales de seguridad en el desarrollo.

ID	Referencia
`[CCN-STIC]`	Centro Criptológico Nacional. *Guías CCN-STIC* de la serie 800 (implantación del ENS) y 500/600 (configuración segura de sistemas y aplicaciones). ccn-cert.cni.es. Referencia de bastionado en el sector público español.
`[CCN-ENS]`	Centro Criptológico Nacional. *CCN-STIC 803 (valoración de sistemas)*, *CCN-STIC 804 (guía de implantación del ENS)* y perfiles de cumplimiento específicos.
`[OBSERVATORIO]`	Ministerio para la Transformación Digital y de la Función Pública. *Observatorio de Accesibilidad Web* y *Guía de validación de accesibilidad web*. administracionelectronica.gob.es. Herramienta de seguimiento de la Administración española.
`[AEPD-GUIA]`	Agencia Española de Protección de Datos. *Guía de protección de datos por defecto* y *Guía de privacidad desde el diseño*. aepd.es.
`[SBOM]`	Linux Foundation *SPDX* y OWASP *CycloneDX*. Formatos normalizados de **lista de materiales de software (SBOM)** para inventariar dependencias.
`[SEMVER]`	*Semantic Versioning 2.0.0*. semver.org. Convenio de versionado usado en la gestión de dependencias.
`[EPUB-A11Y]`	W3C / DAISY. *EPUB Accessibility 1.1* y perfiles de documento accesible. Referencia para la accesibilidad de documentos publicados.
`[PDF-UA]`	ISO 14289-1 (**PDF/UA**). Formato de documento PDF accesible universalmente, exigido por el capítulo 10 de la EN 301 549.

Tier 3 — Marco institucional y del puesto (contexto)

ID	Referencia
`[BOAM 10032]`	BOAM 10.032 (23-dic-2025). Bases específicas TIC C1 Ayuntamiento de Madrid — temario oficial de la convocatoria.
`[PSI-MADRID]`	Política de Seguridad de la Información del Ayuntamiento de Madrid y normativa municipal de uso de los sistemas de información, cuyo establecimiento exige el art. 12 del ENS `[ENS]` a toda entidad del sector público. Marco del que cuelgan las normas concretas del puesto de usuario municipal.
`[MADRID-A11Y]`	Declaración de accesibilidad y unidad responsable de accesibilidad del Ayuntamiento de Madrid, publicadas conforme al art. 15 del RD 1112/2018 `[RD1112-2018]`.
`[LEYCAPITALIDAD]`	Ley 22/2006, de 4 de julio, de Capitalidad y de Régimen Especial de Madrid. Marco competencial del Ayuntamiento citado como contexto de los ejemplos.

Las referencias Tier 1 fijan el fundamento normativo y técnico del tema en sus tres bloques: para la accesibilidad y la usabilidad, las recomendaciones del W3C (WCAG, ARIA, ATAG, UAAG, WCAG-EM), las normas ISO de ergonomía y calidad (9241 y 25010) y la cadena jurídica que va de la Convención de la ONU al RD 1112/2018 y a la Ley 11/2023; para el puesto de usuario final, ISO/IEC 27002, el Esquema Nacional de Seguridad y las publicaciones especiales del NIST; y para el desarrollo seguro, el SSDF del NIST, los catálogos de MITRE (CWE, CVE, CAPEC, ATT&CK), los proyectos canónicos de OWASP (Top 10, ASVS, SAMM, Proactive Controls) y los RFC del IETF sobre OAuth 2.0, JWT y TLS. Tier 2 aporta la metodología y la literatura fundacional (Nielsen, Shneiderman, Norman, Saltzer y Schroeder, Shostack) y las guías del CCN y del Observatorio de Accesibilidad, que son las que un técnico del sector público español maneja en la práctica. Tier 3 sitúa el marco municipal de los ejemplos.